Templates

Security, Privacy, Compliance

- Security & Privacy (SEC)
- Identity & Access (IAM)
- Threat Modeling & Abuse Prevention (TMA)
- Secrets & Key Management (SKM)
- Privacy Modeling & Data Minimization (PRIV)
- Audit Logging & Forensics (AUDIT)
- Compliance & Risk (COMP)

Security, Privacy, Compliance

Security & Privacy (SEC)
SEC-01 Security Overview (scope, principles, threat posture)
SEC-02 Security Architecture (trust boundaries, data flows)
SEC-03 Security Requirements (baseline controls checklist)
SEC-04 Vulnerability Management (patching, scans, SLAs)
SEC-05 Incident Response Plan (detect, contain, recover)
SEC-06 Security Monitoring (signals, alerts, dashboards)
SEC-07 Secure SDLC Policy (reviews, CI gates, dependencies)
SEC-08 Security Exceptions Process (approvals, expiries, audit)
SEC-09 Security Testing Plan (SAST/DAST/pen test, coverage)
SEC-10 Security Runbooks (common incidents, operator actions)

Identity & Access (IAM)
IAM-01 Role & Permission Model (roles, permissions, inheritance)
IAM-02 AuthN Methods (passwordless, SSO, MFA binding)
IAM-03 Session Management Policy (expiry, rotation, device binding)
IAM-04 Authorization Enforcement Points (where checks happen)
IAM-05 Service-to-Service Auth (mTLS/JWT, SPIFFE/SPIRE notes)
IAM-06 Admin & Privileged Access Policy (break-glass, step-up)
IAM-07 Account Lifecycle (provision, deprovision, recovery)
IAM-08 API Key Policy (creation, scoping, rotation, revocation)
IAM-09 Access Reviews (periodic review, attestations)
IAM-10 Access Observability (auth logs, auth failures, metrics)

Threat Modeling & Abuse Prevention (TMA)
TMA-01 Threat Model Scope & Method (assets, actors, STRIDE)
TMA-02 Abuse Case Catalog (by abuse_id)
TMA-03 Attack Surface Inventory (endpoints, clients, integrations)
TMA-04 Risk Register (threats, likelihood, impact, mitigations)
TMA-05 Mitigation Mapping (threat → control → owner)
TMA-06 Rate Limit & Bot Defense Strategy (captcha, device signals)

TMA-07 Content/Message Abuse Controls (spam, harassment, scams)
TMA-08 Fraud/Payment Abuse Controls (ties to PAY-08)
TMA-09 Security Validation (tests, drills, red team-lite)
TMA-10 TMA Runbooks (triage, containment actions)

Secrets & Key Management (SKM)
SKM-01 Secrets Inventory (by secret_id)
SKM-02 Storage & Access Policy (vaults, env scoping, least privilege)
SKM-03 Rotation Policy (schedules, triggers, overlap windows)
SKM-04 Key Types & Usage (signing, encryption, API keys, TLS)
SKM-05 KMS/HSM Strategy (providers, boundaries, responsibilities)
SKM-06 Certificate Management (issuance, renewal, revocation)
SKM-07 Secret Distribution (runtime fetch, sidecars, CI rules)
SKM-08 Compromise Response (detect, rotate, revoke, audit)
SKM-09 Logging & Redaction Rules (no secrets in logs)
SKM-10 Observability & Alerts (access spikes, failures, drift)

Privacy Modeling & Data Minimization (PRIV)
PRIV-01 Data Inventory (by data_class/entity)
PRIV-02 PII Classification Model (types, sensitivity)
PRIV-03 Data Minimization Rules (collect/store/share)
PRIV-04 Consent Model (capture, storage, enforcement)
PRIV-05 Retention & Deletion Policy (TTL, DSAR, legal hold)
PRIV-06 Data Sharing Map (internal/external recipients)
PRIV-07 Privacy by Design Checklist (gates, reviews)
PRIV-08 Anonymization/Pseudonymization Rules (hashing, tokenization)
PRIV-09 Privacy Incident Handling (breach response, notifications)
PRIV-10 Privacy Metrics & Audits (coverage, violations)

Audit Logging & Forensics (AUDIT)
AUDIT-01 Audit Event Catalog (by event_type)
AUDIT-02 Audit Schema (required fields, correlation IDs)
AUDIT-03 Capture Rules (what must be logged, where)
AUDIT-04 Tamper Evidence & Integrity (append-only, hashing)
AUDIT-05 Retention & Access Controls (who can view, how long)
AUDIT-06 Investigation Workflow (queries, exports, chain-of-custody)
AUDIT-07 Admin/Privileged Actions Audit (special handling)
AUDIT-08 Redaction & PII Handling (safe storage of audit data)
AUDIT-09 Alerts & Anomaly Detection (suspicious patterns)
AUDIT-10 Forensics Runbooks (incident support procedures)

Compliance & Risk (COMP)
COMP-01 Compliance Scope (frameworks, in/out scope)
COMP-02 Control Matrix (control_id → requirement → evidence)
COMP-03 Vendor Risk Management (third-party reviews, DPAs)

COMP-04 Policy & Training Requirements (who must do what)
COMP-05 Data Processing Agreements & Records (RoPA, DPA pointers)
COMP-06 Regulatory Requirements (CAN-SPAM, PCI, SOC2, HIPAA, etc.)
COMP-07 Risk Assessments (periodic, triggers, owners)
COMP-08 Exception Management (waivers, expiries, reviews)
COMP-09 Evidence Collection Plan (artifacts, cadence, storage)
COMP-10 Compliance Reporting & Audits (internal/external audits)

Security & Privacy (SEC)

SEC-01

SEC-01 — Security Overview (scope, principles, threat posture)
Header Block
template_id: SEC-01
title: Security Overview (scope, principles, threat posture)
type: security_overview
template_version: 1.0.0
output_path: 10_app/security/SEC-01_Security_Overview.md
compliance_gate_id: TMP-05.PRIMARY.SEC
upstream_dependencies: ["SPEC_INDEX", "PRD-06"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "PRD-06", "SEC-02"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Create the single, canonical overview of the security posture for the product: scope, security principles, assumed threats, and what “secure” means for this build. This document sets the baseline expectations for all downstream security/privacy/compliance docs and must not invent guarantees beyond upstream inputs.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
PRD-06 NFRs/Security constraints: {{prd.nfrs}} | OPTIONAL
Security architecture: {{xref:SEC-02}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Security scope (in-scope systems/surfaces)
Out-of-scope statement (explicit)
Security principles list (top 5–12)
Threat posture summary (major threat classes)
Trust assumptions (what is assumed secure)
Data sensitivity summary (high-level classes)
Security ownership (who owns security decisions)
Security review cadence (when reviewed)
Known gaps / exceptions pointer (SEC-08)
References to core security docs (SEC-02..SEC-10)

Optional Fields
Product risk tier | OPTIONAL
External compliance drivers summary | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Every statement must be traceable to upstream inputs or marked UNKNOWN.
Do not claim compliance certifications unless explicitly provided.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.
Use consistent terminology from: {{glossary.terms}} | OPTIONAL

Output Format

1. Scope
   In-scope surfaces:
   {{scope.in[0]}}
   {{scope.in[1]}}
   Out-of-scope (explicit):
   {{scope.out[0]}}
   {{scope.out[1]}}
2. Security Principles
   {{principles[0]}}
   {{principles[1]}}
   {{principles[2]}}
3. Threat Posture
   Primary threat classes:
   {{threats[0]}}
   {{threats[1]}}
   {{threats[2]}}
   Assumed attacker capability: {{threats.attacker_model}} | OPTIONAL
4. Trust Assumptions
   {{assumptions[0]}}
   {{assumptions[1]}}
   {{assumptions[2]}}
5. Data Sensitivity Summary
   data_classes: {{data.classes}}
   highest_risk_data: {{data.highest_risk}} | OPTIONAL
6. Ownership & Governance
   security_owner: {{governance.owner}}
   decision_process: {{governance.decision_process}} | OPTIONAL
   review_cadence: {{governance.review_cadence}}
7. Known Gaps / Exceptions
   exceptions_process_ref: {{xref:SEC-08}} | OPTIONAL
   known_gaps:
   {{gaps[0]}} | OPTIONAL
   {{gaps[1]}} | OPTIONAL
8. References
   Security architecture: {{xref:SEC-02}}
   Security requirements: {{xref:SEC-03}} | OPTIONAL

Incident response: {{xref:SEC-05}} | OPTIONAL
Monitoring: {{xref:SEC-06}} | OPTIONAL
Secure SDLC: {{xref:SEC-07}} | OPTIONAL

Cross-References
Upstream: {{xref:PRD-06}} | OPTIONAL, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:SEC-02}}, {{xref:SEC-03}}, {{xref:SEC-05}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Fill required fields; mark UNKNOWN rather than inventing.
intermediate: Required. Replace UNKNOWN with sourced statements when inputs exist.
advanced: Required. Add crisp scope boundaries and explicit threat posture statements.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, prd.nfrs, attacker model, highest risk data, decision process, known gaps, risk tier, compliance drivers, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If scope.in is UNKNOWN → block Completeness Gate.
If principles is UNKNOWN → block Completeness Gate.
If governance.owner is UNKNOWN → block Completeness Gate.
If governance.review_cadence is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.SEC
Pass conditions:
required_fields_present == true
scope_defined == true
principles_defined == true
ownership_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

SEC-02

SEC-02 — Security Architecture (trust boundaries, data flows)
Header Block
template_id: SEC-02
title: Security Architecture (trust boundaries, data flows)
type: security_architecture
template_version: 1.0.0
output_path: 10_app/security/SEC-02_Security_Architecture.md
compliance_gate_id: TMP-05.PRIMARY.SEC
upstream_dependencies: ["SPEC_INDEX", "ARCH-01"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "ARCH-01", "API-01", "EVT-01", "FMS-01"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical security architecture: system components, trust boundaries, data flows, and where security controls are enforced. This document is the anchor for threat modeling and must be consistent with the system architecture and integration inventories.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
System architecture: {{xref:ARCH-01}} | OPTIONAL
API surface: {{xref:API-01}} | OPTIONAL
Eventing: {{xref:EVT-01}} | OPTIONAL
Storage targets: {{xref:FMS-01}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Component list (major services/clients)
Trust boundary list (boundary_id)
Data flow list (flow_id)
Entry points (web/mobile/API/webhooks)
Authentication points (where authn occurs)
Authorization points (where authz enforced)
Sensitive data zones (where high-risk data lives)
Network controls (allowlists, egress policy)
Logging/audit zones (where logs stored)
References to downstream security docs (SEC-03..SEC-10)

Optional Fields
Deployment model summary | OPTIONAL

Third-party dependencies list | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Trust boundaries and flows must be explicit and consistent with upstream architecture.
Do not invent components; if not in inputs, mark UNKNOWN and flag.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Components
   {{components[0]}}
   {{components[1]}}
   {{components[2]}}
2. Trust Boundaries
   Boundary
   boundary_id: {{boundaries[0].boundary_id}}
   name: {{boundaries[0].name}}
   between: {{boundaries[0].between}}
   notes: {{boundaries[0].notes}} | OPTIONAL

(Repeat per boundary.)

3. Data Flows
   Flow
   flow_id: {{flows[0].flow_id}}
   from: {{flows[0].from}}
   to: {{flows[0].to}}
   data_classes: {{flows[0].data_classes}}
   controls: {{flows[0].controls}} | OPTIONAL

(Repeat per flow.)

4. Entry Points
   entry_points: {{entry.points}}
5. AuthN / AuthZ Enforcement Points
   authn_points: {{auth.authn_points}}
   authz_points: {{auth.authz_points}}
6. Sensitive Data Zones
   zones: {{data.zones}}
   highest_risk_zone: {{data.highest_risk_zone}} | OPTIONAL
7. Network Controls
   egress_policy_ref: {{net.egress_policy_ref}} (expected: {{xref:IXS-03}}) | OPTIONAL
   ingress_controls: {{net.ingress_controls}} | OPTIONAL

8. Logging / Audit Zones
   log_stores: {{logs.stores}}
   audit_ref: {{xref:AUDIT-03}} | OPTIONAL
9. References
   Security requirements: {{xref:SEC-03}} | OPTIONAL
   Vulnerability mgmt: {{xref:SEC-04}} | OPTIONAL
   Incident response: {{xref:SEC-05}} | OPTIONAL
   Monitoring: {{xref:SEC-06}} | OPTIONAL
   Secure SDLC: {{xref:SEC-07}} | OPTIONAL

Cross-References
Upstream: {{xref:ARCH-01}} | OPTIONAL, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:TMA-01}}, {{xref:SEC-03}}, {{xref:IAM-04}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. List components, entry points, and at least high-level flows/boundaries.
intermediate: Required. Add explicit authn/authz points and sensitive data zones.
advanced: Required. Add crisp boundary IDs, control placement, and third-party dependency mapping.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, notes, controls, deployment model, third-party list, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If boundaries list is UNKNOWN → block Completeness Gate.
If flows list is UNKNOWN → block Completeness Gate.
If auth.authn_points is UNKNOWN → block Completeness Gate.
If logs.stores is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.SEC
Pass conditions:
required_fields_present == true
trust_boundaries_defined == true
data_flows_defined == true
auth_points_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

SEC-03

SEC-03 — Security Requirements (baseline controls checklist)
Header Block
template_id: SEC-03
title: Security Requirements (baseline controls checklist)
type: security_requirements_baseline
template_version: 1.0.0
output_path: 10_app/security/SEC-03_Security_Requirements_Baseline.md
compliance_gate_id: TMP-05.PRIMARY.SEC
upstream_dependencies: ["SEC-01", "SEC-02", "STANDARDS_INDEX"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SEC-01", "SEC-02", "IAM-01", "AUDIT-01"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the baseline security requirements for the product as a checklist of enforceable controls (what must be true). This document is the “security bar” used by reviews and gates and must align with system trust boundaries, AuthN/AuthZ model, and audit requirements.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Security overview: {{xref:SEC-01}} | OPTIONAL
Security architecture: {{xref:SEC-02}} | OPTIONAL
Role/permission model: {{xref:IAM-01}} | OPTIONAL
Audit event catalog: {{xref:AUDIT-01}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Control registry (control_id list)
Control categories (AuthN, AuthZ, Data, Network, Logging, SDLC)
Minimum required controls per category
Evidence requirement per control (what proves it)
Owner per control (team/role)
Severity/priority per control (high/med/low)
Verification method per control (test/check/manual)
Exception policy reference (SEC-08)

Optional Fields
Per-surface control deltas (web/mobile/api) | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Controls must be testable or have explicit evidence requirements.
Do not list vague controls (“be secure”); every control must be enforceable.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Control Categories
   categories: {{controls.categories}}
2. Control Registry (repeat per control_id)
   Control
   control_id: {{controls.items[0].control_id}}
   category: {{controls.items[0].category}}
   title: {{controls.items[0].title}}
   requirement: {{controls.items[0].requirement}}
   severity: {{controls.items[0].severity}} (high/med/low/UNKNOWN)
   owner: {{controls.items[0].owner}}
   evidence: {{controls.items[0].evidence}}
   verification_method: {{controls.items[0].verification_method}}
   (test/check/manual/UNKNOWN)
   refs: {{controls.items[0].refs}} | OPTIONAL
   notes: {{controls.items[0].notes}} | OPTIONAL

(Repeat per control.)

3. Evidence Summary
   minimum_evidence_artifacts: {{evidence.minimum_artifacts}} | OPTIONAL
   storage_location: {{evidence.storage_location}} | OPTIONAL
4. Exceptions
   exceptions_ref: {{xref:SEC-08}} | OPTIONAL
   exceptions_rules: {{exceptions.rules}} | OPTIONAL
5. References
   Security architecture: {{xref:SEC-02}} | OPTIONAL
   Secure SDLC: {{xref:SEC-07}} | OPTIONAL
   Audit logging: {{xref:AUDIT-03}} | OPTIONAL

Cross-References
Upstream: {{xref:SEC-01}}, {{xref:SEC-02}} | OPTIONAL, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:SEC-07}}, {{xref:COMP-02}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define categories and at least a starter control registry with UNKNOWN where needed.

intermediate: Required. Add evidence + verification method per control.
advanced: Required. Add severity, ownership, and explicit references/evidence artifacts per control.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, refs/notes, evidence summary fields, exceptions rules, per-surface deltas, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If controls.categories is UNKNOWN → block Completeness Gate.
If controls.items[*].control_id is UNKNOWN → block Completeness Gate.*
*If controls.items[*].requirement is UNKNOWN → block Completeness Gate.
If controls.items[*].owner is UNKNOWN → block Completeness Gate.*
*If controls.items[*].verification_method is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.SEC
Pass conditions:
required_fields_present == true
control_registry_defined == true
each_control_has_evidence_and_verification == true
placeholder_resolution == true
no_unapproved_unknowns == true

SEC-04

SEC-04 — Vulnerability Management (patching, scans, SLAs)
Header Block
template_id: SEC-04
title: Vulnerability Management (patching, scans, SLAs)
type: vulnerability_management
template_version: 1.0.0
output_path: 10_app/security/SEC-04_Vulnerability_Management.md
compliance_gate_id: TMP-05.PRIMARY.SEC
upstream_dependencies: ["SEC-03", "SEC-07"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SEC-03", "SEC-07", "COMP-02"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical vulnerability management program for the product: scanning, triage, patch SLAs by severity, dependency management, and verification/closure workflow. This template must be consistent with Secure SDLC gates and compliance control expectations.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Security requirements baseline: {{xref:SEC-03}} | OPTIONAL
Secure SDLC policy: {{xref:SEC-07}} | OPTIONAL
Control matrix: {{xref:COMP-02}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Vulnerability sources list (SAST, SCA, DAST, pen test, bug reports)
Severity model (critical/high/med/low)
Patch SLA by severity (days)
Triage workflow (intake → assess → assign → fix → verify → close)
Ownership rules (who fixes, who approves risk)
Dependency update policy (SCA handling)
Exception/waiver rules (SEC-08)
Verification requirements (proof of fix)
Reporting cadence (weekly/monthly)
Telemetry requirements (open vulns by severity, SLA breaches)

Optional Fields
Coordinated disclosure policy | OPTIONAL
Asset inventory linkage | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
SLA must be explicit and enforceable.
Exceptions must have expiries and approvals.
Verification must be recorded (evidence pointer).
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Sources
   sources: {{vuln.sources}}
2. Severity Model
   model: {{severity.model}}
   definitions: {{severity.definitions}} | OPTIONAL
3. Patch SLAs
   critical_days: {{sla.critical_days}}
   high_days: {{sla.high_days}}
   med_days: {{sla.med_days}}
   low_days: {{sla.low_days}} | OPTIONAL
4. Triage Workflow
   steps:
   {{workflow.steps[0]}}
   {{workflow.steps[1]}}
   {{workflow.steps[2]}} | OPTIONAL
5. Ownership
   fix_owner_rule: {{owners.fix_owner_rule}}
   risk_acceptance_owner: {{owners.risk_acceptance_owner}} | OPTIONAL
6. Dependency Policy
   sca_required: {{deps.sca_required}}
   update_policy: {{deps.update_policy}}
   blocked_severity_threshold: {{deps.blocked_severity_threshold}} | OPTIONAL
7. Exceptions
   exceptions_ref: {{xref:SEC-08}} | OPTIONAL
   waiver_rules: {{exceptions.waiver_rules}} | OPTIONAL
8. Verification
   verification_required: {{verify.required}}
   evidence_required: {{verify.evidence_required}}
9. Reporting
   cadence: {{report.cadence}}
   report_location: {{report.location}} | OPTIONAL
10. Telemetry
    open_vulns_metric: {{telemetry.open_vulns_metric}}
    sla_breach_metric: {{telemetry.sla_breach_metric}} | OPTIONAL
11. References
    Security baseline: {{xref:SEC-03}} | OPTIONAL

Secure SDLC: {{xref:SEC-07}} | OPTIONAL
Compliance controls: {{xref:COMP-02}} | OPTIONAL

Cross-References
Upstream: {{xref:SEC-03}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:SEC-05}}, {{xref:SEC-09}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define sources, SLAs, and workflow steps; mark UNKNOWN where tooling is unknown.
intermediate: Required. Define ownership, dependency policy, and verification evidence.
advanced: Required. Add threshold gating, reporting rigor, and telemetry/SLA breach monitoring detail.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, definitions, low SLA, extra workflow steps, risk acceptance owner, blocked threshold, waiver rules, report location, optional telemetry metrics, disclosure/asset linkage, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If vuln.sources is UNKNOWN → block Completeness Gate.
If sla.critical_days is UNKNOWN → block Completeness Gate.
If workflow.steps[0] is UNKNOWN → block Completeness Gate.
If verify.evidence_required is UNKNOWN → block Completeness Gate.
If telemetry.open_vulns_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.SEC
Pass conditions:
required_fields_present == true
sla_defined == true
workflow_defined == true
verification_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

SEC-05

SEC-05 — Incident Response Plan (detect, contain, recover)
Header Block
template_id: SEC-05
title: Incident Response Plan (detect, contain, recover)
type: incident_response_plan
template_version: 1.0.0
output_path: 10_app/security/SEC-05_Incident_Response_Plan.md
compliance_gate_id: TMP-05.PRIMARY.SEC
upstream_dependencies: ["SEC-01", "SEC-06", "AUDIT-06"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SEC-01", "SEC-06", "AUDIT-06", "COMP-06"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical incident response plan for security events: detection, triage, containment, eradication, recovery, and post-incident review. This template must coordinate with audit/forensics workflows and compliance notification requirements.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Security overview: {{xref:SEC-01}} | OPTIONAL
Security monitoring: {{xref:SEC-06}} | OPTIONAL
Investigation workflow: {{xref:AUDIT-06}} | OPTIONAL
Regulatory requirements: {{xref:COMP-06}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Incident severity model (sev levels)
Incident types list (account takeover, data leak, malware, etc.)
Detection sources (alerts, reports)
Triage process (who does what)
Containment actions (block keys, disable endpoints, rotate secrets)
Evidence preservation rules (logs, snapshots)
Communication plan (internal/external)
Regulatory notification trigger rules (if applicable)
Recovery steps (restore, validate)
Post-incident review requirements (RCA, action items)
Runbook references (SEC-10, AUDIT-10)

Optional Fields
On-call rotations / contacts | OPTIONAL

Tabletop exercise cadence | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Containment actions must be permissioned and auditable.
Evidence handling must preserve chain-of-custody where needed.
Do not claim regulatory timelines unless provided; use UNKNOWN when unclear.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Severity Model
   levels: {{sev.levels}}
   definitions: {{sev.definitions}} | OPTIONAL
2. Incident Types
   types: {{types.list}}
3. Detection & Intake
   sources: {{detect.sources}}
   intake_rule: {{detect.intake_rule}} | OPTIONAL
4. Triage Process
   steps:
   {{triage.steps[0]}}
   {{triage.steps[1]}}
   {{triage.steps[2]}} | OPTIONAL
5. Containment Actions
   actions: {{contain.actions}}
   permission_rule: {{contain.permission_rule}} | OPTIONAL
6. Evidence Preservation
   what_to_capture: {{evidence.what_to_capture}}
   storage_location: {{evidence.storage_location}} | OPTIONAL
   chain_of_custody_rule: {{evidence.chain_of_custody_rule}} | OPTIONAL
7. Communications
   internal_comms_rule: {{comms.internal_rule}}
   external_comms_rule: {{comms.external_rule}} | OPTIONAL
   customer_notice_trigger_rule: {{comms.customer_notice_trigger_rule}} | OPTIONAL
8. Regulatory Notifications
   regulatory_trigger_rule: {{reg.trigger_rule}}
   timeline: {{reg.timeline}} | OPTIONAL
9. Recovery
   recovery_steps: {{recover.steps}}
   validation_rule: {{recover.validation_rule}} | OPTIONAL
10. Post-Incident Review
    rca_required: {{post.rca_required}}

rca_template_ref: {{post.rca_template_ref}} | OPTIONAL
action_item_tracking_rule: {{post.action_item_tracking_rule}} | OPTIONAL

11. References
    Security monitoring: {{xref:SEC-06}} | OPTIONAL
    Secrets compromise response: {{xref:SKM-08}} | OPTIONAL
    Forensics workflow: {{xref:AUDIT-06}} | OPTIONAL
    Forensics runbooks: {{xref:AUDIT-10}} | OPTIONAL
    Security runbooks: {{xref:SEC-10}} | OPTIONAL

Cross-References
Upstream: {{xref:SEC-01}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:SEC-10}}, {{xref:AUDIT-10}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define severity, detection sources, triage and containment steps.
intermediate: Required. Define evidence handling and comms and post-incident requirements.
advanced: Required. Add regulatory trigger rigor, tabletop cadence, and permissioning detail.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, definitions, intake rule, permission rule, evidence storage/chain, external/customer comms, regulatory timeline, rca refs/action tracking, on-call/tabletop cadence, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If sev.levels is UNKNOWN → block Completeness Gate.
If types.list is UNKNOWN → block Completeness Gate.
If triage.steps[0] is UNKNOWN → block Completeness Gate.
If contain.actions is UNKNOWN → block Completeness Gate.
If post.rca_required is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.SEC
Pass conditions:
required_fields_present == true
severity_and_types_defined == true
triage_and_containment_defined == true
evidence_and_comms_defined == true
post_incident_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

SEC-06

SEC-06 — Security Monitoring (signals, alerts, dashboards)
Header Block
template_id: SEC-06
title: Security Monitoring (signals, alerts, dashboards)
type: security_monitoring
template_version: 1.0.0
output_path: 10_app/security/SEC-06_Security_Monitoring.md
compliance_gate_id: TMP-05.PRIMARY.SEC
upstream_dependencies: ["SEC-02", "AUDIT-09", "TMA-03"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SEC-02", "AUDIT-09", "TMA-03", "IAM-10"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical security monitoring requirements: what signals are collected, how they're aggregated, dashboards, alert definitions, routing, and runbook references. This template must be consistent with attack surface inventory and audit/anomaly expectations.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Security architecture: {{xref:SEC-02}} | OPTIONAL
Attack surface inventory: {{xref:TMA-03}} | OPTIONAL
Audit anomaly detection: {{xref:AUDIT-09}} | OPTIONAL
Access observability: {{xref:IAM-10}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Signal categories (auth, authz, data access, network, app abuse)
Signal sources (logs/metrics/traces/providers)
Dashboard requirements (minimum panels)
Alert registry (alert_id list)
Alert definitions (condition, severity)
Routing policy (oncall/team)
Triage/runbook references (SEC-10, AUDIT-10)
Noise control rules (dedupe, suppression windows)
Data retention for security telemetry
Telemetry redaction rules (no secrets/PII)

Optional Fields
SIEM forwarding rules | OPTIONAL

Detection-as-code approach | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Alerts must be actionable and link to a runbook.
Telemetry must comply with logging/redaction rules.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Signal Categories
   categories: {{signals.categories}}
   sources: {{signals.sources}}
2. Dashboards
   dashboard_name: {{dash.name}}
   minimum_panels: {{dash.minimum_panels}}
   panel_list: {{dash.panel_list}} | OPTIONAL
3. Alert Registry
   alerts: {{alerts.list}}
4. Alert Definitions (repeat per alert_id)
   Alert
   alert_id: {{items[0].alert_id}}
   condition: {{items[0].condition}}
   severity: {{items[0].severity}} (low/med/high/UNKNOWN)
   routing: {{items[0].routing}}
   runbook_ref: {{items[0].runbook_ref}} | OPTIONAL
   suppression_rule: {{items[0].suppression_rule}} | OPTIONAL

(Repeat per alert.)

5. Noise Controls
   dedupe_rule: {{noise.dedupe_rule}}
   suppression_windows: {{noise.suppression_windows}} | OPTIONAL
6. Retention & Redaction
   retention_days: {{retention.days}}
   redaction_rule: {{redact.rule}}
7. References
   Security runbooks: {{xref:SEC-10}} | OPTIONAL
   Forensics runbooks: {{xref:AUDIT-10}} | OPTIONAL
   Audit anomaly detection: {{xref:AUDIT-09}} | OPTIONAL

Cross-References
Upstream: {{xref:SEC-02}}, {{xref:SPEC_INDEX}} | OPTIONAL

Downstream: {{xref:SEC-10}}, {{xref:SEC-05}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define categories, one dashboard, and an alert list.
intermediate: Required. Define alert conditions/routing and noise controls and retention.
advanced: Required. Add SIEM forwarding, detection-as-code, and precise suppression rules.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, panel list, runbook refs, suppression rules/windows, siem/detection-as-code, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If signals.categories is UNKNOWN → block Completeness Gate.
If dash.minimum_panels is UNKNOWN → block Completeness Gate.
If alerts.list is UNKNOWN → block Completeness Gate.
If retention.days is UNKNOWN → block Completeness Gate.
If redact.rule is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.SEC
Pass conditions:
required_fields_present == true
signals_defined == true
dashboards_defined == true
alerts_defined == true
retention_and_redaction_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

SEC-07

SEC-07 — Secure SDLC Policy (reviews, CI gates, dependencies)
Header Block
template_id: SEC-07
title: Secure SDLC Policy (reviews, CI gates, dependencies)
type: secure_sdlc_policy
template_version: 1.0.0
output_path: 10_app/security/SEC-07_Secure_SDLC_Policy.md
compliance_gate_id: TMP-05.PRIMARY.SEC
upstream_dependencies: ["SEC-03", "COMP-02"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SEC-03", "COMP-02", "TESTPLAN-01"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical Secure SDLC policy for the product: required reviews, CI security gates, dependency controls, secret scanning, and release requirements. This template must be consistent with the baseline security controls and compliance evidence expectations.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Security baseline controls: {{xref:SEC-03}} | OPTIONAL
Compliance control matrix: {{xref:COMP-02}} | OPTIONAL
Test plan: {{xref:TESTPLAN-01}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
SDLC stages covered (design/dev/review/test/release)
Required review types (code review, security review)
Branch protection rules (required checks)
CI security gates list (SAST, SCA, secret scan)
Dependency policy (allowed sources, pinning, lockfiles)
Secrets handling in SDLC (no secrets in repo)
Pre-release checklist (security sign-off)
Release blocking criteria (fail conditions)
Evidence artifacts produced (logs/reports)
Owner/custodian for SDLC policy

Optional Fields
Threat model checkpoint (TMA) | OPTIONAL
Emergency hotfix process | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
CI gates must be enforceable and tied to branch protections.
Dependencies must be deterministic (lockfiles required).
Security gates must produce artifacts usable as evidence.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Stages Covered
   stages: {{sdlc.stages}}
2. Reviews
   required_reviews: {{reviews.required}}
   security_review_trigger_rule: {{reviews.security_trigger_rule}} | OPTIONAL
3. Branch Protections
   protected_branches: {{branch.protected_branches}}
   required_checks: {{branch.required_checks}}
   merge_requirements: {{branch.merge_requirements}} | OPTIONAL
4. CI Security Gates
   gates: {{ci.gates}}
   fail_conditions: {{ci.fail_conditions}}
   artifact_outputs: {{ci.artifact_outputs}} | OPTIONAL
5. Dependency Policy
   lockfiles_required: {{deps.lockfiles_required}}
   allowed_registries: {{deps.allowed_registries}} | OPTIONAL
   pinning_rule: {{deps.pinning_rule}}
   vuln_threshold_block: {{deps.vuln_threshold_block}} | OPTIONAL
6. Secrets in SDLC
   no_secrets_in_repo_rule: {{secrets.no_secrets_in_repo_rule}}
   secret_scanning_required: {{secrets.scanning_required}}
7. Pre-Release Checklist
   checklist: {{release.checklist}}
   security_signoff_required: {{release.security_signoff_required}}
8. Release Blocking Criteria
   block_when: {{release.block_when}}
9. Evidence
   evidence_artifacts: {{evidence.artifacts}}
   storage_location: {{evidence.storage_location}} | OPTIONAL
10. Ownership
    policy_owner: {{owner.policy_owner}}
11. References
    Security baseline: {{xref:SEC-03}} | OPTIONAL
    Vulnerability mgmt: {{xref:SEC-04}} | OPTIONAL
    Threat modeling: {{xref:TMA-01}} | OPTIONAL
    Compliance matrix: {{xref:COMP-02}} | OPTIONAL

Cross-References
Upstream: {{xref:SEC-03}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:SEC-09}}, {{xref:SEC-08}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define stages, basic reviews, and at least SAST/SCA/secret scan gates.
intermediate: Required. Define branch protections, fail conditions, and evidence artifacts.
advanced: Required. Add hotfix process, security trigger rules, and strict dependency governance.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, security trigger, merge requirements, artifact outputs, allowed registries, vuln threshold, evidence storage, threat checkpoint, hotfix process, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If ci.gates is UNKNOWN → block Completeness Gate.
If ci.fail_conditions is UNKNOWN → block Completeness Gate.
If deps.pinning_rule is UNKNOWN → block Completeness Gate.
If secrets.no_secrets_in_repo_rule is UNKNOWN → block Completeness Gate.
If owner.policy_owner is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.SEC
Pass conditions:
required_fields_present == true
ci_gates_defined == true
branch_protections_defined == true
dependency_policy_defined == true
release_blocking_defined == true
evidence_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

SEC-08

SEC-08 — Security Exceptions Process (approvals, expiries, audit)
Header Block
template_id: SEC-08
title: Security Exceptions Process (approvals, expiries, audit)
type: security_exceptions_process
template_version: 1.0.0
output_path: 10_app/security/SEC-08_Security_Exceptions_Process.md
compliance_gate_id: TMP-05.PRIMARY.SEC
upstream_dependencies: ["SEC-03", "COMP-08", "AUDIT-07"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SEC-03", "COMP-08", "AUDIT-07", "ADMIN-03"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical process for requesting, approving, tracking, and expiring security exceptions/waivers to baseline controls. This template must ensure exceptions are time-bound, risk-assessed, auditable, and visible to operators/compliance.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Security baseline controls: {{xref:SEC-03}} | OPTIONAL
Compliance exception management: {{xref:COMP-08}} | OPTIONAL
Privileged actions audit: {{xref:AUDIT-07}} | OPTIONAL
Audit trail: {{xref:ADMIN-03}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Exception request schema (fields required)
Approval roles (who can approve)
Risk assessment requirement (likelihood/impact)
Expiry requirement (max duration)
Compensating controls requirement
Tracking system/location (where exceptions stored)
Review cadence (periodic re-approval)
Revocation process (how to end early)
Audit logging requirements (who approved what)
Telemetry requirements (active exceptions count, expired)

Optional Fields
Emergency exception process | OPTIONAL

Exception templates by control category | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
No exceptions without expiry and compensating controls (unless explicitly allowed by policy).
Approvals must be recorded and immutable (audit trail).
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Exception Request Schema
   fields_required: {{schema.fields_required}}
   example_id_format: {{schema.id_format}} | OPTIONAL
2. Approvals
   approver_roles: {{approvals.roles}}
   approval_steps: {{approvals.steps}} | OPTIONAL
3. Risk Assessment
   required: {{risk.required}}
   model: {{risk.model}} (likelihood_impact/UNKNOWN) | OPTIONAL
4. Expiry
   expiry_required: {{expiry.required}}
   max_duration_days: {{expiry.max_duration_days}}
   renewal_policy: {{expiry.renewal_policy}} | OPTIONAL
5. Compensating Controls
   required: {{comp.required}}
   documentation_rule: {{comp.documentation_rule}} | OPTIONAL
6. Tracking
   system: {{track.system}}
   storage_location: {{track.storage_location}} | OPTIONAL
7. Reviews & Revocation
   review_cadence: {{review.cadence}}
   revoke_process: {{review.revoke_process}}
8. Audit
   audit_required: {{audit.required}}
   audit_events: {{audit.events}}
   audit_fields: {{audit.fields}} | OPTIONAL
9. Telemetry
   active_exceptions_metric: {{telemetry.active_metric}}
   expired_exceptions_metric: {{telemetry.expired_metric}} | OPTIONAL
10. References
    Security baseline: {{xref:SEC-03}} | OPTIONAL
    Compliance exceptions: {{xref:COMP-08}} | OPTIONAL
    Privileged actions audit: {{xref:AUDIT-07}} | OPTIONAL

Cross-References
Upstream: {{xref:SEC-03}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:SEC-04}}, {{xref:COMP-09}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define schema fields, approver roles, max duration, and revoke process.
intermediate: Required. Define risk model and compensating control documentation and audit events.
advanced: Required. Add emergency process and control-category templates and telemetry rigor.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, id format, approval steps, risk model, renewal policy, documentation rule, storage location, audit fields, expired metric, emergency/templates, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If approvals.roles is UNKNOWN → block Completeness Gate.
If expiry.max_duration_days is UNKNOWN → block Completeness Gate.
If review.revoke_process is UNKNOWN → block Completeness Gate.
If audit.required is UNKNOWN → block Completeness Gate.
If telemetry.active_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.SEC
Pass conditions:
required_fields_present == true
approval_and_expiry_defined == true
risk_and_comp_controls_defined == true
audit_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

SEC-09

SEC-09 — Security Testing Plan (SAST/DAST/pen test, coverage)
Header Block
template_id: SEC-09
title: Security Testing Plan (SAST/DAST/pen test, coverage)
type: security_testing_plan
template_version: 1.0.0
output_path: 10_app/security/SEC-09_Security_Testing_Plan.md
compliance_gate_id: TMP-05.PRIMARY.SEC
upstream_dependencies: ["SEC-07", "SEC-04", "TMA-05"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SEC-07", "SEC-04", "TMA-05", "TESTPLAN-01"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical security testing plan: what security tests run (static, dependency, dynamic), when they run, what coverage is required, how findings are triaged, and what evidence is produced. This template must be consistent with Secure SDLC gates and vulnerability management SLAs.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Secure SDLC policy: {{xref:SEC-07}} | OPTIONAL
Vulnerability management: {{xref:SEC-04}} | OPTIONAL
Threat→control mapping: {{xref:TMA-05}} | OPTIONAL
Test plan: {{xref:TESTPLAN-01}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Test types list (SAST, SCA, DAST, secrets scan, pen test)
Execution cadence (per PR, nightly, release)
Scope/targets (repos, services, endpoints)
Coverage expectations (what must be tested)
Failing thresholds (what blocks merges/releases)
Triaging rules (who triages, how prioritized)
Evidence artifacts produced (reports)
Retention policy for test artifacts
Telemetry requirements (finding counts, trend)

Optional Fields
Red team/tabletop drills | OPTIONAL

Bug bounty policy link | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Testing must map to controls/threats (traceability).
Failing thresholds must be explicit and enforceable.
Evidence artifacts must be saved for compliance/audit as required.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Test Types
   types: {{tests.types}}
2. Cadence
   cadence: {{tests.cadence}}
3. Scope / Targets
   targets: {{scope.targets}}
   endpoint_scope_ref: {{scope.endpoint_scope_ref}} | OPTIONAL
4. Coverage Expectations
   must_cover: {{coverage.must_cover}}
   traceability_rule: {{coverage.traceability_rule}} | OPTIONAL
5. Failing Thresholds
   block_merge_when: {{thresholds.block_merge_when}}
   block_release_when: {{thresholds.block_release_when}} | OPTIONAL
6. Triaging
   triage_owner: {{triage.owner}}
   triage_process: {{triage.process}}
7. Evidence
   artifact_list: {{evidence.artifact_list}}
   storage_location: {{evidence.storage_location}} | OPTIONAL
   retention_days: {{evidence.retention_days}}
8. Telemetry
   findings_metric: {{telemetry.findings_metric}}
   trend_metric: {{telemetry.trend_metric}} | OPTIONAL
9. References
   Secure SDLC: {{xref:SEC-07}} | OPTIONAL
   Vuln management: {{xref:SEC-04}} | OPTIONAL
   Threat mapping: {{xref:TMA-05}} | OPTIONAL

Cross-References
Upstream: {{xref:SEC-07}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:SEC-10}}, {{xref:COMP-09}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define test types and cadence and retention days.
intermediate: Required. Define thresholds and triage process and evidence artifacts.
advanced: Required. Add traceability to threats/controls and red team/bounty policies.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, endpoint scope ref, traceability rule, release thresholds, trend metric, storage location, red team/bounty, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If tests.types is UNKNOWN → block Completeness Gate.
If thresholds.block_merge_when is UNKNOWN → block Completeness Gate.
If triage.process is UNKNOWN → block Completeness Gate.
If evidence.retention_days is UNKNOWN → block Completeness Gate.
If telemetry.findings_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.SEC
Pass conditions:
required_fields_present == true
test_types_and_cadence_defined == true
thresholds_defined == true
triage_defined == true
evidence_and_retention_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

SEC-10

SEC-10 — Security Runbooks (common incidents, operator actions)
Header Block
template_id: SEC-10
title: Security Runbooks (common incidents, operator actions)
type: security_runbooks
template_version: 1.0.0
output_path: 10_app/security/SEC-10_Security_Runbooks.md
compliance_gate_id: TMP-05.PRIMARY.SEC
upstream_dependencies: ["SEC-05", "SEC-06", "AUDIT-10"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SEC-05", "SEC-06", "AUDIT-10", "SKM-08", "IAM-06"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical set of security runbooks for common incident types: step-by-step triage, containment actions, evidence capture, and recovery checks. This template must align with the incident response plan and monitoring alert registry and must not introduce operator actions that are not permissioned/auditable.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Incident response plan: {{xref:SEC-05}} | OPTIONAL
Security monitoring: {{xref:SEC-06}} | OPTIONAL
Forensics runbooks: {{xref:AUDIT-10}} | OPTIONAL
Secrets compromise response: {{xref:SKM-08}} | OPTIONAL
Privileged access policy: {{xref:IAM-06}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Runbook registry (runbook_id list)
runbook_id (stable identifier)
incident type binding (must match SEC-05 types)
Trigger signals/alerts (from SEC-06)
Triage steps (ordered)
Containment actions (ordered)
Evidence capture checklist
Recovery validation steps
Escalation rule (when to page/notify)
Permissions required (role)
Audit requirements (log operator actions)
Telemetry requirements (runbook invoked, time-to-contain)

Optional Fields
Customer comms snippet pointers | OPTIONAL
Automation hooks | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Every runbook must map to at least one trigger signal and one containment action.
Operator actions must be permissioned and auditable.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Runbook Registry Summary
   total_runbooks: {{meta.total}}
   notes: {{meta.notes}} | OPTIONAL
2. Runbooks (repeat per runbook_id)
   Runbook
   runbook_id: {{books[0].runbook_id}}
   incident_type: {{books[0].incident_type}}
   triggers: {{books[0].triggers}}
   triage_steps:
   {{books[0].triage_steps[0]}}
   {{books[0].triage_steps[1]}}
   containment_actions:
   {{books[0].containment_actions[0]}}
   {{books[0].containment_actions[1]}} | OPTIONAL
   evidence_checklist: {{books[0].evidence_checklist}}
   recovery_validation: {{books[0].recovery_validation}}
   escalation_rule: {{books[0].escalation_rule}}
   permissions_required: {{books[0].permissions_required}}
   audit_required: {{books[0].audit_required}}
   telemetry:
   invoked_metric: {{books[0].telemetry.invoked_metric}}
   ttc_metric: {{books[0].telemetry.ttc_metric}} | OPTIONAL

(Repeat per runbook.)

3. References
   Incident response plan: {{xref:SEC-05}} | OPTIONAL
   Monitoring/alerts: {{xref:SEC-06}} | OPTIONAL
   Secrets compromise: {{xref:SKM-08}} | OPTIONAL
   Forensics runbooks: {{xref:AUDIT-10}} | OPTIONAL

Cross-References
Upstream: {{xref:SEC-05}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:AUDIT-06}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define runbook registry and triage/containment steps.
intermediate: Required. Define evidence checklist, escalation, and permissions/audit.
advanced: Required. Add automation hooks and tighter telemetry and cross-runbook reuse patterns.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, meta notes, optional containment steps, optional metrics, comms snippets, automation hooks, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If books[*].runbook_id is UNKNOWN → block Completeness Gate.
If books[*].triage_steps[0] is UNKNOWN → block Completeness Gate.
If books[*].containment_actions[0] is UNKNOWN → block Completeness Gate.
If books[*].audit_required is UNKNOWN → block Completeness Gate.
If books[*].telemetry.invoked_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.SEC
Pass conditions:
required_fields_present == true
runbooks_defined == true
each_runbook_has_triggers_and_actions == true
audit_and_permissions_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

Identity & Access (IAM)

IAM-01

IAM-01 — Role & Permission Model (roles, permissions, inheritance)
Header Block
template_id: IAM-01
title: Role & Permission Model (roles, permissions, inheritance)
type: iam_role_permission_model
template_version: 1.0.0
output_path: 10_app/iam/IAM-01_Role_Permission_Model.md
compliance_gate_id: TMP-05.PRIMARY.IAM
upstream_dependencies: ["API-04", "SSO-03", "ADMIN-01"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "API-04", "SSO-03", "ADMIN-01", "ROUTE-04"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical internal role/permission model: role_ids, permission_ids, inheritance rules, default roles, and how roles/permissions are used for API and UI gating. This template must be consistent with AuthZ rules and claim-to-role mapping and must not invent role/permission IDs beyond upstream inputs.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
API-04 AuthZ Rules: {{api.authz_rules}}
SSO-03 Claim → Role Mapping: {{sso.claim_mapping}} | OPTIONAL
ADMIN-01 Admin Capabilities: {{admin.capabilities}} | OPTIONAL
ROUTE-04 Guard Rules: {{route.guard_rules}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Role registry (role_id list)
Permission registry (perm_id list)
Role definitions (purpose)
Permission definitions (what allowed)
Role → permission mapping
Inheritance rules (role implies role/perm)
Default role rule (new users)
Tenant/organization scoping rules (if applicable)
Admin/privileged role rules (step-up requirements ref)
UI gating rules pointer (ROUTE-04)
Telemetry requirements (authz denies by role/perm)

Optional Fields
Fine-grained ABAC attributes model | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Least privilege: defaults must be minimal.
No permission should exist without a description and a mapping context.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Roles
   roles: {{roles.list}}
2. Permissions
   permissions: {{perms.list}}
3. Role Definitions (repeat)
   Role
   role_id: {{roles.items[0].role_id}}
   name: {{roles.items[0].name}}
   purpose: {{roles.items[0].purpose}}
   inherits: {{roles.items[0].inherits}} | OPTIONAL

(Repeat per role.)

4. Permission Definitions (repeat)
   Permission
   perm_id: {{perms.items[0].perm_id}}
   name: {{perms.items[0].name}}
   description: {{perms.items[0].description}}

(Repeat per permission.)

5. Role → Permission Mapping
   Mapping
   role_id: {{map[0].role_id}}
   perm_ids: {{map[0].perm_ids}}

(Repeat per role.)

6. Defaults & Scoping
   default_role_id: {{defaults.default_role_id}}
   tenant_scope_rule: {{scope.tenant_scope_rule}} | OPTIONAL
7. Privileged Roles
   privileged_roles: {{priv.roles}}
   step_up_ref: {{priv.step_up_ref}} (expected: {{xref:SSO-07}}) | OPTIONAL

8. UI Gating
   route_guard_ref: {{xref:ROUTE-04}} | OPTIONAL
9. Telemetry
   authz_deny_metric: {{telemetry.authz_deny_metric}}
   fields: {{telemetry.fields}} | OPTIONAL
10. References
    AuthZ rules: {{xref:API-04}}
    Claim mapping: {{xref:SSO-03}} | OPTIONAL
    Admin capabilities: {{xref:ADMIN-01}} | OPTIONAL
    Step-up rules: {{xref:SSO-07}} | OPTIONAL

Cross-References
Upstream: {{xref:API-04}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:IAM-04}}, {{xref:IAM-10}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define roles, permissions, and default role; do not invent IDs.
intermediate: Required. Define mappings and inheritance and privileged role list.
advanced: Required. Add scoping/ABAC model and strict traceability and telemetry fields.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, inherits, tenant scope rule, step up ref, telemetry fields, abac model, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If roles.list is UNKNOWN → block Completeness Gate.
If perms.list is UNKNOWN → block Completeness Gate.
If defaults.default_role_id is UNKNOWN → block Completeness Gate.
If map list is UNKNOWN → block Completeness Gate.
If telemetry.authz_deny_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.IAM
Pass conditions:
required_fields_present == true
role_and_perm_registries_defined == true
role_perm_mapping_defined == true
default_and_privileged_roles_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

IAM-02

IAM-02 — AuthN Methods (passwordless, SSO, MFA binding)
Header Block
template_id: IAM-02
title: AuthN Methods (passwordless, SSO, MFA binding)
type: iam_authentication_methods
template_version: 1.0.0
output_path: 10_app/iam/IAM-02_Authentication_Methods.md
compliance_gate_id: TMP-05.PRIMARY.IAM
upstream_dependencies: ["SSO-02", "SSO-07", "CSec-01"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SSO-01", "SSO-02", "SSO-07", "CSec-01", "ROUTE-04"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical authentication methods supported by the product and how they are enforced: password vs passwordless, SSO, MFA/step-up binding, and any device assurance rules. This template must be consistent with SSO flow specs and client token storage rules.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
SSO provider inventory: {{xref:SSO-01}} | OPTIONAL
SSO flow spec: {{xref:SSO-02}} | OPTIONAL
MFA/step-up rules: {{xref:SSO-07}} | OPTIONAL
Token storage policy: {{xref:CSec-01}} | OPTIONAL
Guard rules: {{xref:ROUTE-04}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Supported auth methods list (password/otp/webauthn/sso/UNKNOWN)
Primary method (default)
SSO supported (yes/no/UNKNOWN)
MFA supported (yes/no/UNKNOWN)
Step-up binding (what actions require step-up ref)
Credential policy (password rules if used)
Account recovery methods (email link, admin reset)
Device/session assurance notes (if any)
Auth method selection UX rules (what user sees)
Telemetry requirements (login success/fail by method)

Optional Fields
Rate limits/lockouts pointer | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
If password auth is enabled, password policy must be explicit.
If MFA/step-up is required for privileged actions, it must be enforceable server-side.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Supported Methods
   methods: {{auth.methods}}
   primary_method: {{auth.primary_method}}
2. SSO
   sso_supported: {{sso.supported}}
   providers: {{sso.providers}} | OPTIONAL
   flow_ref: {{xref:SSO-02}} | OPTIONAL
3. MFA / Step-Up
   mfa_supported: {{mfa.supported}}
   step_up_ref: {{xref:SSO-07}} | OPTIONAL
4. Credential Policy
   password_policy: {{creds.password_policy}} | OPTIONAL
   passwordless_policy: {{creds.passwordless_policy}} | OPTIONAL
5. Recovery
   recovery_methods: {{recovery.methods}}
   recovery_security_rules: {{recovery.security_rules}} | OPTIONAL
6. UX Rules
   selection_rule: {{ux.selection_rule}}
   fallback_rule: {{ux.fallback_rule}} | OPTIONAL
7. Telemetry
   login_success_metric: {{telemetry.login_success_metric}}
   login_failure_metric: {{telemetry.login_failure_metric}} | OPTIONAL
   breakdown_fields: {{telemetry.breakdown_fields}} | OPTIONAL
8. References
   SSO inventory: {{xref:SSO-01}} | OPTIONAL
   SSO flow: {{xref:SSO-02}} | OPTIONAL
   MFA/step-up: {{xref:SSO-07}} | OPTIONAL
   Session rules: {{xref:IAM-03}} | OPTIONAL
   Lockouts: {{xref:SSO-08}} | OPTIONAL

Cross-References
Upstream: {{xref:SSO-02}}, {{xref:SPEC_INDEX}} | OPTIONAL

Downstream: {{xref:IAM-03}}, {{xref:IAM-06}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define supported methods, primary method, and recovery methods.
intermediate: Required. Define SSO/MFA flags and credential policy and telemetry.
advanced: Required. Add device assurance and UX selection/fallback rigor and server enforcement notes.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, providers list, password policies, passwordless policy, recovery security rules, fallback rule, telemetry breakdown fields, rate limits pointer, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If auth.methods is UNKNOWN → block Completeness Gate.
If auth.primary_method is UNKNOWN → block Completeness Gate.
If recovery.methods is UNKNOWN → block Completeness Gate.
If telemetry.login_success_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.IAM
Pass conditions:
required_fields_present == true
methods_defined == true
recovery_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

IAM-03

IAM-03 — Session Management Policy (expiry, rotation, device binding)
Header Block
template_id: IAM-03
title: Session Management Policy (expiry, rotation, device binding)
type: iam_session_management_policy
template_version: 1.0.0
output_path: 10_app/iam/IAM-03_Session_Management_Policy.md
compliance_gate_id: TMP-05.PRIMARY.IAM
upstream_dependencies: ["SSO-04", "CSec-01", "CER-04"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SSO-04", "CSec-01", "CER-04", "IAM-02"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical session management policy: session artifacts (cookies/tokens), expiry rules, refresh and rotation behavior, device binding, concurrent session rules, logout semantics, and how session expiry is handled in UX. This template must align with SSO session exchange rules and client token storage policies.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
SSO session/token exchange: {{xref:SSO-04}} | OPTIONAL
Token storage policy: {{xref:CSec-01}} | OPTIONAL
Session expiry UX: {{xref:CER-04}} | OPTIONAL
Auth methods: {{xref:IAM-02}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Session model (cookie/jwt/session_token/UNKNOWN)
Issued artifacts (access/refresh/session cookie)
Absolute TTL seconds
Idle TTL seconds (or NONE/UNKNOWN)
Refresh supported (yes/no/UNKNOWN)
Rotation supported (yes/no/UNKNOWN)
Device binding supported (yes/no/UNKNOWN)
Concurrent sessions policy (allow/limit)
Logout policy (local + global)
Revocation policy (invalidate sessions)
Telemetry requirements (session created/expired/refresh fail)
Security logging requirements (no tokens logged)

Optional Fields
Remembered device rule | OPTIONAL
Step-up reuse window | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Session expiry and refresh behavior must be deterministic and enforceable server-side.
Token storage must follow {{xref:CSec-01}}.
If refresh is supported, rotation rules must be explicit to limit token theft blast radius.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Session Model
   model: {{session.model}}
   issued: {{session.issued}}
   storage_ref: {{session.storage_ref}} (expected: {{xref:CSec-01}}) | OPTIONAL
2. TTLs
   absolute_ttl_seconds: {{ttl.absolute}}
   idle_ttl_seconds: {{ttl.idle}}
3. Refresh
   refresh_supported: {{refresh.supported}}
   trigger_rule: {{refresh.trigger_rule}} | OPTIONAL
   on_refresh_fail: {{refresh.on_fail}}
4. Rotation
   rotation_supported: {{rotation.supported}}
   rotation_rule: {{rotation.rule}} | OPTIONAL
5. Device Binding
   device_binding_supported: {{device.supported}}
   device_binding_rule: {{device.rule}} | OPTIONAL
6. Concurrency
   policy: {{conc.policy}} (allow/limit/UNKNOWN)
   max_sessions: {{conc.max_sessions}} | OPTIONAL
7. Logout & Revocation
   local_logout_rule: {{logout.local_rule}}
   global_logout_rule: {{logout.global_rule}} | OPTIONAL
   revocation_rule: {{revoke.rule}}
8. UX Handling
   expiry_ux_ref: {{xref:CER-04}} | OPTIONAL
   re_auth_prompt_rule: {{ux.re_auth_prompt_rule}} | OPTIONAL
9. Telemetry
   session_created_metric: {{telemetry.created_metric}}
   session_expired_metric: {{telemetry.expired_metric}} | OPTIONAL
   refresh_failure_metric: {{telemetry.refresh_fail_metric}} | OPTIONAL

10. Logging
    no_token_logging_rule: {{logs.no_token_logging_rule}}
11. References
    SSO session rules: {{xref:SSO-04}} | OPTIONAL
    Auth methods: {{xref:IAM-02}} | OPTIONAL
    Step-up rules: {{xref:SSO-07}} | OPTIONAL

Cross-References
Upstream: {{xref:IAM-02}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:IAM-06}}, {{xref:AUDIT-01}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define session model, TTLs, logout rule, and no-token-logging rule.
intermediate: Required. Define refresh/rotation and concurrency policy and telemetry.
advanced: Required. Add device binding, step-up reuse windows, and revocation rigor.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, storage ref, refresh trigger, rotation rule, device rule, max sessions, global logout, expiry prompt, optional telemetry metrics, remembered device/step-up window, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If session.model is UNKNOWN → block Completeness Gate.
If ttl.absolute is UNKNOWN → block Completeness Gate.
If refresh.supported is UNKNOWN → block Completeness Gate.
If revoke.rule is UNKNOWN → block Completeness Gate.
If telemetry.created_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.IAM
Pass conditions:
required_fields_present == true
session_model_and_ttls_defined == true
refresh_rotation_defined == true
logout_and_revocation_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

IAM-04

IAM-04 — Authorization Enforcement Points (where checks happen)
Header Block
template_id: IAM-04
title: Authorization Enforcement Points (where checks happen)
type: iam_authorization_enforcement_points
template_version: 1.0.0
output_path: 10_app/iam/IAM-04_Authorization_Enforcement_Points.md
compliance_gate_id: TMP-05.PRIMARY.IAM
upstream_dependencies: ["API-04", "ROUTE-04", "SEC-02"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "API-01", "API-04", "ROUTE-04", "SEC-02", "ADMIN-05"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical set of authorization enforcement points (AEPs): where AuthZ checks occur across API, background jobs, websockets, admin surfaces, and client routing. This template ensures AuthZ is enforced server-side and consistently instrumented.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
API surface: {{xref:API-01}} | OPTIONAL
AuthZ rules: {{xref:API-04}} | OPTIONAL
Route guard rules: {{xref:ROUTE-04}} | OPTIONAL
Security architecture: {{xref:SEC-02}} | OPTIONAL
Privileged API catalog: {{xref:ADMIN-05}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Enforcement point registry (aep_id list)
aep_id (stable identifier)
surface type (api/ws/job/admin/client)
location (middleware/handler/gateway)
What is checked (role/perm/abac attribute)
Decision inputs (user_id, tenant_id, resource_id)
Decision outputs (allow/deny + reason_code)
Logging/telemetry requirements (authz decisions)
Fail-closed rule (deny on error)
Test coverage requirement (unit/integration)

Optional Fields
Policy evaluation caching rules | OPTIONAL

Partial authorization (field-level) | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Critical authorization decisions MUST be enforced server-side at AEPs.
AEPs must fail closed on policy engine errors.
Every denial should produce a reason code for audit/diagnosis.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Registry Summary
   total_aep: {{meta.total}}
   surfaces_covered: {{meta.surfaces_covered}} | OPTIONAL
2. Enforcement Points (repeat per aep_id)
   AEP
   aep_id: {{aeps[0].aep_id}}
   surface: {{aeps[0].surface}}
   location: {{aeps[0].location}}
   checks: {{aeps[0].checks}}
   decision_inputs: {{aeps[0].decision_inputs}}
   deny_reason_codes: {{aeps[0].deny_reason_codes}} | OPTIONAL
   fail_closed: {{aeps[0].fail_closed}}
   telemetry:
   authz_allow_metric: {{aeps[0].telemetry.allow_metric}}
   authz_deny_metric: {{aeps[0].telemetry.deny_metric}} | OPTIONAL
   notes: {{aeps[0].notes}} | OPTIONAL

(Repeat per AEP.)

3. Logging / Reason Codes
   reason_code_format_rule: {{reasons.format_rule}}
   log_required_fields: {{logs.required_fields}} | OPTIONAL
4. Testing Requirements
   minimum_coverage: {{tests.minimum_coverage}}
   required_test_types: {{tests.required_test_types}} | OPTIONAL
5. References
   AuthZ rules: {{xref:API-04}} | OPTIONAL
   Role/perm model: {{xref:IAM-01}} | OPTIONAL
   Admin privileged surface: {{xref:ADMIN-05}} | OPTIONAL
   Security architecture: {{xref:SEC-02}} | OPTIONAL

Cross-References
Upstream: {{xref:API-04}}, {{xref:SPEC_INDEX}} | OPTIONAL

Downstream: {{xref:IAM-10}}, {{xref:AUDIT-03}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define AEP registry and fail-closed and at least one telemetry metric per AEP.
intermediate: Required. Define decision inputs and reason code rules and testing requirements.
advanced: Required. Add caching/field-level auth notes and strict surface coverage mapping.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, deny reason codes, optional deny metric, notes, surfaces covered, caching/field-level auth, required fields/test types, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If aeps[*].aep_id is UNKNOWN → block Completeness Gate.
If aeps[*].fail_closed is UNKNOWN → block Completeness Gate.
If aeps[*].telemetry.allow_metric is UNKNOWN → block Completeness Gate.
If tests.minimum_coverage is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.IAM
Pass conditions:
required_fields_present == true
aep_registry_defined == true
fail_closed_defined == true
telemetry_defined == true
testing_requirements_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

IAM-05

IAM-05 — Service-to-Service Auth (mTLS/JWT, identity)
Header Block
template_id: IAM-05
title: Service-to-Service Auth (mTLS/JWT, identity)
type: iam_service_to_service_auth
template_version: 1.0.0
output_path: 10_app/iam/IAM-05_Service_to_Service_Auth.md
compliance_gate_id: TMP-05.PRIMARY.IAM
upstream_dependencies: ["SEC-02", "SKM-06", "IXS-03"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SEC-02", "SKM-04", "SKM-06", "IXS-03"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical service-to-service authentication model: how internal services identify each other, what credentials are used (mTLS/JWT), how identities are issued/rotated, and how requests are authorized between services. This template must be consistent with trust boundaries and key/cert management rules.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Security architecture (trust boundaries): {{xref:SEC-02}} | OPTIONAL
Key types/usage: {{xref:SKM-04}} | OPTIONAL
Certificate management: {{xref:SKM-06}} | OPTIONAL
Network policy (allowlists): {{xref:IXS-03}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Service identity model (service_id naming)
Auth mechanism (mTLS/JWT/UNKNOWN)
Where verification happens (gateway/service)
Credential issuance model (CA/JWT issuer)
Rotation/renewal rules (SKM refs)
Audience/scope rules for JWT (if used)
Network allowlist policy (which services can call which)
Authorization model for internal calls (least privilege)
Telemetry requirements (auth failures, cert expiry)
Logging/redaction rules (no secrets)

Optional Fields
SPIFFE/SPIRE usage notes | OPTIONAL

Break-glass for internal auth | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Internal auth must be verifiable and rotated; no long-lived static secrets.
Fail closed on identity verification errors.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Service Identity
   service_id_rule: {{service.id_rule}}
   naming_convention: {{service.naming_convention}} | OPTIONAL
2. Auth Mechanism
   mechanism: {{auth.mechanism}} (mtls/jwt/UNKNOWN)
   verification_point: {{auth.verification_point}} (gateway/service/UNKNOWN)
3. Credential Issuance
   issuer_model: {{creds.issuer_model}}
   cert_ref: {{creds.cert_ref}} (expected: {{xref:SKM-06}}) | OPTIONAL
   jwt_issuer_ref: {{creds.jwt_issuer_ref}} | OPTIONAL
4. Rotation / Renewal
   rotation_policy_ref: {{creds.rotation_policy_ref}} (expected: {{xref:SKM-03}}) | OPTIONAL
   renewal_rule: {{creds.renewal_rule}} | OPTIONAL
5. JWT Rules (if applicable)
   audience_rule: {{jwt.audience_rule}} | OPTIONAL
   scope_rule: {{jwt.scope_rule}} | OPTIONAL
   ttl_seconds: {{jwt.ttl_seconds}} | OPTIONAL
6. Network Policy
   allowlist_rule: {{net.allowlist_rule}}
   policy_ref: {{net.policy_ref}} (expected: {{xref:IXS-03}}) | OPTIONAL
7. Authorization for Internal Calls
   least_privilege_rule: {{authz.least_privilege_rule}}
   service_to_service_permissions: {{authz.permissions}} | OPTIONAL
8. Telemetry
   auth_failure_metric: {{telemetry.auth_failure_metric}}
   cert_expiry_metric: {{telemetry.cert_expiry_metric}} | OPTIONAL
9. Logging
   no_secret_logging_rule: {{logs.no_secret_logging_rule}}
10. References
    Security architecture: {{xref:SEC-02}} | OPTIONAL
    Secrets/key mgmt: {{xref:SKM-01}} | OPTIONAL
    Certificates: {{xref:SKM-06}} | OPTIONAL

Cross-References
Upstream: {{xref:SEC-02}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:SKM-03}}, {{xref:SEC-06}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define mechanism, verification point, and allowlist rule.
intermediate: Required. Define issuance + rotation and telemetry.
advanced: Required. Add JWT audience/scope rigor, SPIFFE notes, and internal permission mapping.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, naming convention, refs, renewal rule, jwt rules, policy ref, permissions, cert expiry metric, spiffe/break-glass, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If auth.mechanism is UNKNOWN → block Completeness Gate.
If auth.verification_point is UNKNOWN → block Completeness Gate.
If net.allowlist_rule is UNKNOWN → block Completeness Gate.
If telemetry.auth_failure_metric is UNKNOWN → block Completeness Gate.
If logs.no_secret_logging_rule is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.IAM
Pass conditions:
required_fields_present == true
mechanism_and_verification_defined == true
issuance_and_rotation_defined == true
network_policy_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

IAM-06

IAM-06 — Admin & Privileged Access Policy (break-glass, step-up)
Header Block
template_id: IAM-06
title: Admin & Privileged Access Policy (break-glass, step-up)
type: iam_admin_privileged_access_policy
template_version: 1.0.0
output_path: 10_app/iam/IAM-06_Admin_Privileged_Access_Policy.md
compliance_gate_id: TMP-05.PRIMARY.IAM
upstream_dependencies: ["IAM-01", "SSO-07", "ADMIN-01"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "IAM-01", "SSO-07", "ADMIN-01", "AUDIT-07"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical policy for privileged access: admin roles, break-glass procedures, step-up requirements, session constraints for admins, and audit controls. This template must be consistent with role/permission model, MFA/step-up rules, and privileged action auditing.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Role/perm model: {{xref:IAM-01}} | OPTIONAL
MFA/step-up rules: {{xref:SSO-07}} | OPTIONAL
Admin capabilities matrix: {{xref:ADMIN-01}} | OPTIONAL
Privileged actions audit: {{xref:AUDIT-07}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Privileged roles list (role_ids)
What is considered privileged (capabilities/actions)
Step-up requirement rule (when required)
Break-glass supported (yes/no/UNKNOWN)
Break-glass process (how to activate/deactivate)
Admin session constraints (short TTL, device binding)
Approval requirements (2-person rule?) if applicable
Audit requirements (all privileged actions logged)
Access review cadence (IAM-09)
Telemetry requirements (privileged actions, break-glass usage)

Optional Fields
Just-in-time access policy | OPTIONAL

Emergency contact rules | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Privileged access must require MFA/step-up when policy says so.
Break-glass must be time-bound and auditable.
Admin sessions must be stricter than standard user sessions where possible.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Privileged Definition
   privileged_roles: {{priv.roles}}
   privileged_actions: {{priv.actions}}
2. Step-Up
   step_up_required_rule: {{step.rule}}
   step_up_ref: {{xref:SSO-07}} | OPTIONAL
3. Break-Glass
   supported: {{break.supported}}
   activation_steps: {{break.activation_steps}}
   max_duration_minutes: {{break.max_duration_minutes}} | OPTIONAL
4. Admin Session Constraints
   admin_ttl_seconds: {{session.admin_ttl_seconds}}
   device_binding_required: {{session.device_binding_required}} | OPTIONAL
5. Approvals
   approval_required: {{approve.required}} | OPTIONAL
   approval_rule: {{approve.rule}} | OPTIONAL
6. Audit
   audit_required: {{audit.required}}
   audit_ref: {{xref:AUDIT-07}} | OPTIONAL
   audit_fields: {{audit.fields}} | OPTIONAL
7. Reviews
   access_review_cadence: {{reviews.cadence}}
   review_ref: {{xref:IAM-09}} | OPTIONAL
8. Telemetry
   privileged_action_metric: {{telemetry.priv_action_metric}}
   break_glass_metric: {{telemetry.break_glass_metric}} | OPTIONAL
9. References
   Admin capabilities: {{xref:ADMIN-01}} | OPTIONAL
   Role model: {{xref:IAM-01}} | OPTIONAL
   Session policy: {{xref:IAM-03}} | OPTIONAL

Cross-References
Upstream: {{xref:IAM-01}}, {{xref:SPEC_INDEX}} | OPTIONAL

Downstream: {{xref:IAM-09}}, {{xref:SEC-06}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define privileged roles/actions and break-glass steps (or mark UNKNOWN).
intermediate: Required. Define admin session TTL and audit rules and access review cadence.
advanced: Required. Add JIT access and approvals rigor and telemetry fields.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, max duration, approvals, audit fields, break glass metric, jit/emergency contact, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If priv.roles is UNKNOWN → block Completeness Gate.
If step.rule is UNKNOWN → block Completeness Gate.
If break.activation_steps is UNKNOWN → block Completeness Gate (when break.supported == true).
If audit.required is UNKNOWN → block Completeness Gate.
If telemetry.priv_action_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.IAM
Pass conditions:
required_fields_present == true
privileged_definition_defined == true
step_up_and_break_glass_defined == true
audit_defined == true
reviews_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

IAM-07

IAM-07 — Account Lifecycle (provision, deprovision, recovery)
Header Block
template_id: IAM-07
title: Account Lifecycle (provision, deprovision, recovery)
type: iam_account_lifecycle
template_version: 1.0.0
output_path: 10_app/iam/IAM-07_Account_Lifecycle.md
compliance_gate_id: TMP-05.PRIMARY.IAM
upstream_dependencies: ["SSO-05", "IAM-02", "PRIV-05"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "IAM-01", "IAM-02", "SSO-05", "ADMIN-04", "PRIV-05"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical lifecycle for user accounts: creation/provisioning (self-serve or SCIM), activation, suspension, deprovisioning, recovery, and deletion/retention interactions. This template must align with SSO/SCIM specs, auth methods, and privacy deletion rules.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Role/perm model: {{xref:IAM-01}} | OPTIONAL
Auth methods: {{xref:IAM-02}} | OPTIONAL
SCIM provisioning: {{xref:SSO-05}} | OPTIONAL
Admin data repair procedures: {{xref:ADMIN-04}} | OPTIONAL
Privacy retention/deletion: {{xref:PRIV-05}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Account states (pending/active/suspended/deleted/UNKNOWN)
Provisioning methods supported (self-serve/SCIM/admin)
Activation rules (email verify, SSO first login)
Default role assignment rule (IAM-01 ref)
Deprovisioning triggers (SCIM deprovision, admin action, inactivity)
Suspension rules (why/how)
Recovery methods (reset, admin restore)
Deletion/retention interaction rule (PRIV-05)
Audit requirements (account state changes)
Telemetry requirements (provision success, deprovision events)

Optional Fields
Dormant account policy | OPTIONAL

Reactivation policy | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Deprovisioning must revoke sessions and access promptly.
Account deletion must respect legal holds/retention policies.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. States
   states: {{states.list}}
   state_definitions: {{states.definitions}} | OPTIONAL
2. Provisioning
   methods_supported: {{prov.methods_supported}}
   activation_rule: {{prov.activation_rule}}
   default_role_ref: {{xref:IAM-01}} | OPTIONAL
3. Deprovisioning
   triggers: {{deprov.triggers}}
   steps: {{deprov.steps}}
   session_revoke_rule: {{deprov.session_revoke_rule}} | OPTIONAL
4. Suspension
   reasons: {{susp.reasons}}
   how_to_suspend: {{susp.how_to_suspend}}
5. Recovery
   methods: {{recovery.methods}}
   security_rules: {{recovery.security_rules}} | OPTIONAL
6. Deletion / Retention
   privacy_ref: {{xref:PRIV-05}} | OPTIONAL
   deletion_interaction_rule: {{delete.interaction_rule}}
7. Audit
   audit_required: {{audit.required}}
   audit_events: {{audit.events}}
   audit_fields: {{audit.fields}} | OPTIONAL
8. Telemetry
   provision_success_metric: {{telemetry.provision_success_metric}}
   deprovision_metric: {{telemetry.deprovision_metric}} | OPTIONAL
9. References
   Auth methods: {{xref:IAM-02}} | OPTIONAL
   Session policy: {{xref:IAM-03}} | OPTIONAL
   SCIM provisioning: {{xref:SSO-05}} | OPTIONAL
   Admin repair: {{xref:ADMIN-04}} | OPTIONAL

Cross-References
Upstream: {{xref:IAM-02}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:IAM-10}}, {{xref:AUDIT-01}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define states, provisioning methods, and deprovision triggers/steps.
intermediate: Required. Define suspension/recovery rules and audit events.
advanced: Required. Add dormant/reactivation policies and session revoke rigor.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, definitions, session revoke rule, recovery security rules, audit fields, optional telemetry metrics, dormant/reactivation, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If states.list is UNKNOWN → block Completeness Gate.
If prov.activation_rule is UNKNOWN → block Completeness Gate.
If deprov.steps is UNKNOWN → block Completeness Gate.
If delete.interaction_rule is UNKNOWN → block Completeness Gate.
If telemetry.provision_success_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.IAM
Pass conditions:
required_fields_present == true
states_and_provisioning_defined == true
deprovisioning_defined == true
deletion_retention_interaction_defined == true
audit_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

IAM-08

IAM-08 — API Key Policy (creation, scoping, rotation, revocation)
Header Block
template_id: IAM-08
title: API Key Policy (creation, scoping, rotation, revocation)
type: iam_api_key_policy
template_version: 1.0.0
output_path: 10_app/iam/IAM-08_API_Key_Policy.md
compliance_gate_id: TMP-05.PRIMARY.IAM
upstream_dependencies: ["API-04", "SKM-02", "AUDIT-01"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "API-01", "API-04", "SKM-02", "AUDIT-01", "ADMIN-05"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical policy for API keys: how keys are created, scoped, stored, rotated, revoked, and audited. This template must be consistent with AuthZ rules and secrets storage policies and must not invent key capabilities beyond upstream inputs.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
API surface: {{xref:API-01}} | OPTIONAL
AuthZ rules: {{xref:API-04}} | OPTIONAL
Secrets storage policy: {{xref:SKM-02}} | OPTIONAL
Audit event catalog: {{xref:AUDIT-01}} | OPTIONAL
Privileged API catalog: {{xref:ADMIN-05}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
API key types supported (user key/service key/UNKNOWN)
Key format rule (prefix, length, hashing)
Creation rules (who can create)
Scope model (perm scopes, endpoint scopes)
Default scope rule (least privilege)
Storage rule (hashed at rest)
Rotation policy (intervals, triggers)
Revocation policy (immediate, propagate)
Usage logging rules (what is logged)
Rate limits for key usage (RLIM refs)
Telemetry requirements (key auth success/fail, revoked usage)

Optional Fields
Key expiration support | OPTIONAL
Key allowlist/denylist policy | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Keys must never be stored in plaintext; store hashes only.
Scopes must be least-privilege and enforceable at authorization points.
Key creation/rotation/revocation must be auditable.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Key Types
   types: {{keys.types}}
2. Format
   format_rule: {{keys.format_rule}}
   hashing_rule: {{keys.hashing_rule}}
3. Creation
   who_can_create: {{create.who_can_create}}
   creation_surface: {{create.surface}} | OPTIONAL
4. Scoping
   scope_model: {{scope.model}}
   default_scope_rule: {{scope.default_rule}}
   scope_examples: {{scope.examples}} | OPTIONAL
5. Storage
   hashed_at_rest: {{store.hashed_at_rest}}
   storage_ref: {{store.storage_ref}} (expected: {{xref:SKM-02}}) | OPTIONAL
6. Rotation
   rotation_required: {{rotate.required}}
   interval_days: {{rotate.interval_days}} | OPTIONAL
   rotation_triggers: {{rotate.triggers}} | OPTIONAL
7. Revocation
   revoke_supported: {{revoke.supported}}
   revoke_rule: {{revoke.rule}}
   propagation_rule: {{revoke.propagation_rule}} | OPTIONAL
8. Logging / Rate Limits
   usage_log_fields: {{logs.usage_log_fields}}
   rate_limit_ref: {{logs.rate_limit_ref}} (expected: {{xref:RLIM-01}}/{{xref:RLIM-02}}) | OPTIONAL
9. Telemetry
   key_auth_success_metric: {{telemetry.auth_success_metric}}
   key_auth_failure_metric: {{telemetry.auth_failure_metric}} | OPTIONAL
   revoked_key_usage_metric: {{telemetry.revoked_usage_metric}} | OPTIONAL

10. References
    AuthZ rules: {{xref:API-04}} | OPTIONAL
    Secrets storage: {{xref:SKM-02}} | OPTIONAL
    Rate limits: {{xref:RLIM-01}} | OPTIONAL
    Audit schema: {{xref:AUDIT-02}} | OPTIONAL

Cross-References
Upstream: {{xref:API-04}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:IAM-10}}, {{xref:AUDIT-01}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define key types, hashing rule, scope model, and revoke rule.
intermediate: Required. Define rotation and logging fields and telemetry.
advanced: Required. Add expiration/allowlist controls and strict propagation/rate-limit linkage.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, creation surface, examples, storage ref, interval/triggers, propagation, rate limit ref, optional metrics, expiration/allowlist, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If keys.format_rule is UNKNOWN → block Completeness Gate.
If keys.hashing_rule is UNKNOWN → block Completeness Gate.
If scope.model is UNKNOWN → block Completeness Gate.
If revoke.rule is UNKNOWN → block Completeness Gate.
If telemetry.auth_success_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.IAM
Pass conditions:
required_fields_present == true
format_and_hashing_defined == true
scoping_defined == true
rotation_and_revocation_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

IAM-09

IAM-09 — Access Reviews (periodic review, attestations)
Header Block
template_id: IAM-09
title: Access Reviews (periodic review, attestations)
type: iam_access_reviews
template_version: 1.0.0
output_path: 10_app/iam/IAM-09_Access_Reviews.md
compliance_gate_id: TMP-05.PRIMARY.IAM
upstream_dependencies: ["IAM-01", "IAM-06", "COMP-07"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "IAM-01", "IAM-06", "COMP-07", "AUDIT-07"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical access review process: who is reviewed (privileged roles, API keys, service identities), how often, what evidence is captured, and how removals are executed and audited. This template must align with privileged access policy and compliance risk assessment expectations.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Role/perm model: {{xref:IAM-01}} | OPTIONAL
Privileged access policy: {{xref:IAM-06}} | OPTIONAL
Risk assessment process: {{xref:COMP-07}} | OPTIONAL
Privileged actions audit: {{xref:AUDIT-07}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Review scope (what access types covered)
Review cadence (monthly/quarterly/UNKNOWN)
Reviewer roles (who attests)
Evidence required (export, report, signoff record)
Review workflow steps (generate list → review → remediate → close)
Remediation rules (remove access, rotate keys)
Escalation rules (non-response, high-risk findings)
Audit logging requirements (review performed + changes)
Telemetry requirements (reviews completed on time, findings)

Optional Fields
Automated review support | OPTIONAL

Sampling rules | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Reviews must include privileged roles and machine credentials at minimum.
Remediations must be tracked to closure.
Evidence must be stored in an audit-safe location.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Scope
   access_types: {{scope.access_types}}
   minimum_included: {{scope.minimum_included}} | OPTIONAL
2. Cadence & Reviewers
   cadence: {{cadence.value}}
   reviewer_roles: {{reviewers.roles}}
3. Evidence
   evidence_artifacts: {{evidence.artifacts}}
   storage_location: {{evidence.storage_location}} | OPTIONAL
4. Workflow
   steps:
   {{workflow.steps[0]}}
   {{workflow.steps[1]}}
   {{workflow.steps[2]}} | OPTIONAL
5. Remediation
   remediation_actions: {{remed.actions}}
   time_to_fix_rule: {{remed.time_to_fix_rule}} | OPTIONAL
6. Escalation
   non_response_rule: {{esc.non_response_rule}}
   high_risk_rule: {{esc.high_risk_rule}} | OPTIONAL
7. Audit
   audit_required: {{audit.required}}
   audit_events: {{audit.events}}
   audit_ref: {{xref:AUDIT-07}} | OPTIONAL
8. Telemetry
   review_completion_metric: {{telemetry.completion_metric}}
   finding_count_metric: {{telemetry.finding_count_metric}} | OPTIONAL
9. References
   Privileged access: {{xref:IAM-06}} | OPTIONAL
   API key policy: {{xref:IAM-08}} | OPTIONAL
   Service auth: {{xref:IAM-05}} | OPTIONAL
   Compliance risk: {{xref:COMP-07}} | OPTIONAL

Cross-References
Upstream: {{xref:IAM-06}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:SEC-06}}, {{xref:COMP-10}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define cadence, scope, reviewers, and workflow steps.
intermediate: Required. Define evidence artifacts and remediation/escalation rules.
advanced: Required. Add automation/sampling and strict telemetry and audit event rigor.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, minimum included, storage location, extra workflow steps, time-to-fix, high risk rule, audit ref, optional metrics, automation/sampling, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If scope.access_types is UNKNOWN → block Completeness Gate.
If cadence.value is UNKNOWN → block Completeness Gate.
If reviewers.roles is UNKNOWN → block Completeness Gate.
If workflow.steps[0] is UNKNOWN → block Completeness Gate.
If telemetry.completion_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.IAM
Pass conditions:
required_fields_present == true
scope_and_cadence_defined == true
workflow_defined == true
audit_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

IAM-10

IAM-10 — Access Observability (auth logs, auth failures, metrics)
Header Block
template_id: IAM-10
title: Access Observability (auth logs, auth failures, metrics)
type: iam_access_observability
template_version: 1.0.0
output_path: 10_app/iam/IAM-10_Access_Observability.md
compliance_gate_id: TMP-05.PRIMARY.IAM
upstream_dependencies: ["IAM-03", "AUDIT-02", "SEC-06"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "IAM-02", "IAM-03", "IAM-04", "AUDIT-02", "SEC-06", "CER-05"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical observability for authentication and authorization: required logs, metrics, dashboards, and alerts for access failures, suspicious patterns, and policy denials. This template must align with audit schema requirements and security monitoring.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Auth methods: {{xref:IAM-02}} | OPTIONAL
Session policy: {{xref:IAM-03}} | OPTIONAL
AuthZ enforcement points: {{xref:IAM-04}} | OPTIONAL
Audit schema: {{xref:AUDIT-02}} | OPTIONAL
Security monitoring: {{xref:SEC-06}} | OPTIONAL
Logging/redaction: {{xref:CER-05}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Log event types list (login_success, login_fail, authz_deny, token_refresh)
Required log fields (timestamp, user_id hash, tenant_id, ip hash, device id)
Redaction rules (no tokens, no secrets)
Core metrics (success rate, failure rate, deny rate)
Dashboards minimum panels
Alerts (credential stuffing, authz deny spike, refresh fail spike)
Alert routing policy (oncall/security)
Retention rules for auth logs
High-cardinality controls (hashing, sampling)
Runbook references (SEC-10)

Optional Fields
Geo anomaly rules | OPTIONAL
Risk scoring notes | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Never log tokens/secrets.
User identifiers should be hashed in logs unless explicitly approved.
Alerts must be actionable and link to runbooks.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Event Types
   event_types: {{events.types}}
2. Log Fields
   required_fields: {{logs.required_fields}}
   hashing_rule: {{logs.hashing_rule}} | OPTIONAL
3. Redaction
   no_token_logging_rule: {{redact.no_token_logging_rule}}
   no_secret_logging_rule: {{redact.no_secret_logging_rule}} | OPTIONAL
4. Metrics
   login_success_rate_metric: {{metrics.login_success_rate_metric}}
   login_failure_rate_metric: {{metrics.login_failure_rate_metric}} | OPTIONAL
   authz_deny_rate_metric: {{metrics.authz_deny_rate_metric}} | OPTIONAL
5. Dashboards
   dashboard_name: {{dash.name}}
   minimum_panels: {{dash.minimum_panels}}
   panel_list: {{dash.panel_list}} | OPTIONAL
6. Alerts
   Alert
   alert_id: {{alerts[0].alert_id}}
   condition: {{alerts[0].condition}}
   severity: {{alerts[0].severity}} (low/med/high/UNKNOWN)
   routing: {{alerts[0].routing}}
   runbook_ref: {{alerts[0].runbook_ref}} | OPTIONAL

(Repeat per alert.)

7. Retention
   retention_days: {{retention.days}}
8. High-Cardinality Controls
   subscription_or_user_hash_rule: {{cardinality.hash_rule}}
   sampling_rule: {{cardinality.sampling_rule}} | OPTIONAL

9. References
   Security monitoring: {{xref:SEC-06}} | OPTIONAL
   Security runbooks: {{xref:SEC-10}} | OPTIONAL
   Audit schema: {{xref:AUDIT-02}} | OPTIONAL

Cross-References
Upstream: {{xref:IAM-03}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:AUDIT-09}}, {{xref:SEC-05}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL, {{standards.rules[STD-PII-REDACTION]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define event types, required fields, and retention.
intermediate: Required. Define metrics, dashboards, and at least one alert.
advanced: Required. Add geo anomaly/risk scoring and strict high-cardinality controls.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, hashing rule, panel list, runbook refs, optional metrics, sampling rule, geo/risk notes, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If events.types is UNKNOWN → block Completeness Gate.
If logs.required_fields is UNKNOWN → block Completeness Gate.
If redact.no_token_logging_rule is UNKNOWN → block Completeness Gate.
If dash.minimum_panels is UNKNOWN → block Completeness Gate.
If retention.days is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.IAM
Pass conditions:
required_fields_present == true
event_types_and_logs_defined == true
redaction_defined == true
dashboards_and_alerts_defined == true
retention_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

Threat Modeling & Abuse Prevention (TMA)

TMA-01

TMA-01 — Threat Model Scope & Method (assets, actors, STRIDE)
Header Block
template_id: TMA-01
title: Threat Model Scope & Method (assets, actors, STRIDE)
type: threat_model_scope_method
template_version: 1.0.0
output_path: 10_app/threat_model/TMA-01_Threat_Model_Scope_Method.md
compliance_gate_id: TMP-05.PRIMARY.TMA
upstream_dependencies: ["SEC-02", "SPEC_INDEX"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SEC-02", "TMA-03", "PRIV-01"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical scope and method for threat modeling: what assets and surfaces are included, attacker personas, and the analysis method (e.g., STRIDE), plus required outputs (abuse cases, risk register). This template anchors the TMA series and must align with security architecture.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Security architecture: {{xref:SEC-02}} | OPTIONAL
Attack surface inventory: {{xref:TMA-03}} | OPTIONAL
Data inventory: {{xref:PRIV-01}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Scope statement (what is included)
Out-of-scope statement (explicit)
Assets list (asset_id list)
Actor list (actor_id list)
Threat modeling method (STRIDE/PASTA/UNKNOWN)
Diagram inventory requirement (DFDs / trust boundaries refs)
Required outputs list (TMA-02, TMA-04, TMA-05)
Review cadence (when updated)
Ownership (who maintains threat model)
Telemetry/evidence pointers (where findings tracked)

Optional Fields
Assumed constraints (time/tools) | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Do not invent assets/actors; if missing, mark UNKNOWN and flag.
Method must be explicit and consistently applied.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Scope
   in_scope:
   {{scope.in[0]}}
   {{scope.in[1]}}
   out_of_scope:
   {{scope.out[0]}}
   {{scope.out[1]}}
2. Assets
   Asset
   asset_id: {{assets[0].asset_id}}
   name: {{assets[0].name}}
   data_classes: {{assets[0].data_classes}} | OPTIONAL
   notes: {{assets[0].notes}} | OPTIONAL

(Repeat per asset.)

3. Actors
   Actor
   actor_id: {{actors[0].actor_id}}
   name: {{actors[0].name}}
   capabilities: {{actors[0].capabilities}} | OPTIONAL

(Repeat per actor.)

4. Method
   method: {{method.name}} (STRIDE/PASTA/UNKNOWN)
   steps: {{method.steps}} | OPTIONAL
5. Diagrams
   required_diagrams: {{diagrams.required}}
   dfd_ref: {{diagrams.dfd_ref}} | OPTIONAL
6. Required Outputs
   outputs: {{outputs.list}} (expected: {{xref:TMA-02}}, {{xref:TMA-04}}, {{xref:TMA-05}})
7. Governance
   owner: {{gov.owner}}
   review_cadence: {{gov.review_cadence}}
   tracking_location: {{gov.tracking_location}} | OPTIONAL

8. References
   Security architecture: {{xref:SEC-02}} | OPTIONAL
   Attack surface: {{xref:TMA-03}} | OPTIONAL
   Data inventory: {{xref:PRIV-01}} | OPTIONAL

Cross-References
Upstream: {{xref:SEC-02}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:TMA-02}}, {{xref:TMA-04}}, {{xref:TMA-05}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define scope, method, and at least starter assets/actors lists (UNKNOWN allowed if flagged).
intermediate: Required. Define diagrams and outputs and tracking.
advanced: Required. Add explicit actor capabilities and review cadence rigor and traceability pointers.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, data classes/notes, capabilities, method steps, dfd ref, tracking location, constraints, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If scope.in is UNKNOWN → block Completeness Gate.
If assets list is UNKNOWN → block Completeness Gate.
If actors list is UNKNOWN → block Completeness Gate.
If method.name is UNKNOWN → block Completeness Gate.
If gov.owner is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.TMA
Pass conditions:
required_fields_present == true
scope_assets_actors_defined == true
method_defined == true
governance_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

TMA-02

TMA-02 — Abuse Case Catalog (by abuse_id)
Header Block
template_id: TMA-02
title: Abuse Case Catalog (by abuse_id)
type: abuse_case_catalog
template_version: 1.0.0
output_path: 10_app/threat_model/TMA-02_Abuse_Case_Catalog.md
compliance_gate_id: TMP-05.PRIMARY.TMA
upstream_dependencies: ["TMA-01", "TMA-03", "RLIM-03"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "TMA-01", "TMA-03", "RLIM-03", "PAY-08"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Create the canonical catalog of abuse cases (misuse scenarios) the system must defend against, indexed by abuse_id, including impacted assets, attack steps, detection signals, and mitigations pointers. This template must align with attack surface inventory and existing abuse/rate-limit controls.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Threat model scope/method: {{xref:TMA-01}} | OPTIONAL
Attack surface inventory: {{xref:TMA-03}} | OPTIONAL
Abuse signals/detection: {{xref:RLIM-03}} | OPTIONAL
Payments fraud controls: {{xref:PAY-08}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Abuse registry (abuse_id list)
abuse_id (stable identifier)
Title
Impacted surfaces (api/web/mobile/ws)
Impacted assets (asset_id refs)
Attacker type (actor_id ref)
Attack steps (ordered)
Primary impact (fraud, spam, data leak, DoS)
Detection signals (metrics/logs)
Mitigation/control references (RLIM/TMA-05/SEC/IAM)
Residual risk rating (high/med/low/UNKNOWN)
Telemetry requirements (abuse attempts detected)

Optional Fields
Customer harm notes | OPTIONAL
Manual moderation workflow ref | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Each abuse case must link to at least one detection signal and one mitigation/control.
Do not invent actor/asset IDs; use those defined in TMA-01 where possible.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Registry Summary
   total_abuse_cases: {{meta.total}}
   notes: {{meta.notes}} | OPTIONAL
2. Abuse Cases (repeat per abuse_id)
   Abuse Case
   abuse_id: {{cases[0].abuse_id}}
   title: {{cases[0].title}}
   surfaces: {{cases[0].surfaces}}
   assets: {{cases[0].assets}}
   attacker: {{cases[0].attacker}}
   impact: {{cases[0].impact}}
   attack_steps:
   {{cases[0].steps[0]}}
   {{cases[0].steps[1]}}
   {{cases[0].steps[2]}} | OPTIONAL
   detection_signals: {{cases[0].detection_signals}}
   mitigation_refs: {{cases[0].mitigation_refs}}
   residual_risk: {{cases[0].residual_risk}}
   telemetry_metric: {{cases[0].telemetry_metric}}
   customer_harm: {{cases[0].customer_harm}} | OPTIONAL
   moderation_ref: {{cases[0].moderation_ref}} | OPTIONAL

(Repeat per abuse case.)

3. References
   Attack surface: {{xref:TMA-03}} | OPTIONAL
   Risk register: {{xref:TMA-04}} | OPTIONAL
   Mitigation mapping: {{xref:TMA-05}} | OPTIONAL
   Rate limits/abuse signals: {{xref:RLIM-03}} | OPTIONAL
   Enforcement actions: {{xref:RLIM-04}} | OPTIONAL

Cross-References
Upstream: {{xref:TMA-01}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:TMA-04}}, {{xref:TMA-05}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define abuse registry and steps and one detection + mitigation per case.
intermediate: Required. Add attacker/asset refs and residual risk rating and telemetry metric.
advanced: Required. Add customer harm/moderation refs and tighter mitigation traceability.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, notes, optional step, customer harm, moderation ref, actor/asset refs if not available (must be flagged), residual risk if uncertain
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If cases[*].abuse_id is UNKNOWN → block Completeness Gate.
If cases[*].steps[0] is UNKNOWN → block Completeness Gate.
If cases[*].detection_signals is UNKNOWN → block Completeness Gate.
If cases[*].mitigation_refs is UNKNOWN → block Completeness Gate.
If cases[*].telemetry_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.TMA
Pass conditions:
required_fields_present == true
abuse_registry_defined == true
each_case_has_detection_and_mitigation == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

TMA-03

TMA-03 — Attack Surface Inventory (endpoints, clients, integrations)
Header Block
template_id: TMA-03
title: Attack Surface Inventory (endpoints, clients, integrations)
type: attack_surface_inventory
template_version: 1.0.0
output_path: 10_app/threat_model/TMA-03_Attack_Surface_Inventory.md
compliance_gate_id: TMP-05.PRIMARY.TMA
upstream_dependencies: ["API-01", "WHCP-01", "FMS-02", "ROUTE-01"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "API-01", "WHCP-01", "FMS-02", "ROUTE-01", "MOB-01"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Create the canonical inventory of externally reachable and high-risk internal surfaces that can be attacked: API endpoints, web/mobile clients, webhooks, file upload surfaces, and third-party integration entry points. This template is used to drive threat modeling coverage and monitoring.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
API endpoint catalog: {{xref:API-01}} | OPTIONAL
Webhook catalog: {{xref:WHCP-01}} | OPTIONAL
Upload/download spec: {{xref:FMS-02}} | OPTIONAL
Route contract: {{xref:ROUTE-01}} | OPTIONAL
Mobile navigation map: {{xref:MOB-01}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Surface registry (surface_id list)
surface_id (stable identifier)
surface type (api/web/mobile/webhook/upload/admin/ws)
Identifier (endpoint_id/path, route_id, webhook_id, etc.)
Auth requirement (public/authenticated/UNKNOWN)
Primary risk class (low/med/high/UNKNOWN)
Data classes exposed (PII, payments, etc.)
Rate limit applicability (RLIM ref)
Logging/monitoring expectation (SEC-06 ref)
Owner (team/service)

Optional Fields
Deprecation status | OPTIONAL

Known mitigations summary | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Every surface must declare auth requirement and risk class.
Do not invent endpoint IDs/routes/webhook IDs; reference upstream inventories when available.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Inventory Summary
   total_surfaces: {{meta.total}}
   by_type: {{meta.by_type}} | OPTIONAL
2. Surfaces (repeat per surface_id)
   Surface
   surface_id: {{surfaces[0].surface_id}}
   type: {{surfaces[0].type}}
   identifier: {{surfaces[0].identifier}}
   auth_requirement: {{surfaces[0].auth_requirement}}
   risk_class: {{surfaces[0].risk_class}}
   data_classes: {{surfaces[0].data_classes}}
   rate_limit_ref: {{surfaces[0].rate_limit_ref}} | OPTIONAL
   monitoring_ref: {{surfaces[0].monitoring_ref}} (expected: {{xref:SEC-06}}) | OPTIONAL
   owner: {{surfaces[0].owner}}
   status: {{surfaces[0].status}} | OPTIONAL
   known_mitigations: {{surfaces[0].known_mitigations}} | OPTIONAL
   open_questions:
   {{surfaces[0].open_questions[0]}} | OPTIONAL

(Repeat per surface.)

3. References
   Security monitoring: {{xref:SEC-06}} | OPTIONAL
   Abuse catalog: {{xref:TMA-02}} | OPTIONAL
   Risk register: {{xref:TMA-04}} | OPTIONAL

Cross-References
Upstream: {{xref:API-01}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:TMA-04}}, {{xref:SEC-06}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define surface list with auth requirement and risk class (UNKNOWN allowed if flagged).

intermediate: Required. Add data classes, owner, and monitoring references.
advanced: Required. Add mitigations summaries, deprecation status, and strict traceability to upstream IDs.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, rate limit ref, monitoring ref, status, mitigations, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If surfaces[*].surface_id is UNKNOWN → block Completeness Gate.
If surfaces[*].auth_requirement is UNKNOWN → block Completeness Gate.
If surfaces[*].risk_class is UNKNOWN → block Completeness Gate.
If surfaces[*].owner is UNKNOWN → block Completeness Gate.
If surfaces[*].data_classes is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.TMA
Pass conditions:
required_fields_present == true
surface_registry_defined == true
each_surface_has_auth_and_risk == true
data_classes_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

TMA-04

TMA-04 — Risk Register (threats, likelihood, impact, mitigations)
Header Block
template_id: TMA-04
title: Risk Register (threats, likelihood, impact, mitigations)
type: threat_risk_register
template_version: 1.0.0
output_path: 10_app/threat_model/TMA-04_Risk_Register.md
compliance_gate_id: TMP-05.PRIMARY.TMA
upstream_dependencies: ["TMA-02", "TMA-03", "SEC-03"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "TMA-01", "TMA-02", "TMA-03", "SEC-03", "COMP-07"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical risk register for threats and abuse: each risk item, what it impacts, likelihood/impact ratings, existing mitigations, gaps, owners, and tracking status. This template must align with abuse cases and security baseline controls and should be used to drive remediation work.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Threat model scope/method: {{xref:TMA-01}} | OPTIONAL
Abuse case catalog: {{xref:TMA-02}} | OPTIONAL
Attack surface inventory: {{xref:TMA-03}} | OPTIONAL
Security baseline controls: {{xref:SEC-03}} | OPTIONAL
Risk assessment process: {{xref:COMP-07}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Risk registry (risk_id list)
risk_id (stable identifier)
Title/description
Linked abuse_id or threat ref (if applicable)
Impacted surfaces (surface_id refs)
Impacted assets (asset_id refs)
Likelihood rating (low/med/high/UNKNOWN)
Impact rating (low/med/high/UNKNOWN)
Overall risk rating (derive or explicit)
Existing mitigations (control refs)
Gaps/needed mitigations
Owner

Status (open/mitigating/accepted/closed/UNKNOWN)
Review date/cadence
Telemetry requirement (how monitored)

Optional Fields
Due date | OPTIONAL
Risk acceptance record (if accepted) | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Each risk must link to at least one mitigation or explicitly state NONE + gap.
Risk acceptance must follow SEC-08/COMP-08 (time-bound, approved).
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Registry Summary
   total_risks: {{meta.total}}
   open_high_risks: {{meta.open_high}} | OPTIONAL
2. Risk Items (repeat per risk_id)
   Risk
   risk_id: {{risks[0].risk_id}}
   title: {{risks[0].title}}
   description: {{risks[0].description}}
   linked_abuse_id: {{risks[0].linked_abuse_id}} | OPTIONAL
   surfaces: {{risks[0].surfaces}}
   assets: {{risks[0].assets}}
   likelihood: {{risks[0].likelihood}}
   impact: {{risks[0].impact}}
   overall: {{risks[0].overall}} | OPTIONAL
   mitigations: {{risks[0].mitigations}}
   gaps: {{risks[0].gaps}}
   owner: {{risks[0].owner}}
   status: {{risks[0].status}}
   review_cadence: {{risks[0].review_cadence}}
   telemetry: {{risks[0].telemetry}}
   due_date: {{risks[0].due_date}} | OPTIONAL
   acceptance_ref: {{risks[0].acceptance_ref}} | OPTIONAL
   open_questions:
   {{risks[0].open_questions[0]}} | OPTIONAL

(Repeat per risk.)

3. References
   Abuse catalog: {{xref:TMA-02}} | OPTIONAL
   Attack surface: {{xref:TMA-03}} | OPTIONAL
   Mitigation mapping: {{xref:TMA-05}} | OPTIONAL
   Exceptions: {{xref:SEC-08}} | OPTIONAL

Cross-References
Upstream: {{xref:TMA-02}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:TMA-05}}, {{xref:SEC-06}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define risks with likelihood/impact and at least one mitigation or gap.
intermediate: Required. Add owner, status, review cadence, and telemetry per risk.
advanced: Required. Add due dates, acceptance refs, and consistent derived overall risk rating.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, linked abuse id, overall rating, due date, acceptance ref, open questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If risks[*].risk_id is UNKNOWN → block Completeness Gate.
If risks[*].surfaces is UNKNOWN → block Completeness Gate.
If risks[*].likelihood is UNKNOWN → block Completeness Gate.
If risks[*].impact is UNKNOWN → block Completeness Gate.
If risks[*].mitigations is UNKNOWN → block Completeness Gate (unless explicitly NONE + gaps populated).

Completeness Gate
Gate ID: TMP-05.PRIMARY.TMA
Pass conditions:
required_fields_present == true
risk_registry_defined == true
each_risk_has_mitigations_or_gaps == true
owners_and_status_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

TMA-05

TMA-05 — Mitigation Mapping (threat → control → owner)
Header Block
template_id: TMA-05
title: Mitigation Mapping (threat → control → owner)
type: threat_mitigation_mapping
template_version: 1.0.0
output_path: 10_app/threat_model/TMA-05_Mitigation_Mapping.md
compliance_gate_id: TMP-05.PRIMARY.TMA
upstream_dependencies: ["TMA-04", "SEC-03", "COMP-02"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "TMA-02", "TMA-04", "SEC-03", "COMP-02", "RLIM-04"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Create the canonical mapping from threats/abuse/risk items to implemented controls, owners, and evidence. This is the bridge between threat modeling, security requirements, and compliance control matrices.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Abuse catalog: {{xref:TMA-02}} | OPTIONAL
Risk register: {{xref:TMA-04}} | OPTIONAL
Security controls baseline: {{xref:SEC-03}} | OPTIONAL
Compliance control matrix: {{xref:COMP-02}} | OPTIONAL
Enforcement actions matrix: {{xref:RLIM-04}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Mapping registry (map_id list)
map_id (stable identifier)
risk_id or abuse_id binding
control_id binding (SEC-03)
owner (team/role)
Implementation reference (where implemented)
Verification proof reference (test/report)
Status (planned/in_progress/done/UNKNOWN)
Residual risk note (after control)
Telemetry reference (monitoring signal)

Optional Fields
Compensating controls (if partial) | OPTIONAL

Compliance control linkage (COMP-02 control_id) | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Every mapping must include implementation and verification proof references (or approved UNKNOWN).
Controls must be real and traceable to SEC-03.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Registry Summary
   total_mappings: {{meta.total}}
   done_count: {{meta.done_count}} | OPTIONAL
2. Mappings (repeat per map_id)
   Mapping
   map_id: {{maps[0].map_id}}
   risk_id: {{maps[0].risk_id}} | OPTIONAL
   abuse_id: {{maps[0].abuse_id}} | OPTIONAL
   control_id: {{maps[0].control_id}}
   owner: {{maps[0].owner}}
   implementation_ref: {{maps[0].implementation_ref}}
   verification_proof_ref: {{maps[0].verification_proof_ref}}
   status: {{maps[0].status}}
   residual_risk: {{maps[0].residual_risk}}
   telemetry_ref: {{maps[0].telemetry_ref}}
   comp_controls: {{maps[0].comp_controls}} | OPTIONAL
   comp_link: {{maps[0].comp_link}} | OPTIONAL
   open_questions:
   {{maps[0].open_questions[0]}} | OPTIONAL

(Repeat per mapping.)

3. References
   Risk register: {{xref:TMA-04}} | OPTIONAL
   Security requirements: {{xref:SEC-03}} | OPTIONAL
   Compliance control matrix: {{xref:COMP-02}} | OPTIONAL
   Security monitoring: {{xref:SEC-06}} | OPTIONAL

Cross-References
Upstream: {{xref:TMA-04}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:SEC-06}}, {{xref:COMP-09}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define mapping registry and include control_id + owner + status.
intermediate: Required. Add implementation refs and verification proof refs and telemetry refs.
advanced: Required. Add compliance linkage and residual risk notes and compensating controls rigor.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, done count, risk/abuse id (one must be present), comp controls/link, open questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If maps[*].map_id is UNKNOWN → block Completeness Gate.*
*If maps[*].control_id is UNKNOWN → block Completeness Gate.
If maps[*].implementation_ref is UNKNOWN → block Completeness Gate.*
*If maps[*].verification_proof_ref is UNKNOWN → block Completeness Gate.
If maps[*].telemetry_ref is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.TMA
Pass conditions:
required_fields_present == true
mapping_registry_defined == true
control_bindings_valid == true
implementation_and_proof_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

TMA-06

TMA-06 — Rate Limit & Bot Defense Strategy (captcha, device signals)
Header Block
template_id: TMA-06
title: Rate Limit & Bot Defense Strategy (captcha, device signals)
type: tma_rate_limit_bot_defense_strategy
template_version: 1.0.0
output_path: 10_app/threat_model/TMA-06_Rate_Limit_Bot_Defense_Strategy.md
compliance_gate_id: TMP-05.PRIMARY.TMA
upstream_dependencies: ["RLIM-01", "RLIM-03", "RLIM-04", "TMA-03"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "TMA-03", "RLIM-01", "RLIM-02", "RLIM-03", "RLIM-04", "FORM-06"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical strategy for bot defense and rate limiting: what surfaces are protected, what signals are used, what enforcement actions exist, and how users recover from false positives. This template must align with rate limit policies/catalogs and the attack surface inventory.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Attack surface inventory: {{xref:TMA-03}} | OPTIONAL
Rate limit policy: {{xref:RLIM-01}} | OPTIONAL
Rate limit catalog: {{xref:RLIM-02}} | OPTIONAL
Abuse signals: {{xref:RLIM-03}} | OPTIONAL
Enforcement matrix: {{xref:RLIM-04}} | OPTIONAL
Form anti-abuse: {{xref:FORM-06}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Protected surfaces list (surface_id refs)
Bot signal sources (ip/device/user behavior)
Challenge mechanisms supported (captcha/email verify/UNKNOWN)
Rate limit strategy (global + per surface)
Escalation ladder (warn → throttle → block)
False positive recovery process
Exemptions/allowlist policy
Telemetry requirements (bot blocks, captcha pass rate)
Privacy constraints (minimize device fingerprinting)
Runbook references (RLIM-06 / SEC-10)

Optional Fields
Adaptive risk scoring notes | OPTIONAL
Geo-based rules | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-PII-REDACTION]}} | OPTIONAL
Bot defense must not rely on collecting excessive PII; prefer coarse signals where possible.
Recovery process must exist and be documented.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Protected Surfaces
   surfaces: {{protect.surfaces}}
2. Signals
   signals: {{signals.list}}
   collection_rules: {{signals.collection_rules}} | OPTIONAL
3. Challenges
   supported: {{challenge.supported}}
   types: {{challenge.types}} | OPTIONAL
4. Rate Limit Strategy
   policy_ref: {{rate.policy_ref}} (expected: {{xref:RLIM-01}}) | OPTIONAL
   catalog_ref: {{rate.catalog_ref}} (expected: {{xref:RLIM-02}}) | OPTIONAL
5. Escalation Ladder
   ladder: {{enforce.ladder}}
6. False Positives
   recovery_process: {{fp.recovery_process}}
   appeals_rule: {{fp.appeals_rule}} | OPTIONAL
7. Exemptions
   exemptions_supported: {{exempt.supported}}
   allowlist_policy: {{exempt.allowlist_policy}} | OPTIONAL
8. Telemetry
   bot_block_metric: {{telemetry.bot_block_metric}}
   captcha_pass_metric: {{telemetry.captcha_pass_metric}} | OPTIONAL
   fields: {{telemetry.fields}} | OPTIONAL
9. Privacy Constraints
   minimization_rule: {{privacy.minimization_rule}}
   device_id_policy: {{privacy.device_id_policy}} | OPTIONAL
10. References
    Rate limit catalog: {{xref:RLIM-02}} | OPTIONAL
    Abuse signals: {{xref:RLIM-03}} | OPTIONAL
    Enforcement matrix: {{xref:RLIM-04}} | OPTIONAL
    Security runbooks: {{xref:SEC-10}} | OPTIONAL

Cross-References
Upstream: {{xref:TMA-03}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:TMA-07}}, {{xref:RLIM-06}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define protected surfaces, escalation ladder, and recovery process.
intermediate: Required. Define challenges and exemptions and telemetry metrics.
advanced: Required. Add adaptive/geo rules and strict minimization and evidence pointers.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, collection rules, challenge types, refs, appeals, allowlist policy, captcha metric/fields, device id policy, adaptive/geo notes, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If protect.surfaces is UNKNOWN → block Completeness Gate.
If enforce.ladder is UNKNOWN → block Completeness Gate.
If fp.recovery_process is UNKNOWN → block Completeness Gate.
If telemetry.bot_block_metric is UNKNOWN → block Completeness Gate.
If privacy.minimization_rule is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.TMA
Pass conditions:
required_fields_present == true
surfaces_and_signals_defined == true
escalation_and_recovery_defined == true
privacy_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

TMA-07

TMA-07 — Content/Message Abuse Controls (spam, harassment, scams)
Header Block
template_id: TMA-07
title: Content/Message Abuse Controls (spam, harassment, scams)
type: tma_content_message_abuse_controls
template_version: 1.0.0
output_path: 10_app/threat_model/TMA-07_Content_Message_Abuse_Controls.md
compliance_gate_id: TMP-05.PRIMARY.TMA
upstream_dependencies: ["TMA-02", "ADMIN-02", "RLIM-03", "RLIM-04"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "TMA-02", "TMA-03", "ADMIN-02", "ADMIN-01", "RLIM-03", "RLIM-04", "CER-05"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical abuse controls for user-generated content and messaging: spam/harassment/scam detection signals, enforcement actions, moderation workflows, and user safety features. This template must align with abuse case catalog, admin/moderation tooling, and enforcement matrices.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Abuse case catalog: {{xref:TMA-02}} | OPTIONAL
Attack surface inventory: {{xref:TMA-03}} | OPTIONAL
Support/moderation tools: {{xref:ADMIN-02}} | OPTIONAL
Admin capabilities: {{xref:ADMIN-01}} | OPTIONAL
Abuse signals: {{xref:RLIM-03}} | OPTIONAL
Enforcement matrix: {{xref:RLIM-04}} | OPTIONAL
Logging/redaction: {{xref:CER-05}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Abuse categories covered (spam/harassment/scams)
Detection signals list (heuristics, reports)
Rate limit ties (TMA-06 / RLIM refs)
User reporting flow (how users report)
Moderation workflow (queue, triage, actions)
Enforcement actions (mute/ban/throttle)
Appeals process (if enforcement occurs)
Evidence retention policy (message excerpts, hashes)
Privacy/redaction rules for content logs
Telemetry requirements (reports, actions taken, repeat offenders)

Optional Fields
Automated moderation support | OPTIONAL
Safety UX features (block user, keyword filters) | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-PII-REDACTION]}} | OPTIONAL
Do not store more user content than necessary for safety/audit.
Enforcement actions must be permissioned and auditable.
Appeals must exist for high-impact actions (ban) unless explicitly disallowed.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Categories
   categories: {{abuse.categories}}
2. Detection Signals
   signals: {{detect.signals}}
   user_reports_signal: {{detect.user_reports_signal}} | OPTIONAL
3. Reporting Flow
   report_entry_points: {{report.entry_points}}
   report_fields: {{report.fields}} | OPTIONAL
4. Moderation Workflow
   queue_model: {{mod.queue_model}}
   steps: {{mod.steps}}
   actions_supported: {{mod.actions_supported}} | OPTIONAL
5. Enforcement
   enforcement_ref: {{enforce.ref}} (expected: {{xref:RLIM-04}}) | OPTIONAL
   actions: {{enforce.actions}}
   ban_threshold_rule: {{enforce.ban_threshold_rule}} | OPTIONAL
6. Appeals
   appeals_supported: {{appeals.supported}}
   appeals_process: {{appeals.process}} | OPTIONAL
7. Evidence & Retention
   evidence_model: {{evidence.model}} (hash/excerpt/UNKNOWN)
   retention_days: {{evidence.retention_days}}
   redaction_rule: {{evidence.redaction_rule}} | OPTIONAL
8. Privacy / Logging
   no_full_content_logging_rule: {{privacy.no_full_content_logging_rule}}
   safe_fields: {{privacy.safe_fields}} | OPTIONAL
9. Telemetry
   reports_metric: {{telemetry.reports_metric}}
   actions_metric: {{telemetry.actions_metric}} | OPTIONAL
   repeat_offender_metric: {{telemetry.repeat_offender_metric}} | OPTIONAL

10. References
    Rate limit/bot defense: {{xref:TMA-06}} | OPTIONAL
    Admin tools: {{xref:ADMIN-02}} | OPTIONAL
    Audit trail: {{xref:ADMIN-03}} | OPTIONAL
    Security runbooks: {{xref:SEC-10}} | OPTIONAL

Cross-References
Upstream: {{xref:TMA-02}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:AUDIT-01}}, {{xref:COMP-06}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define categories, reporting flow, and moderation steps and retention days.
intermediate: Required. Define enforcement and appeals and privacy rules and telemetry.
advanced: Required. Add automated moderation and safety UX features with strict evidence minimization.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, reports signal, report fields, supported actions, thresholds, appeals process, redaction/safe fields, optional metrics, automation/safety UX, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If abuse.categories is UNKNOWN → block Completeness Gate.
If mod.steps is UNKNOWN → block Completeness Gate.
If evidence.retention_days is UNKNOWN → block Completeness Gate.
If privacy.no_full_content_logging_rule is UNKNOWN → block Completeness Gate.
If telemetry.reports_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.TMA
Pass conditions:
required_fields_present == true
categories_and_workflow_defined == true
evidence_and_privacy_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

TMA-08

TMA-08 — Fraud/Payment Abuse Controls (ties to PAY-08)
Header Block
template_id: TMA-08
title: Fraud/Payment Abuse Controls (ties to PAY-08)
type: tma_fraud_payment_abuse_controls
template_version: 1.0.0
output_path: 10_app/threat_model/TMA-08_Fraud_Payment_Abuse_Controls.md
compliance_gate_id: TMP-05.PRIMARY.TMA
upstream_dependencies: ["PAY-08", "TMA-02", "RLIM-03"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "PAY-08", "PAY-02", "TMA-02", "RLIM-03", "RLIM-04"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the threat-model perspective on payment/fraud abuse: catalog the key fraud vectors, required controls, monitoring signals, and escalation paths—anchored to the implementation-level PAY-08 document. This template must not diverge from the actual payments fraud controls.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Payments fraud controls: {{xref:PAY-08}} | OPTIONAL
Payment flows: {{xref:PAY-02}} | OPTIONAL
Abuse catalog: {{xref:TMA-02}} | OPTIONAL
Abuse signals: {{xref:RLIM-03}} | OPTIONAL
Enforcement actions: {{xref:RLIM-04}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Fraud vectors list (vector_id list)
vector_id (stable identifier)
Linked abuse_id/risk_id (if any)
Attack description
Impacted payment flows (PAY-02)
Controls required (PAY-08 refs)
Detection signals (metrics/logs)
Enforcement actions (block/review)
Escalation path (support/fraud team)
Telemetry requirements (fraud blocks, review outcomes)
Residual risk rating (high/med/low/UNKNOWN)

Optional Fields
Provider-specific fraud notes | OPTIONAL
Chargeback strategy pointer | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Every vector must map to at least one PAY-08 control and one detection signal.
Do not introduce new controls here; reference PAY-08 for implementation detail.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Vector Registry Summary
   total_vectors: {{meta.total}}
   notes: {{meta.notes}} | OPTIONAL
2. Vectors (repeat per vector_id)
   Vector
   vector_id: {{vectors[0].vector_id}}
   linked_abuse_id: {{vectors[0].linked_abuse_id}} | OPTIONAL
   attack: {{vectors[0].attack}}
   flows_impacted: {{vectors[0].flows_impacted}}
   controls_ref: {{vectors[0].controls_ref}} (expected: {{xref:PAY-08}})
   detection_signals: {{vectors[0].detection_signals}}
   enforcement_actions: {{vectors[0].enforcement_actions}}
   escalation_path: {{vectors[0].escalation_path}}
   telemetry_metric: {{vectors[0].telemetry_metric}}
   residual_risk: {{vectors[0].residual_risk}}
   provider_notes: {{vectors[0].provider_notes}} | OPTIONAL

(Repeat per vector.)

3. References
   Payments fraud controls: {{xref:PAY-08}} | OPTIONAL
   Refunds/disputes: {{xref:PAY-06}} | OPTIONAL
   Rate limit strategy: {{xref:TMA-06}} | OPTIONAL
   Risk register: {{xref:TMA-04}} | OPTIONAL

Cross-References
Upstream: {{xref:PAY-08}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:TMA-04}}, {{xref:SEC-06}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define vectors, impacted flows, and at least one detection/enforcement per

vector.
intermediate: Required. Add escalation and telemetry and residual risk.
advanced: Required. Add provider notes and tighter linkage to abuse/risk IDs and chargeback strategy pointers.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, notes, linked abuse/risk ids, provider notes, chargeback pointer, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If vectors[*].vector_id is UNKNOWN → block Completeness Gate.
If vectors[*].controls_ref is UNKNOWN → block Completeness Gate.
If vectors[*].detection_signals is UNKNOWN → block Completeness Gate.
If vectors[*].enforcement_actions is UNKNOWN → block Completeness Gate.
If vectors[*].telemetry_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.TMA
Pass conditions:
required_fields_present == true
vectors_defined == true
each_vector_has_controls_and_detection == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

TMA-09

TMA-09 — Security Validation (tests, drills, red team-lite)
Header Block
template_id: TMA-09
title: Security Validation (tests, drills, red team-lite)
type: tma_security_validation
template_version: 1.0.0
output_path: 10_app/threat_model/TMA-09_Security_Validation.md
compliance_gate_id: TMP-05.PRIMARY.TMA
upstream_dependencies: ["SEC-09", "TMA-04", "SEC-05"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SEC-09", "TMA-04", "SEC-05", "SEC-10"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the validation program that proves threats/risks are mitigated: security tests mapped to risks, tabletop drills, red-team-lite exercises, and closure evidence. This template connects the threat model to the security testing plan and incident response preparedness.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Security testing plan: {{xref:SEC-09}} | OPTIONAL
Risk register: {{xref:TMA-04}} | OPTIONAL
Incident response: {{xref:SEC-05}} | OPTIONAL
Security runbooks: {{xref:SEC-10}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Validation activities list (tests/drills)
Risk coverage mapping rule (risk_id → validation)
Tabletop drill cadence
Red team-lite cadence (or NONE/UNKNOWN)
Drill scope selection rules (which incidents tested)
Success criteria (pass/fail)
Evidence artifacts produced (reports, notes)
Remediation workflow for failed validations
Telemetry requirements (coverage %, failures)

Optional Fields
External pen test integration | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Every high-risk item should have a validation activity mapped to it.
Validations must produce evidence artifacts.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Activities
   activities: {{acts.list}}
2. Risk Coverage
   mapping_rule: {{coverage.mapping_rule}}
   coverage_target: {{coverage.target}} | OPTIONAL
3. Tabletop Drills
   cadence: {{tabletop.cadence}}
   scope_rule: {{tabletop.scope_rule}} | OPTIONAL
4. Red Team-lite
   cadence: {{redteam.cadence}}
   scope_rule: {{redteam.scope_rule}} | OPTIONAL
5. Success Criteria
   criteria: {{success.criteria}}
6. Evidence
   artifacts: {{evidence.artifacts}}
   storage_location: {{evidence.storage_location}} | OPTIONAL
7. Remediation
   on_fail_steps: {{remed.on_fail_steps}}
   tracking_rule: {{remed.tracking_rule}} | OPTIONAL
8. Telemetry
   validation_coverage_metric: {{telemetry.coverage_metric}}
   validation_fail_metric: {{telemetry.fail_metric}} | OPTIONAL
9. References
   Risk register: {{xref:TMA-04}} | OPTIONAL
   Security testing: {{xref:SEC-09}} | OPTIONAL
   Incident response: {{xref:SEC-05}} | OPTIONAL
   Runbooks: {{xref:SEC-10}} | OPTIONAL

Cross-References
Upstream: {{xref:TMA-04}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:TMA-10}}, {{xref:SEC-06}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define tabletop cadence, success criteria, and evidence artifacts.
intermediate: Required. Define mapping to risk ids and remediation workflow and telemetry.

advanced: Required. Add red team scope rigor and external pen test integration and coverage targets.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, coverage target, scope rules, storage location, tracking rule, optional metrics, external pen test, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If acts.list is UNKNOWN → block Completeness Gate.
If tabletop.cadence is UNKNOWN → block Completeness Gate.
If success.criteria is UNKNOWN → block Completeness Gate.
If evidence.artifacts is UNKNOWN → block Completeness Gate.
If telemetry.coverage_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.TMA
Pass conditions:
required_fields_present == true
activities_defined == true
risk_coverage_defined == true
evidence_defined == true
remediation_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

TMA-10

TMA-10 — TMA Runbooks (triage, containment actions)
Header Block
template_id: TMA-10
title: TMA Runbooks (triage, containment actions)
type: tma_runbooks
template_version: 1.0.0
output_path: 10_app/threat_model/TMA-10_TMA_Runbooks.md
compliance_gate_id: TMP-05.PRIMARY.TMA
upstream_dependencies: ["TMA-02", "TMA-04", "SEC-10"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "TMA-02", "TMA-04", "SEC-10", "RLIM-04", "ADMIN-02"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical runbooks for abuse/threat scenarios (non-incident and incident-adjacent): triage, containment actions, evidence capture, and escalation. This template should connect abuse cases and risks to concrete operator steps and must align with security runbooks and enforcement matrices.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Abuse catalog: {{xref:TMA-02}} | OPTIONAL
Risk register: {{xref:TMA-04}} | OPTIONAL
Security runbooks: {{xref:SEC-10}} | OPTIONAL
Enforcement matrix: {{xref:RLIM-04}} | OPTIONAL
Support tools: {{xref:ADMIN-02}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Runbook registry (runbook_id list)
runbook_id (stable identifier)
Linked abuse_id/risk_id
Trigger signals (what starts it)
Triage steps (ordered)
Containment/enforcement actions (ordered)
Evidence capture checklist
Escalation rules (when to involve security/legal)
Permissions required
Audit requirements
Telemetry requirements (invocations, time-to-mitigate)

Optional Fields
Customer comms pointers | OPTIONAL
Automation hooks | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Every runbook must map to at least one abuse_id or risk_id.
Containment actions must be permissioned and auditable.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Registry Summary
   total_runbooks: {{meta.total}}
   notes: {{meta.notes}} | OPTIONAL
2. Runbooks (repeat per runbook_id)
   Runbook
   runbook_id: {{books[0].runbook_id}}
   abuse_id: {{books[0].abuse_id}} | OPTIONAL
   risk_id: {{books[0].risk_id}} | OPTIONAL
   triggers: {{books[0].triggers}}
   triage_steps:
   {{books[0].triage_steps[0]}}
   {{books[0].triage_steps[1]}}
   actions:
   {{books[0].actions[0]}}
   {{books[0].actions[1]}} | OPTIONAL
   evidence_checklist: {{books[0].evidence_checklist}}
   escalation_rule: {{books[0].escalation_rule}}
   permissions_required: {{books[0].permissions_required}}
   audit_required: {{books[0].audit_required}}
   telemetry:
   invoked_metric: {{books[0].telemetry.invoked_metric}}
   ttm_metric: {{books[0].telemetry.ttm_metric}} | OPTIONAL

(Repeat per runbook.)

3. References
   Security runbooks: {{xref:SEC-10}} | OPTIONAL
   Enforcement actions: {{xref:RLIM-04}} | OPTIONAL
   Support tools: {{xref:ADMIN-02}} | OPTIONAL

Cross-References
Upstream: {{xref:TMA-02}}, {{xref:SPEC_INDEX}} | OPTIONAL

Downstream: {{xref:SEC-05}}, {{xref:AUDIT-09}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define registry, triggers, triage steps, and at least one action per runbook.
intermediate: Required. Define evidence, escalation, permissions/audit, and telemetry.
advanced: Required. Add automation hooks and customer comms pointers and stricter mappings.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, meta notes, optional risk/abuse id (one required), optional steps, optional metrics, comms/automation hooks, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If books[*].runbook_id is UNKNOWN → block Completeness Gate.
If books[*].triage_steps[0] is UNKNOWN → block Completeness Gate.
If books[*].actions[0] is UNKNOWN → block Completeness Gate.
If books[*].audit_required is UNKNOWN → block Completeness Gate.
If books[*].telemetry.invoked_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.TMA
Pass conditions:
required_fields_present == true
runbooks_defined == true
each_runbook_mapped_to_abuse_or_risk == true
permissions_and_audit_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

Secrets & Key Management (SKM)

SKM-01

SKM-01 — Secrets Inventory (by secret_id)
Header Block
template_id: SKM-01
title: Secrets Inventory (by secret_id)
type: secrets_inventory
template_version: 1.0.0
output_path: 10_app/secrets/SKM-01_Secrets_Inventory.md
compliance_gate_id: TMP-05.PRIMARY.SKM
upstream_dependencies: ["IXS-04", "FMS-01", "NOTIF-02", "PAY-01"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "IXS-04", "PAY-01", "NOTIF-02", "FMS-01", "SSO-01"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Create the single, canonical inventory of secrets and keys used by the system, indexed by secret_id, including what each secret is for, where it is stored, who can access it, rotation requirements, and which components depend on it. This template must not include secret values.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Secrets/credentials policy (integration): {{xref:IXS-04}} | OPTIONAL
Payment providers: {{xref:PAY-01}} | OPTIONAL
Notification providers: {{xref:NOTIF-02}} | OPTIONAL
Storage providers: {{xref:FMS-01}} | OPTIONAL
SSO providers: {{xref:SSO-01}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Secrets registry (secret_id list)
secret_id (stable identifier)
Secret type (api_key/oauth_client_secret/jwt_signing_key/tls_cert/UNKNOWN)
Purpose/usage
Owning system/component
Storage location class (vault/env/kms/UNKNOWN)
Access policy (who can read)
Rotation required (yes/no/UNKNOWN)
Rotation interval (days) (or NONE/UNKNOWN)
Dependencies (services/providers that use it)
Redaction/logging rule (never log)
Audit requirements (access to secret)

Optional Fields
Environment scoping (dev/stage/prod) | OPTIONAL
Expiry date (for certs) | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Never include secret values or raw material.
Every secret must have an owner and an access policy.
If a secret is rotation_required, interval must be defined (or approved UNKNOWN with flag).
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Registry Summary
   total_secrets: {{meta.total}}
   notes: {{meta.notes}} | OPTIONAL
2. Secrets (repeat per secret_id)
   Secret
   secret_id: {{secrets[0].secret_id}}
   type: {{secrets[0].type}}
   purpose: {{secrets[0].purpose}}
   owner_component: {{secrets[0].owner_component}}
   storage_class: {{secrets[0].storage_class}}
   access_policy: {{secrets[0].access_policy}}
   rotation_required: {{secrets[0].rotation_required}}
   rotation_interval_days: {{secrets[0].rotation_interval_days}}
   dependencies: {{secrets[0].dependencies}}
   env_scope: {{secrets[0].env_scope}} | OPTIONAL
   expiry_date: {{secrets[0].expiry_date}} | OPTIONAL
   logging_rule: {{secrets[0].logging_rule}}
   audit_required: {{secrets[0].audit_required}}
   open_questions:
   {{secrets[0].open_questions[0]}} | OPTIONAL

(Repeat per secret.)

3. References
   Storage/access policy: {{xref:SKM-02}} | OPTIONAL
   Rotation policy: {{xref:SKM-03}} | OPTIONAL
   Compromise response: {{xref:SKM-08}} | OPTIONAL

Cross-References
Upstream: {{xref:IXS-04}} | OPTIONAL, {{xref:SPEC_INDEX}} | OPTIONAL

Downstream: {{xref:SKM-02}}, {{xref:SKM-03}}, {{xref:SKM-09}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. List secrets and purposes and owners; no values.
intermediate: Required. Add storage class, access policy, rotation rules.
advanced: Required. Add dependencies mapping and audit/expiry rigor and env scoping.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, notes, env scope, expiry date, rotation interval if flagged, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If secrets[*].secret_id is UNKNOWN → block Completeness Gate.
If secrets[*].owner_component is UNKNOWN → block Completeness Gate.
If secrets[*].access_policy is UNKNOWN → block Completeness Gate.
If secrets[*].logging_rule is UNKNOWN → block Completeness Gate.
If secrets[*].rotation_required is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.SKM
Pass conditions:
required_fields_present == true
secret_ids_unique == true
owners_and_access_policies_defined == true
rotation_rules_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

SKM-02

SKM-02 — Storage & Access Policy (vaults, env scoping, least privilege)
Header Block
template_id: SKM-02
title: Storage & Access Policy (vaults, env scoping, least privilege)
type: secrets_storage_access_policy
template_version: 1.0.0
output_path: 10_app/secrets/SKM-02_Storage_Access_Policy.md
compliance_gate_id: TMP-05.PRIMARY.SKM
upstream_dependencies: ["SKM-01", "SEC-03", "IAM-05"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SKM-01", "SEC-03", "IAM-05", "IXS-04"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical policy for where secrets are stored and how access is controlled: vault/KMS usage, environment scoping, least privilege, auditability, and prohibited patterns. This template must align with secrets inventory and baseline security controls.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Secrets inventory: {{xref:SKM-01}} | OPTIONAL
Security baseline: {{xref:SEC-03}} | OPTIONAL
Service-to-service auth: {{xref:IAM-05}} | OPTIONAL
Integration secrets policy: {{xref:IXS-04}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Allowed storage backends (vault/kms/env/UNKNOWN)
Environment scoping rule (dev/stage/prod separation)
Access control model (role-based, service identity)
Least privilege rule (per secret)
Audit logging rule for secret reads/writes
Prohibited patterns (secrets in code/logs/images)
CI/CD secret handling rules (inject, mask)
Human access policy (who can view)
Break-glass policy for secrets access
Telemetry requirements (secret access spikes, failures)

Optional Fields
Secret naming conventions | OPTIONAL

Rotation integration notes | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
No secrets in source control or build artifacts.
Human access should be rare and audited.
Break-glass must be time-bound and logged.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Storage Backends
   allowed_backends: {{store.allowed_backends}}
   primary_backend: {{store.primary_backend}} | OPTIONAL
2. Environment Scoping
   env_separation_rule: {{env.separation_rule}}
   cross_env_access_allowed: {{env.cross_env_access_allowed}} | OPTIONAL
3. Access Control
   model: {{access.model}}
   service_identity_rule: {{access.service_identity_rule}} | OPTIONAL
   human_access_rule: {{access.human_access_rule}}
4. Least Privilege
   least_privilege_rule: {{lp.rule}}
   per_secret_policy_rule: {{lp.per_secret_policy_rule}} | OPTIONAL
5. Audit Logging
   audit_required: {{audit.required}}
   audit_events: {{audit.events}}
   audit_fields: {{audit.fields}} | OPTIONAL
6. CI/CD Handling
   injection_rule: {{ci.injection_rule}}
   masking_rule: {{ci.masking_rule}}
   rotation_in_ci_rule: {{ci.rotation_in_ci_rule}} | OPTIONAL
7. Prohibited Patterns
   prohibited: {{ban.list}}
8. Break-Glass
   supported: {{break.supported}}
   process: {{break.process}}
   max_duration_minutes: {{break.max_duration_minutes}} | OPTIONAL
9. Telemetry
   secret_access_spike_metric: {{telemetry.access_spike_metric}}
   secret_access_fail_metric: {{telemetry.access_fail_metric}} | OPTIONAL
10. References
    Secrets inventory: {{xref:SKM-01}} | OPTIONAL

Rotation policy: {{xref:SKM-03}} | OPTIONAL
Logging/redaction: {{xref:SKM-09}} | OPTIONAL

Cross-References
Upstream: {{xref:SKM-01}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:SKM-03}}, {{xref:SKM-08}}, {{xref:SKM-10}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define allowed backends, env separation, and prohibited patterns.
intermediate: Required. Define audit events, CI rules, and human access policy.
advanced: Required. Add per-secret least privilege rules and break-glass rigor and telemetry fields.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, primary backend, cross-env allowed, service identity rule, per-secret rule, audit fields, rotation in CI, max duration, optional telemetry, naming/rotation notes, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If store.allowed_backends is UNKNOWN → block Completeness Gate.
If env.separation_rule is UNKNOWN → block Completeness Gate.
If access.human_access_rule is UNKNOWN → block Completeness Gate.
If ci.masking_rule is UNKNOWN → block Completeness Gate.
If ban.list is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.SKM
Pass conditions:
required_fields_present == true
storage_and_env_scoping_defined == true
access_and_audit_defined == true
ci_and_prohibited_patterns_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

SKM-03

SKM-03 — Rotation Policy (schedules, triggers, overlap windows)
Header Block
template_id: SKM-03
title: Rotation Policy (schedules, triggers, overlap windows)
type: secrets_rotation_policy
template_version: 1.0.0
output_path: 10_app/secrets/SKM-03_Rotation_Policy.md
compliance_gate_id: TMP-05.PRIMARY.SKM
upstream_dependencies: ["SKM-01", "SKM-02", "SEC-04"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SKM-01", "SKM-02", "SEC-04", "AUDIT-07"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical rotation policy for secrets, keys, and certificates: rotation schedules by type, trigger-based rotations (compromise), overlap windows, and how rotations are executed and verified. This template must align with secrets inventory, storage policy, and vulnerability/incident processes.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Secrets inventory: {{xref:SKM-01}} | OPTIONAL
Storage/access policy: {{xref:SKM-02}} | OPTIONAL
Vulnerability management: {{xref:SEC-04}} | OPTIONAL
Privileged audit: {{xref:AUDIT-07}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Rotation schedule by secret type (api keys, oauth, jwt keys, tls certs)
Rotation triggers list (time-based, compromise, employee exit)
Overlap window rule (dual validity)
Rotation execution workflow (steps)
Verification rule (prove new secret in use)
Rollback rule (if rotation breaks prod)
Emergency rotation rule (incident)
Ownership rules (who rotates)
Audit requirements (rotation events logged)
Telemetry requirements (rotation success/fail, expired secrets)

Optional Fields
Automated rotation support | OPTIONAL

Key ceremony notes (for signing keys) | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Rotation must not require exposing secret material in plaintext to humans.
Overlap windows must be bounded.
Emergency rotation must be runnable under incident response constraints.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Schedules
   api_key_interval_days: {{sched.api_key_days}}
   oauth_secret_interval_days: {{sched.oauth_days}} | OPTIONAL
   jwt_signing_key_interval_days: {{sched.jwt_days}} | OPTIONAL
   tls_cert_renewal_days: {{sched.tls_days}} | OPTIONAL
2. Triggers
   triggers: {{triggers.list}}
3. Overlap
   overlap_window_seconds: {{overlap.window_seconds}}
   dual_valid_rule: {{overlap.dual_valid_rule}} | OPTIONAL
4. Workflow
   steps:
   {{workflow.steps[0]}}
   {{workflow.steps[1]}}
   {{workflow.steps[2]}} | OPTIONAL
5. Verification
   verification_rule: {{verify.rule}}
   evidence_rule: {{verify.evidence_rule}} | OPTIONAL
6. Rollback
   rollback_rule: {{rollback.rule}}
7. Emergency Rotation
   emergency_rule: {{emergency.rule}}
   ir_ref: {{xref:SEC-05}} | OPTIONAL
8. Ownership
   rotation_owner: {{owner.rotation_owner}}
   approvals_required: {{owner.approvals_required}} | OPTIONAL
9. Audit
   audit_required: {{audit.required}}
   audit_events: {{audit.events}}
10. Telemetry
    rotation_success_metric: {{telemetry.success_metric}}
    rotation_failure_metric: {{telemetry.failure_metric}} | OPTIONAL
    expired_secret_metric: {{telemetry.expired_metric}} | OPTIONAL

11. References
    Storage/access policy: {{xref:SKM-02}} | OPTIONAL
    Compromise response: {{xref:SKM-08}} | OPTIONAL
    Security monitoring: {{xref:SEC-06}} | OPTIONAL

Cross-References
Upstream: {{xref:SKM-01}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:SKM-08}}, {{xref:SKM-10}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define schedule, triggers, workflow, and rollback rule.
intermediate: Required. Define overlap window and verification evidence and audit events.
advanced: Required. Add automated rotation and key ceremony notes and incident-friendly emergency steps.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, optional schedules, dual valid rule, evidence rule, approvals, optional metrics, automation/ceremony, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If sched.api_key_days is UNKNOWN → block Completeness Gate.
If triggers.list is UNKNOWN → block Completeness Gate.
If overlap.window_seconds is UNKNOWN → block Completeness Gate.
If verify.rule is UNKNOWN → block Completeness Gate.
If telemetry.success_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.SKM
Pass conditions:
required_fields_present == true
schedules_and_triggers_defined == true
workflow_and_verification_defined == true
rollback_and_emergency_defined == true
audit_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

SKM-04

SKM-04 — Key Types & Usage (signing, encryption, API keys, TLS)
Header Block
template_id: SKM-04
title: Key Types & Usage (signing, encryption, API keys, TLS)
type: key_types_usage
template_version: 1.0.0
output_path: 10_app/secrets/SKM-04_Key_Types_Usage.md
compliance_gate_id: TMP-05.PRIMARY.SKM
upstream_dependencies: ["SKM-01", "SEC-02", "SKM-05"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SKM-01", "SEC-02", "SKM-05", "FMS-06", "PAY-09"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical taxonomy of keys and how they are used across the system: signing keys, encryption keys, API keys, TLS certs, and token secrets. This template establishes consistent rules for key purpose separation, algorithm choices, and where keys are stored/used.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Secrets inventory: {{xref:SKM-01}} | OPTIONAL
Security architecture: {{xref:SEC-02}} | OPTIONAL
KMS/HSM strategy: {{xref:SKM-05}} | OPTIONAL
File security: {{xref:FMS-06}} | OPTIONAL
Payments security/PCI: {{xref:PAY-09}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Key type registry (key_type list)
Purpose separation rules (signing vs encryption)
Allowed algorithms list (or UNKNOWN)
Key storage backend rule (KMS/HSM/vault)
Key usage contexts (JWT signing, envelope encryption, TLS)
Key access model (service identities)
Key rotation linkage (SKM-03)
Key lifecycle states (active/retiring/retired)
Telemetry requirements (key usage errors, nearing expiry)

Optional Fields
Key derivation rules | OPTIONAL

Key identifiers naming conventions | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Do not reuse the same key for multiple purposes.
Key types must have explicit allowed usage contexts.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Key Types
   key_types: {{types.list}}
2. Purpose Separation
   rules: {{purpose.rules}}
3. Algorithms
   allowed_algorithms: {{algorithms.allowed}}
4. Storage
   storage_rule: {{storage.rule}}
   kms_ref: {{xref:SKM-05}} | OPTIONAL
5. Usage Contexts
   contexts: {{usage.contexts}}
6. Access Model
   service_identity_rule: {{access.service_identity_rule}}
   human_access_rule: {{access.human_access_rule}} | OPTIONAL
7. Rotation
   rotation_ref: {{xref:SKM-03}} | OPTIONAL
   rotation_rules: {{rotation.rules}} | OPTIONAL
8. Lifecycle States
   states: {{lifecycle.states}}
   state_transition_rule: {{lifecycle.transition_rule}} | OPTIONAL
9. Telemetry
   key_usage_error_metric: {{telemetry.key_usage_error_metric}}
   key_expiry_warning_metric: {{telemetry.key_expiry_warning_metric}} | OPTIONAL
10. References
    Secrets inventory: {{xref:SKM-01}} | OPTIONAL
    Storage/access policy: {{xref:SKM-02}} | OPTIONAL
    Rotation policy: {{xref:SKM-03}} | OPTIONAL

Cross-References
Upstream: {{xref:SKM-01}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:SKM-06}}, {{xref:SKM-10}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define key types, purpose separation, and storage rule.
intermediate: Required. Define allowed algorithms and usage contexts and lifecycle states.
advanced: Required. Add derivation/naming conventions and tight rotation/lifecycle transition rigor.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, kms ref, rotation rules, transition rule, optional telemetry, derivation/naming, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If types.list is UNKNOWN → block Completeness Gate.
If purpose.rules is UNKNOWN → block Completeness Gate.
If algorithms.allowed is UNKNOWN → block Completeness Gate.
If storage.rule is UNKNOWN → block Completeness Gate.
If telemetry.key_usage_error_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.SKM
Pass conditions:
required_fields_present == true
key_types_and_usage_defined == true
purpose_separation_defined == true
storage_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

SKM-05

SKM-05 — KMS/HSM Strategy (providers, boundaries, responsibilities)
Header Block
template_id: SKM-05
title: KMS/HSM Strategy (providers, boundaries, responsibilities)
type: kms_hsm_strategy
template_version: 1.0.0
output_path: 10_app/secrets/SKM-05_KMS_HSM_Strategy.md
compliance_gate_id: TMP-05.PRIMARY.SKM
upstream_dependencies: ["SKM-02", "SKM-04", "SEC-02"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SKM-02", "SKM-04", "SEC-02", "IXS-01"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical strategy for cryptographic key management using KMS and/or HSM: which provider(s) are used, what keys live where, boundary responsibilities, and how access/rotation/audit work at this layer. This template must align with storage/access policy and security architecture trust boundaries.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Storage/access policy: {{xref:SKM-02}} | OPTIONAL
Key types/usage: {{xref:SKM-04}} | OPTIONAL
Security architecture: {{xref:SEC-02}} | OPTIONAL
Integration inventory (providers): {{xref:IXS-01}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
KMS/HSM provider(s) list (provider_id)
Key classes that MUST use KMS/HSM (e.g., encryption master keys)
Boundary statement (what KMS/HSM protects)
Responsibilities split (app vs provider)
Access control model (service identities, IAM policies)
Audit logging for KMS usage (who used what)
Rotation integration rule (SKM-03)
Backup/DR rule (key availability)
Telemetry requirements (KMS errors, throttling, latency)

Optional Fields
HSM requirement (true/false/UNKNOWN) | OPTIONAL

Bring-your-own-key policy | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Master keys should not be exportable unless explicitly allowed.
KMS policies must follow least privilege and be environment-scoped.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Providers
   providers: {{kms.providers}}
2. Key Classes in KMS/HSM
   required_key_classes: {{kms.required_key_classes}}
3. Boundary
   boundary_statement: {{kms.boundary_statement}}
4. Responsibilities
   app_responsibilities: {{resp.app}}
   provider_responsibilities: {{resp.provider}} | OPTIONAL
5. Access Control
   policy_model: {{access.policy_model}}
   service_identity_rule: {{access.service_identity_rule}} | OPTIONAL
6. Audit
   audit_required: {{audit.required}}
   audit_events: {{audit.events}} | OPTIONAL
7. Rotation
   rotation_ref: {{xref:SKM-03}} | OPTIONAL
   rotation_integration_rule: {{rotate.integration_rule}} | OPTIONAL
8. Backup / DR
   availability_rule: {{dr.availability_rule}}
   restore_rule: {{dr.restore_rule}} | OPTIONAL
9. Telemetry
   kms_error_metric: {{telemetry.kms_error_metric}}
   kms_latency_metric: {{telemetry.kms_latency_metric}} | OPTIONAL
10. References
    Storage/access policy: {{xref:SKM-02}} | OPTIONAL
    Key types/usage: {{xref:SKM-04}} | OPTIONAL
    Certificates: {{xref:SKM-06}} | OPTIONAL

Cross-References
Upstream: {{xref:SKM-02}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:SKM-06}}, {{xref:SKM-10}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define providers, boundary statement, and required key classes.
intermediate: Required. Define access policy model, DR availability, and telemetry.
advanced: Required. Add HSM/BYOK notes and stricter audit/rotation integration rigor.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, provider responsibilities, service identity rule, audit events, rotation integration, restore rule, optional telemetry, hsm/byok, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If kms.providers is UNKNOWN → block Completeness Gate.
If kms.required_key_classes is UNKNOWN → block Completeness Gate.
If kms.boundary_statement is UNKNOWN → block Completeness Gate.
If dr.availability_rule is UNKNOWN → block Completeness Gate.
If telemetry.kms_error_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.SKM
Pass conditions:
required_fields_present == true
providers_and_boundaries_defined == true
key_classes_defined == true
access_and_dr_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

SKM-06

SKM-06 — Certificate Management (issuance, renewal, revocation)
Header Block
template_id: SKM-06
title: Certificate Management (issuance, renewal, revocation)
type: certificate_management
template_version: 1.0.0
output_path: 10_app/secrets/SKM-06_Certificate_Management.md
compliance_gate_id: TMP-05.PRIMARY.SKM
upstream_dependencies: ["SKM-03", "IAM-05", "SEC-04"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SKM-03", "IAM-05", "SEC-04", "IXS-01"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical lifecycle for certificates (TLS/mTLS): issuance, renewal, rotation, revocation, and monitoring. This template must align with service-to-service auth and rotation policies and ensure cert expiry does not cause outages.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Rotation policy: {{xref:SKM-03}} | OPTIONAL
Service-to-service auth: {{xref:IAM-05}} | OPTIONAL
Vulnerability management: {{xref:SEC-04}} | OPTIONAL
Integration inventory (providers): {{xref:IXS-01}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Certificate types list (public TLS, internal mTLS)
Issuance model (ACME/CA/internal/UNKNOWN)
Certificate authority/provider binding
Renewal cadence (days before expiry)
Rotation/overlap rules (dual cert support)
Revocation rules (when/how)
Distribution mechanism (how services get certs)
Monitoring/alerts (expiring soon, failures)
Audit requirements (issuance/revocation events)
Telemetry requirements (renewal success/fail, expiry warnings)

Optional Fields
SAN naming conventions | OPTIONAL

Certificate pinning notes | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Certificates must be rotated before expiry with clear monitoring.
Revocation must be runnable during incidents.
Private keys must never be logged or stored insecurely.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Types
   types: {{cert.types}}
2. Issuance
   model: {{cert.issuance_model}} (acme/ca/internal/UNKNOWN)
   provider: {{cert.provider}}
   ca_ref: {{cert.ca_ref}} | OPTIONAL
3. Renewal
   renew_before_days: {{renew.before_days}}
   renewal_trigger_rule: {{renew.trigger_rule}} | OPTIONAL
4. Rotation / Overlap
   overlap_window_days: {{rotate.overlap_days}}
   dual_cert_rule: {{rotate.dual_cert_rule}} | OPTIONAL
5. Revocation
   revocation_supported: {{revoke.supported}}
   revocation_rule: {{revoke.rule}}
6. Distribution
   distribution_model: {{dist.model}}
   service_fetch_rule: {{dist.service_fetch_rule}} | OPTIONAL
7. Monitoring
   expiry_warning_alert: {{monitor.expiry_warning_alert}}
   renewal_failure_alert: {{monitor.renewal_failure_alert}} | OPTIONAL
8. Audit
   audit_required: {{audit.required}}
   audit_events: {{audit.events}} | OPTIONAL
9. Telemetry
   renewal_success_metric: {{telemetry.renewal_success_metric}}
   expiry_warning_metric: {{telemetry.expiry_warning_metric}} | OPTIONAL
10. References
    Rotation policy: {{xref:SKM-03}} | OPTIONAL
    Service auth: {{xref:IAM-05}} | OPTIONAL
    Security monitoring: {{xref:SEC-06}} | OPTIONAL

Cross-References
Upstream: {{xref:SKM-03}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:SKM-08}}, {{xref:SKM-10}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define issuance model, renewal days, and revocation rule.
intermediate: Required. Define overlap/dual cert and monitoring alerts and telemetry.
advanced: Required. Add naming/pinning notes and strict distribution and audit event details.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, ca ref, trigger rule, dual cert rule, alerts, audit events, optional telemetry, naming/pinning, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If cert.types is UNKNOWN → block Completeness Gate.
If cert.issuance_model is UNKNOWN → block Completeness Gate.
If renew.before_days is UNKNOWN → block Completeness Gate.
If revoke.rule is UNKNOWN → block Completeness Gate.
If telemetry.renewal_success_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.SKM
Pass conditions:
required_fields_present == true
issuance_and_renewal_defined == true
revocation_defined == true
monitoring_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

SKM-07

SKM-07 — Secret Distribution (runtime fetch, sidecars, CI rules)
Header Block
template_id: SKM-07
title: Secret Distribution (runtime fetch, sidecars, CI rules)
type: secret_distribution
template_version: 1.0.0
output_path: 10_app/secrets/SKM-07_Secret_Distribution.md
compliance_gate_id: TMP-05.PRIMARY.SKM
upstream_dependencies: ["SKM-02", "IAM-05", "SEC-07"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SKM-02", "IAM-05", "SEC-07", "JBS-03"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical mechanisms for distributing secrets to runtime workloads and CI/CD: how services fetch secrets, how identities are used, how secrets are refreshed, and what is prohibited. This template must align with storage/access policy and Secure SDLC rules.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Storage/access policy: {{xref:SKM-02}} | OPTIONAL
Service-to-service identity: {{xref:IAM-05}} | OPTIONAL
Secure SDLC: {{xref:SEC-07}} | OPTIONAL
Scheduling rules (jobs/workers): {{xref:JBS-03}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Runtime distribution model (fetch at startup, sidecar, env inject, UNKNOWN)
CI distribution model (ephemeral tokens, secrets vault integration)
Identity binding rule (service identity → secret access)
Refresh/renewal rule (how secrets updated without redeploy)
Caching rules (in-memory only, TTL)
Least privilege distribution rule (only what needed)
Prohibited patterns (write secrets to disk/logs)
Failure behavior (fail closed vs degrade)
Telemetry requirements (fetch failures, denied access)
Audit requirements (secret reads)

Optional Fields
Local dev workflow | OPTIONAL

Multi-region considerations | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Secrets should be fetched dynamically where possible; avoid long-lived env vars in prod.
Do not store secrets on disk unless explicitly approved and encrypted.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Runtime
   model: {{runtime.model}}
   fetch_rule: {{runtime.fetch_rule}} | OPTIONAL
2. CI/CD
   model: {{ci.model}}
   ephemeral_token_rule: {{ci.ephemeral_token_rule}} | OPTIONAL
3. Identity Binding
   binding_rule: {{id.binding_rule}}
4. Refresh
   refresh_supported: {{refresh.supported}}
   refresh_rule: {{refresh.rule}} | OPTIONAL
5. Caching
   cache_rule: {{cache.rule}}
   cache_ttl_seconds: {{cache.ttl_seconds}} | OPTIONAL
6. Least Privilege
   distribution_rule: {{lp.distribution_rule}}
7. Failure Behavior
   on_fetch_fail: {{fail.on_fetch_fail}}
   on_access_denied: {{fail.on_access_denied}} | OPTIONAL
8. Prohibited Patterns
   prohibited: {{ban.list}}
9. Telemetry
   fetch_failure_metric: {{telemetry.fetch_failure_metric}}
   access_denied_metric: {{telemetry.access_denied_metric}} | OPTIONAL
10. Audit
    audit_required: {{audit.required}}
    audit_ref: {{xref:SKM-09}} | OPTIONAL
11. References
    Storage/access policy: {{xref:SKM-02}} | OPTIONAL
    Rotation policy: {{xref:SKM-03}} | OPTIONAL
    Secure SDLC: {{xref:SEC-07}} | OPTIONAL

Cross-References
Upstream: {{xref:SKM-02}}, {{xref:SPEC_INDEX}} | OPTIONAL

Downstream: {{xref:SKM-08}}, {{xref:SKM-10}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define runtime/CI models and prohibited patterns and fail behavior.
intermediate: Required. Define refresh/caching rules and telemetry and audit requirement.
advanced: Required. Add local dev workflow and multi-region notes and strict binding rules.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, fetch rule, ephemeral token rule, refresh rule, cache ttl, access denied behavior, audit ref, local dev/multi-region, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If runtime.model is UNKNOWN → block Completeness Gate.
If ci.model is UNKNOWN → block Completeness Gate.
If id.binding_rule is UNKNOWN → block Completeness Gate.
If ban.list is UNKNOWN → block Completeness Gate.
If telemetry.fetch_failure_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.SKM
Pass conditions:
required_fields_present == true
distribution_models_defined == true
binding_and_fail_behavior_defined == true
prohibited_patterns_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

SKM-08

SKM-08 — Compromise Response (detect, rotate, revoke, audit)
Header Block
template_id: SKM-08
title: Compromise Response (detect, rotate, revoke, audit)
type: secrets_compromise_response
template_version: 1.0.0
output_path: 10_app/secrets/SKM-08_Compromise_Response.md
compliance_gate_id: TMP-05.PRIMARY.SKM
upstream_dependencies: ["SEC-05", "SKM-03", "SKM-02"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SEC-05", "SKM-01", "SKM-02", "SKM-03", "AUDIT-10", "SEC-06"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical response procedure when a secret/key is suspected or confirmed compromised: detection, containment, rotation, revocation, audit, and recovery verification. This template must align with incident response and rotation policies.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Incident response plan: {{xref:SEC-05}} | OPTIONAL
Secrets inventory: {{xref:SKM-01}} | OPTIONAL
Storage/access policy: {{xref:SKM-02}} | OPTIONAL
Rotation policy: {{xref:SKM-03}} | OPTIONAL
Forensics runbooks: {{xref:AUDIT-10}} | OPTIONAL
Security monitoring: {{xref:SEC-06}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Compromise triggers (what indicates compromise)
Immediate containment actions (disable key, block traffic)
Secret classification (high-risk vs low-risk)
Rotation procedure (how to rotate safely)
Revocation procedure (invalidate old)
Dependency update rule (services that must reload)
Verification rule (prove old key no longer works)
Audit logging requirements (who rotated/revoked)
Communication/escalation rules (who notified)
Telemetry requirements (compromise events, time-to-rotate)

Optional Fields
Customer notification rules | OPTIONAL
Post-incident follow-ups | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Containment must be fast and permissioned.
Rotation must not expose secret material to humans.
Verification must be explicit (attempt auth with old key should fail).
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Triggers
   triggers: {{triggers.list}}
2. Containment
   actions: {{contain.actions}}
   permission_rule: {{contain.permission_rule}} | OPTIONAL
3. Classification
   risk_tiers: {{class.risk_tiers}}
   tiering_rule: {{class.tiering_rule}} | OPTIONAL
4. Rotation
   rotation_steps: {{rotate.steps}}
   overlap_rule: {{rotate.overlap_rule}} | OPTIONAL
5. Revocation
   revoke_steps: {{revoke.steps}}
   propagation_rule: {{revoke.propagation_rule}} | OPTIONAL
6. Dependency Updates
   reload_rule: {{deps.reload_rule}}
   services_impacted: {{deps.services_impacted}} | OPTIONAL
7. Verification
   verification_steps: {{verify.steps}}
   success_criteria: {{verify.success_criteria}} | OPTIONAL
8. Audit
   audit_required: {{audit.required}}
   audit_events: {{audit.events}} | OPTIONAL
9. Communications / Escalation
   notify_rule: {{comms.notify_rule}}
   escalate_rule: {{comms.escalate_rule}} | OPTIONAL
10. Telemetry
    compromise_event_metric: {{telemetry.compromise_event_metric}}
    time_to_rotate_metric: {{telemetry.time_to_rotate_metric}} | OPTIONAL
11. References
    Incident response: {{xref:SEC-05}} | OPTIONAL

Rotation policy: {{xref:SKM-03}} | OPTIONAL
Access policy: {{xref:SKM-02}} | OPTIONAL
Security runbooks: {{xref:SEC-10}} | OPTIONAL

Cross-References
Upstream: {{xref:SEC-05}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:SEC-10}}, {{xref:SEC-06}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define triggers, containment actions, and rotate/revoke steps.
intermediate: Required. Define dependency reload rule, verification steps, and audit/telemetry.
advanced: Required. Add tiering rules, customer comms, and post-incident follow-ups rigor.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, permission rule, tiering rule, overlap/propagation rules, impacted services, success criteria, audit events, escalate/customer comms, time-to-rotate metric, follow-ups, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If triggers.list is UNKNOWN → block Completeness Gate.
If contain.actions is UNKNOWN → block Completeness Gate.
If rotate.steps is UNKNOWN → block Completeness Gate.
If revoke.steps is UNKNOWN → block Completeness Gate.
If telemetry.compromise_event_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.SKM
Pass conditions:
required_fields_present == true
triggers_and_containment_defined == true
rotate_and_revoke_defined == true
verification_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

SKM-09

SKM-09 — Logging & Redaction Rules (no secrets in logs)
Header Block
template_id: SKM-09
title: Logging & Redaction Rules (no secrets in logs)
type: secrets_logging_redaction_rules
template_version: 1.0.0
output_path: 10_app/secrets/SKM-09_Logging_Redaction_Rules.md
compliance_gate_id: TMP-05.PRIMARY.SKM
upstream_dependencies: ["SEC-07", "CER-05", "SKM-02"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SEC-07", "CER-05", "SKM-02", "AUDIT-02"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical logging and redaction rules to prevent secrets/key material from being emitted into logs, traces, crash reports, or analytics. This template must align with SDLC secret scanning, application logging policy, and audit schema constraints.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Secure SDLC policy: {{xref:SEC-07}} | OPTIONAL
Client/server logging policy: {{xref:CER-05}} | OPTIONAL
Secrets storage/access policy: {{xref:SKM-02}} | OPTIONAL
Audit schema: {{xref:AUDIT-02}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
No-secrets-in-logs rule (explicit)
Sensitive fields allowlist (what can be logged)
Sensitive fields denylist (tokens, keys, auth headers)
Redaction strategy (mask/hash/drop)
Logging wrappers/middleware rule (centralized logging)
Trace/span redaction rule
Crash report redaction rule
Verification rule (tests/scanners confirm no leakage)
Incident procedure if leakage detected (SKM-08 ref)
Telemetry requirements (redaction hits, leakage detections)

Optional Fields
PII redaction coupling (PRIV-02) | OPTIONAL

Sampling rules | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Auth headers, cookies, tokens must never be logged.
Redaction must occur before logs leave the process (not only in SIEM).
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Core Rule
   no_secrets_rule: {{core.no_secrets_rule}}
2. Allowlist / Denylist
   allowlist_fields: {{fields.allowlist}}
   denylist_fields: {{fields.denylist}}
3. Redaction Strategy
   strategy: {{redact.strategy}} (mask/hash/drop/UNKNOWN)
   examples: {{redact.examples}} | OPTIONAL
4. Implementation
   logging_wrapper_rule: {{impl.wrapper_rule}}
   trace_redaction_rule: {{impl.trace_rule}} | OPTIONAL
   crash_redaction_rule: {{impl.crash_rule}} | OPTIONAL
5. Verification
   verification_rule: {{verify.rule}}
   tooling_ref: {{verify.tooling_ref}} | OPTIONAL
6. Leakage Procedure
   leakage_detected_rule: {{leak.rule}}
   compromise_ref: {{xref:SKM-08}} | OPTIONAL
7. Telemetry
   redaction_hit_metric: {{telemetry.redaction_hit_metric}}
   leakage_detection_metric: {{telemetry.leakage_detection_metric}} | OPTIONAL
8. References
   Secure SDLC: {{xref:SEC-07}} | OPTIONAL
   Compromise response: {{xref:SKM-08}} | OPTIONAL
   Privacy classification: {{xref:PRIV-02}} | OPTIONAL

Cross-References
Upstream: {{xref:SKM-02}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:SEC-06}}, {{xref:COMP-09}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define denylist and core rule and verification rule.

intermediate: Required. Define redaction strategy and crash/trace rules and telemetry.
advanced: Required. Add PII coupling and sampling and strict tooling references.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, examples, trace/crash rules, tooling ref, optional metrics, pii coupling, sampling, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If core.no_secrets_rule is UNKNOWN → block Completeness Gate.
If fields.denylist is UNKNOWN → block Completeness Gate.
If redact.strategy is UNKNOWN → block Completeness Gate.
If verify.rule is UNKNOWN → block Completeness Gate.
If telemetry.redaction_hit_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.SKM
Pass conditions:
required_fields_present == true
denylist_defined == true
redaction_defined == true
verification_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

SKM-10

SKM-10 — Observability & Alerts (access spikes, failures, drift)
Header Block
template_id: SKM-10
title: Observability & Alerts (access spikes, failures, drift)
type: secrets_observability_alerts
template_version: 1.0.0
output_path: 10_app/secrets/SKM-10_Observability_Alerts.md
compliance_gate_id: TMP-05.PRIMARY.SKM
upstream_dependencies: ["SKM-02", "SKM-03", "SEC-06"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SKM-01", "SKM-02", "SKM-03", "SEC-06", "AUDIT-09"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical observability and alerting for secrets/key management: access spikes, denied access, rotation failures, expiring certs, and configuration drift. This template must align with security monitoring and audit anomaly detection.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Secrets inventory: {{xref:SKM-01}} | OPTIONAL
Storage/access policy: {{xref:SKM-02}} | OPTIONAL
Rotation policy: {{xref:SKM-03}} | OPTIONAL
Security monitoring baseline: {{xref:SEC-06}} | OPTIONAL
Audit anomaly detection: {{xref:AUDIT-09}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Dashboards minimum panels (secrets health)
Key metrics list (reads, writes, denies, rotation success)
Alert registry (alert_id list)
Alert definitions (access spike, deny spike, rotation fail, cert expiring)
Alert routing policy (security/oncall)
Noise control rules (dedupe, suppression)
Runbook references (SKM-08, SEC-10)
Retention rules for secrets telemetry (no secret material)
Telemetry redaction rule (metadata only)

Optional Fields
Drift detection rules (policy mismatches) | OPTIONAL

Automated remediation hooks | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Do not include secret material in telemetry; metadata only.
Alerts must be actionable and link to runbooks.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Dashboards
   dashboard_name: {{dash.name}}
   minimum_panels: {{dash.minimum_panels}}
   panel_list: {{dash.panel_list}} | OPTIONAL
2. Key Metrics
   metrics: {{metrics.list}}
3. Alerts
   alerts: {{alerts.list}}
4. Alert Definitions (repeat)
   Alert
   alert_id: {{items[0].alert_id}}
   condition: {{items[0].condition}}
   severity: {{items[0].severity}} (low/med/high/UNKNOWN)
   routing: {{items[0].routing}}
   runbook_ref: {{items[0].runbook_ref}} | OPTIONAL
   suppression_rule: {{items[0].suppression_rule}} | OPTIONAL

(Repeat per alert.)

5. Noise Controls
   dedupe_rule: {{noise.dedupe_rule}}
   suppression_windows: {{noise.suppression_windows}} | OPTIONAL
6. Retention / Redaction
   retention_days: {{retention.days}}
   redaction_rule: {{redact.rule}}
7. Runbooks
   compromise_ref: {{xref:SKM-08}} | OPTIONAL
   security_runbooks_ref: {{xref:SEC-10}} | OPTIONAL
8. Drift Detection (Optional)
   drift_rules: {{drift.rules}} | OPTIONAL
9. References
   Storage/access policy: {{xref:SKM-02}} | OPTIONAL
   Rotation policy: {{xref:SKM-03}} | OPTIONAL
   Certificate mgmt: {{xref:SKM-06}} | OPTIONAL

Cross-References
Upstream: {{xref:SKM-02}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:SEC-05}}, {{xref:COMP-09}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define dashboard min panels, metrics list, and alert list.
intermediate: Required. Define alert conditions/routing and noise controls and retention.
advanced: Required. Add drift rules and automated remediation hooks and strict runbook mapping.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, panel list, runbook refs, suppression rules/windows, drift rules, auto remediation, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If dash.minimum_panels is UNKNOWN → block Completeness Gate.
If metrics.list is UNKNOWN → block Completeness Gate.
If alerts.list is UNKNOWN → block Completeness Gate.
If retention.days is UNKNOWN → block Completeness Gate.
If redact.rule is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.SKM
Pass conditions:
required_fields_present == true
dashboards_and_alerts_defined == true
noise_controls_defined == true
retention_and_redaction_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

Privacy Modeling & Data Minimization (PRIV)

PRIV-01

PRIV-01 — Data Inventory (by data_class/entity)
Header Block
template_id: PRIV-01
title: Data Inventory (by data_class/entity)
type: privacy_data_inventory
template_version: 1.0.0
output_path: 10_app/privacy/PRIV-01_Data_Inventory.md
compliance_gate_id: TMP-05.PRIMARY.PRIV
upstream_dependencies: ["DATA-06", "DOMAIN_MAP", "SPEC_INDEX"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "DATA-06", "EVT-02", "FMS-08"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Create the canonical inventory of data the system collects/stores/processes, indexed by data_class and entity, including where it lives, who uses it, and sensitivity notes. This inventory anchors PII classification, minimization, and retention policies.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Canonical schemas: {{xref:DATA-06}} | OPTIONAL
Event schemas: {{xref:EVT-02}} | OPTIONAL
File metadata/indexing: {{xref:FMS-08}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Data class registry (data_class list)
Entity registry (entity_name list)
data_class (stable classification label)
entity_name (table/model)
Fields of interest (PII candidates)
Storage location (db/bucket/log/UNKNOWN)
Producers (who writes)
Consumers (who reads)
Primary purpose (why collected)
Retention reference (PRIV-05)
Sharing reference (PRIV-06)
Telemetry requirements (inventory coverage %)

Optional Fields
Notes on lawful basis | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-PII-REDACTION]}} | OPTIONAL
Do not invent entities; use DATA-06 and event schemas as primary sources.
Every inventory entry must include purpose; if unknown, mark UNKNOWN and flag.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Data Classes
   data_classes: {{classes.list}}
2. Entities
   entities: {{entities.list}}
3. Inventory Entries (repeat)
   Entry
   data_class: {{items[0].data_class}}
   entity_name: {{items[0].entity_name}}
   fields_of_interest: {{items[0].fields_of_interest}}
   storage_location: {{items[0].storage_location}}
   producers: {{items[0].producers}}
   consumers: {{items[0].consumers}}
   purpose: {{items[0].purpose}}
   retention_ref: {{items[0].retention_ref}} (expected: {{xref:PRIV-05}}) | OPTIONAL
   sharing_ref: {{items[0].sharing_ref}} (expected: {{xref:PRIV-06}}) | OPTIONAL
   notes: {{items[0].notes}} | OPTIONAL

(Repeat per entry.)

4. Telemetry
   inventory_coverage_metric: {{telemetry.coverage_metric}}
5. References
   PII classification: {{xref:PRIV-02}} | OPTIONAL
   Minimization rules: {{xref:PRIV-03}} | OPTIONAL
   Retention/deletion: {{xref:PRIV-05}} | OPTIONAL

Cross-References
Upstream: {{xref:DATA-06}} | OPTIONAL, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:PRIV-02}}, {{xref:PRIV-03}}, {{xref:COMP-05}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. List classes/entities and purposes; use UNKNOWN when needed.

intermediate: Required. Add producers/consumers and storage locations.
advanced: Required. Add retention/sharing refs and coverage telemetry rigor.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, retention/sharing refs, notes, lawful basis notes, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If classes.list is UNKNOWN → block Completeness Gate.
If entities.list is UNKNOWN → block Completeness Gate.
If items[*].purpose is UNKNOWN → block Completeness Gate.
If telemetry.coverage_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.PRIV
Pass conditions:
required_fields_present == true
data_classes_and_entities_defined == true
purposes_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

PRIV-02

PRIV-02 — PII Classification Model (types, sensitivity)
Header Block
template_id: PRIV-02
title: PII Classification Model (types, sensitivity)
type: privacy_pii_classification_model
template_version: 1.0.0
output_path: 10_app/privacy/PRIV-02_PII_Classification_Model.md
compliance_gate_id: TMP-05.PRIMARY.PRIV
upstream_dependencies: ["PRIV-01", "SEC-01"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "PRIV-01", "SEC-01", "FMS-06"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical PII classification model used across the system: what counts as PII, sensitivity tiers, examples, and handling expectations. This template must align with security posture and file/media PII rules.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Data inventory: {{xref:PRIV-01}} | OPTIONAL
Security overview: {{xref:SEC-01}} | OPTIONAL
File security/compliance: {{xref:FMS-06}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
PII definition statement
Sensitivity tiers list (tier_id list)
Tier definitions (what included)
PII types registry (email, phone, address, biometrics, etc.)
Special categories (children, health, financial)
Handling rules per tier (store/share/log)
Redaction rules per tier (logs/analytics)
Telemetry requirements (pii violations detected)

Optional Fields
Jurisdiction-specific notes | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-PII-REDACTION]}} | OPTIONAL

Classification must be usable by engineers (clear examples).
Higher tiers must have stricter logging/sharing prohibitions.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Definition
   pii_definition: {{pii.definition}}
2. Tiers
   tiers: {{tiers.list}}
3. Tier Rules (repeat)
   Tier
   tier_id: {{tiers.items[0].tier_id}}
   name: {{tiers.items[0].name}}
   includes: {{tiers.items[0].includes}}
   handling_rules: {{tiers.items[0].handling_rules}}
   redaction_rules: {{tiers.items[0].redaction_rules}}

(Repeat per tier.)

4. PII Types
   types: {{pii.types}}
   special_categories: {{pii.special_categories}} | OPTIONAL
5. Telemetry
   pii_violation_metric: {{telemetry.pii_violation_metric}}
6. References
   Data inventory: {{xref:PRIV-01}} | OPTIONAL
   Minimization rules: {{xref:PRIV-03}} | OPTIONAL
   Logging redaction: {{xref:SKM-09}} | OPTIONAL

Cross-References
Upstream: {{xref:PRIV-01}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:PRIV-03}}, {{xref:PRIV-06}}, {{xref:COMP-06}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define tiers and basic handling/redaction rules.
intermediate: Required. Define types registry and special categories and telemetry.
advanced: Required. Add jurisdiction notes and tighter tier examples and enforcement pointers.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, special categories, jurisdiction notes, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

If pii.definition is UNKNOWN → block Completeness Gate.
If tiers.list is UNKNOWN → block Completeness Gate.
If tiers.items[*].handling_rules is UNKNOWN → block Completeness Gate.
If telemetry.pii_violation_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.PRIV
Pass conditions:
required_fields_present == true
tiers_defined == true
handling_and_redaction_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

PRIV-03

PRIV-03 — Data Minimization Rules (collect/store/share)
Header Block
template_id: PRIV-03
title: Data Minimization Rules (collect/store/share)
type: privacy_data_minimization_rules
template_version: 1.0.0
output_path: 10_app/privacy/PRIV-03_Data_Minimization_Rules.md
compliance_gate_id: TMP-05.PRIMARY.PRIV
upstream_dependencies: ["PRIV-01", "PRIV-02", "PRD-01"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "PRIV-01", "PRIV-02", "PRD-01", "FMS-06"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical data minimization rules: what data is allowed to be collected/stored/shared, what is prohibited, and how teams justify data collection. This template must align with the data inventory and PII tiering model.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Data inventory: {{xref:PRIV-01}} | OPTIONAL
PII classification: {{xref:PRIV-02}} | OPTIONAL
Product overview/scope: {{xref:PRD-01}} | OPTIONAL
File security: {{xref:FMS-06}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Minimization principles list
Collection rules (only collect if needed)
Storage rules (store minimum, prefer derived)
Sharing rules (default no sharing)
Prohibited data categories (by tier/type)
Justification process (what required to add new data)
Approval roles (who approves new data collection)
Telemetry requirements (minimization violations, new fields added)
Reference to deletion/retention policy (PRIV-05)

Optional Fields
Examples of allowed vs disallowed | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-PII-REDACTION]}} | OPTIONAL
Default is minimize: if not needed for a defined purpose, do not collect/store.
New data collection must be reviewed/approved.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Principles
   principles:
   {{principles[0]}}
   {{principles[1]}}
   {{principles[2]}}
2. Collection Rules
   rules: {{collect.rules}}
3. Storage Rules
   rules: {{store.rules}}
4. Sharing Rules
   rules: {{share.rules}}
5. Prohibited Data
   prohibited_types: {{ban.types}}
   prohibited_tiers: {{ban.tiers}} | OPTIONAL
6. Justification & Approvals
   justification_required_fields: {{justify.fields}}
   approver_roles: {{approve.roles}}
   workflow_steps: {{approve.steps}} | OPTIONAL
7. Telemetry
   minimization_violation_metric: {{telemetry.violation_metric}}
   new_field_added_metric: {{telemetry.new_field_metric}} | OPTIONAL
8. Retention/Deletion Reference
   retention_ref: {{xref:PRIV-05}} | OPTIONAL

Cross-References
Upstream: {{xref:PRIV-01}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:PRIV-05}}, {{xref:COMP-05}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define principles, prohibited data, and approvals.
intermediate: Required. Define justification fields and telemetry and sharing rules.
advanced: Required. Add examples and strict “new field” governance and audit trails.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, optional tiers, workflow steps, optional metrics, examples, open_questions

If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If principles is UNKNOWN → block Completeness Gate.
If ban.types is UNKNOWN → block Completeness Gate.
If approve.roles is UNKNOWN → block Completeness Gate.
If telemetry.violation_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.PRIV
Pass conditions:
required_fields_present == true
principles_defined == true
prohibited_data_defined == true
approvals_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

PRIV-04

PRIV-04 — Consent Model (capture, storage, enforcement)
Header Block
template_id: PRIV-04
title: Consent Model (capture, storage, enforcement)
type: privacy_consent_model
template_version: 1.0.0
output_path: 10_app/privacy/PRIV-04_Consent_Model.md
compliance_gate_id: TMP-05.PRIMARY.PRIV
upstream_dependencies: ["PRIV-01", "NOTIF-06", "COMP-06"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "PRIV-01", "PRIV-02", "NOTIF-06", "COMP-06", "ROUTE-01"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical consent model for the product: what consent types exist, how consent is captured, stored, updated, and enforced across features (including communications preferences). This template must align with notification preference rules and regulatory requirements.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Data inventory: {{xref:PRIV-01}} | OPTIONAL
PII classification: {{xref:PRIV-02}} | OPTIONAL
Notification preferences: {{xref:NOTIF-06}} | OPTIONAL
Regulatory requirements: {{xref:COMP-06}} | OPTIONAL
Route contract (consent UX surfaces): {{xref:ROUTE-01}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Consent types registry (consent_id list)
consent_id (stable identifier)
What the consent covers (data use / comms / tracking)
Capture points (screens/actions)
Proof fields stored (timestamp, source, user_id)
Withdrawal/update rules (how revoked)
Enforcement points (where checked)
Default state rule (opt-in/opt-out)
Retention rule for consent records
Telemetry requirements (consent changes, violations)

Optional Fields
Age-based consent rules | OPTIONAL
Per-jurisdiction overrides | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-PII-REDACTION]}} | OPTIONAL
Consent enforcement must be server-side where relevant (not only UI).
Withdrawal must be honored promptly and consistently.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Consent Registry Summary
   total_consents: {{meta.total}}
   notes: {{meta.notes}} | OPTIONAL
2. Consent Types (repeat per consent_id)
   Consent
   consent_id: {{consents[0].consent_id}}
   covers: {{consents[0].covers}}
   capture_points: {{consents[0].capture_points}}
   proof_fields: {{consents[0].proof_fields}}
   default_state: {{consents[0].default_state}} (opt_in/opt_out/UNKNOWN)
   withdrawal_rule: {{consents[0].withdrawal_rule}}
   enforcement_points: {{consents[0].enforcement_points}}
   retention_policy: {{consents[0].retention_policy}}
   telemetry_metric: {{consents[0].telemetry_metric}}
   jurisdiction_overrides: {{consents[0].jurisdiction_overrides}} | OPTIONAL
   age_rules: {{consents[0].age_rules}} | OPTIONAL
   open_questions:
   {{consents[0].open_questions[0]}} | OPTIONAL

(Repeat per consent.)

3. Telemetry
   consent_violation_metric: {{telemetry.violation_metric}} | OPTIONAL
4. References
   Notification preferences: {{xref:NOTIF-06}} | OPTIONAL
   Security monitoring: {{xref:SEC-06}} | OPTIONAL
   Regulatory requirements: {{xref:COMP-06}} | OPTIONAL

Cross-References
Upstream: {{xref:PRIV-02}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:PRIV-06}}, {{xref:COMP-05}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define consent registry and withdrawal/enforcement points.
intermediate: Required. Define proof fields, retention, and telemetry metrics.
advanced: Required. Add jurisdiction/age overrides and strict enforcement mappings.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, meta notes, jurisdiction/age rules, consent violation metric, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If consents[*].consent_id is UNKNOWN → block Completeness Gate.
If consents[*].withdrawal_rule is UNKNOWN → block Completeness Gate.
If consents[*].enforcement_points is UNKNOWN → block Completeness Gate.
If consents[*].retention_policy is UNKNOWN → block Completeness Gate.
If consents[*].telemetry_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.PRIV
Pass conditions:
required_fields_present == true
consent_registry_defined == true
withdrawal_and_enforcement_defined == true
retention_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

PRIV-05

PRIV-05 — Retention & Deletion Policy (TTL, DSAR, legal hold)
Header Block
template_id: PRIV-05
title: Retention & Deletion Policy (TTL, DSAR, legal hold)
type: privacy_retention_deletion_policy
template_version: 1.0.0
output_path: 10_app/privacy/PRIV-05_Retention_Deletion_Policy.md
compliance_gate_id: TMP-05.PRIMARY.PRIV
upstream_dependencies: ["PRIV-01", "FMS-05", "COMP-06"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "PRIV-01", "PRIV-02", "FMS-05", "COMP-06", "ADMIN-04"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical retention and deletion policy for user and system data: TTLs by data class, deletion workflows (including DSAR/data deletion requests), legal hold behavior, and deletion propagation to files, caches, and derived data. This template must align with storage lifecycle rules and compliance requirements.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Data inventory: {{xref:PRIV-01}} | OPTIONAL
PII classification: {{xref:PRIV-02}} | OPTIONAL
File retention/lifecycle: {{xref:FMS-05}} | OPTIONAL
Regulatory requirements: {{xref:COMP-06}} | OPTIONAL
Data repair/backfill procedures: {{xref:ADMIN-04}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Retention classes list (class_id list)
Retention TTLs by data_class/entity
Deletion request types (account delete, DSAR erase)
Deletion execution workflow (steps)
Propagation rules (db, files, caches, indexes)
Legal hold supported (yes/no/UNKNOWN)
Legal hold override rule
Verification rule (prove deletion completed)
Audit requirements (deletion events)
Telemetry requirements (deletions completed, backlog)

Optional Fields
Export (DSAR access) rules | OPTIONAL
Backups deletion policy | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-PII-REDACTION]}} | OPTIONAL
Deletion must propagate to derived data and files per rules.
Legal hold must override deletion/TTL when enabled.
Verification must be explicit (counts/checks).
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Retention Classes
   classes: {{retention.classes}}
2. TTLs
   Policy
   data_class: {{ttls[0].data_class}}
   entity_name: {{ttls[0].entity_name}}
   ttl_days: {{ttls[0].ttl_days}}
   notes: {{ttls[0].notes}} | OPTIONAL

(Repeat per policy.)

3. Deletion Request Types
   types: {{delete.types}}
4. Deletion Workflow
   steps:
   {{delete.steps[0]}}
   {{delete.steps[1]}}
   {{delete.steps[2]}} | OPTIONAL
5. Propagation
   propagation_rules: {{prop.rules}}
   file_ref: {{xref:FMS-05}} | OPTIONAL
6. Legal Hold
   supported: {{hold.supported}}
   override_rule: {{hold.override_rule}}
7. Verification
   verification_rule: {{verify.rule}}
   evidence_artifact_rule: {{verify.evidence_artifact_rule}} | OPTIONAL
8. Audit
   audit_required: {{audit.required}}
   audit_events: {{audit.events}} | OPTIONAL

9. Telemetry
   deletion_completed_metric: {{telemetry.completed_metric}}
   deletion_backlog_metric: {{telemetry.backlog_metric}} | OPTIONAL
10. References
   Data inventory: {{xref:PRIV-01}} | OPTIONAL
   Consent model: {{xref:PRIV-04}} | OPTIONAL
   File lifecycle: {{xref:FMS-05}} | OPTIONAL
   Compliance requirements: {{xref:COMP-06}} | OPTIONAL

Cross-References
Upstream: {{xref:PRIV-01}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:PRIV-09}}, {{xref:COMP-09}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define TTLs, deletion workflow steps, and propagation.
intermediate: Required. Define legal hold and verification and audit events.
advanced: Required. Add backups/export policy and strict telemetry/backlog management.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, notes, evidence artifact rule, audit events, backlog metric, export/backup policies, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If retention.classes is UNKNOWN → block Completeness Gate.
If delete.steps[0] is UNKNOWN → block Completeness Gate.
If prop.rules is UNKNOWN → block Completeness Gate.
If hold.override_rule is UNKNOWN → block Completeness Gate (when hold.supported == true).
If telemetry.completed_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.PRIV
Pass conditions:
required_fields_present == true
ttls_defined == true
deletion_and_propagation_defined == true
legal_hold_and_verification_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

PRIV-06

PRIV-06 — Data Sharing Map (internal/external recipients)
Header Block
template_id: PRIV-06
title: Data Sharing Map (internal/external recipients)
type: privacy_data_sharing_map
template_version: 1.0.0
output_path: 10_app/privacy/PRIV-06_Data_Sharing_Map.md
compliance_gate_id: TMP-05.PRIMARY.PRIV
upstream_dependencies: ["PRIV-01", "IXS-01", "PAY-01", "NOTIF-02"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "PRIV-01", "PRIV-02", "IXS-01", "PAY-01", "NOTIF-02", "FMS-01"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical map of data sharing: what data is shared, with whom (internal services and external vendors), for what purpose, and under what constraints. This template must align with integration inventories and PII tiering.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Data inventory: {{xref:PRIV-01}} | OPTIONAL
PII classification: {{xref:PRIV-02}} | OPTIONAL
Integration inventory: {{xref:IXS-01}} | OPTIONAL
Payments providers: {{xref:PAY-01}} | OPTIONAL
Notification providers: {{xref:NOTIF-02}} | OPTIONAL
Storage providers: {{xref:FMS-01}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Sharing registry (share_id list)
share_id (stable identifier)
data_class/entity binding (PRIV-01 refs)
Recipient type (internal_service/external_vendor)
Recipient identifier (service_id/provider_id)
Data fields shared (minimized)
Purpose (why shared)
Legal/consent requirement (PRIV-04 ref)
Transmission method (API/webhook/batch)
Retention expectations at recipient (if known)
Telemetry requirements (sharing events, failures)

Optional Fields
DPA reference (COMP-05) | OPTIONAL
Regional constraints | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-PII-REDACTION]}} | OPTIONAL
Share the minimum necessary data; avoid sharing high-tier PII unless required.
Each external share should have a DPA/record pointer where applicable.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Sharing Summary
   total_shares: {{meta.total}}
   external_shares: {{meta.external}} | OPTIONAL
2. Sharing Entries (repeat per share_id)
   Share
   share_id: {{shares[0].share_id}}
   data_binding: {{shares[0].data_binding}}
   recipient_type: {{shares[0].recipient_type}}
   recipient_id: {{shares[0].recipient_id}}
   fields_shared: {{shares[0].fields_shared}}
   purpose: {{shares[0].purpose}}
   consent_ref: {{shares[0].consent_ref}} (expected: {{xref:PRIV-04}}) | OPTIONAL
   method: {{shares[0].method}}
   recipient_retention: {{shares[0].recipient_retention}} | OPTIONAL
   dpa_ref: {{shares[0].dpa_ref}} | OPTIONAL
   region_constraints: {{shares[0].region_constraints}} | OPTIONAL
   telemetry_metric: {{shares[0].telemetry_metric}}
   open_questions:
   {{shares[0].open_questions[0]}} | OPTIONAL

(Repeat per share.)

3. References
   Data inventory: {{xref:PRIV-01}} | OPTIONAL
   Consent model: {{xref:PRIV-04}} | OPTIONAL
   DPA records: {{xref:COMP-05}} | OPTIONAL

Cross-References
Upstream: {{xref:PRIV-01}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:COMP-05}}, {{xref:PRIV-09}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define share registry, recipient IDs, purposes, and minimized fields.
intermediate: Required. Add consent refs/methods and telemetry and retention expectations.
advanced: Required. Add DPA refs, regional constraints, and stricter minimization enforcement notes.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, consent ref, recipient retention, dpa ref, region constraints, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If shares[*].share_id is UNKNOWN → block Completeness Gate.
If shares[].fields_shared is UNKNOWN → block Completeness Gate.
If shares[*].purpose is UNKNOWN → block Completeness Gate.
If shares[].method is UNKNOWN → block Completeness Gate.
If shares[*].telemetry_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.PRIV
Pass conditions:
required_fields_present == true
share_registry_defined == true
fields_and_purposes_defined == true
recipients_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

PRIV-07

PRIV-07 — Privacy by Design Checklist (gates, reviews)
Header Block
template_id: PRIV-07
title: Privacy by Design Checklist (gates, reviews)
type: privacy_by_design_checklist
template_version: 1.0.0
output_path: 10_app/privacy/PRIV-07_Privacy_By_Design_Checklist.md
compliance_gate_id: TMP-05.PRIMARY.PRIV
upstream_dependencies: ["PRIV-02", "PRIV-03", "SEC-07"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "PRIV-02", "PRIV-03", "SEC-07", "COMP-02"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical privacy-by-design checklist used in design/dev/release gates: minimization, consent, retention, sharing, and logging redaction expectations. This template must align with the privacy models and Secure SDLC gates.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
PII classification: {{xref:PRIV-02}} | OPTIONAL
Minimization rules: {{xref:PRIV-03}} | OPTIONAL
Secure SDLC policy: {{xref:SEC-07}} | OPTIONAL
Compliance controls: {{xref:COMP-02}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Checklist registry (check_id list)
Check categories (collect/store/share/log/retain/consent)
Checklist items per category (testable)
Required review points (design review, release)
Evidence requirement (what proves each check)
Approver roles (privacy/security)
Exception handling ref (COMP-08/SEC-08)
Telemetry requirements (checks completed, violations)

Optional Fields
DPIA trigger rules | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-PII-REDACTION]}} | OPTIONAL
Checklist items must be actionable and testable.
Exceptions must be time-bound and approved.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Categories
   categories: {{cats.list}}
2. Checklist Items (repeat)
   Check
   check_id: {{checks[0].check_id}}
   category: {{checks[0].category}}
   statement: {{checks[0].statement}}
   evidence: {{checks[0].evidence}}
   review_point: {{checks[0].review_point}} (design/release/UNKNOWN)
   approver_roles: {{checks[0].approver_roles}} | OPTIONAL

(Repeat per check.)

3. Reviews
   required_review_points: {{reviews.points}}
   workflow: {{reviews.workflow}} | OPTIONAL
4. Exceptions
   exceptions_ref: {{exceptions.ref}} (expected: {{xref:COMP-08}}/{{xref:SEC-08}}) | OPTIONAL
5. Telemetry
   checks_completed_metric: {{telemetry.completed_metric}}
   privacy_violation_metric: {{telemetry.violation_metric}} | OPTIONAL
6. References
   Minimization: {{xref:PRIV-03}} | OPTIONAL
   Retention/deletion: {{xref:PRIV-05}} | OPTIONAL
   Logging rules: {{xref:SKM-09}} | OPTIONAL

Cross-References
Upstream: {{xref:PRIV-03}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:COMP-09}}, {{xref:PRIV-10}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define categories and core checks and review points.
intermediate: Required. Define evidence and approvers and telemetry.
advanced: Required. Add DPIA triggers and tighter exception/approval workflow and control mapping.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, approver roles, workflow, exceptions ref, optional metrics, dpia triggers, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If checks[*].check_id is UNKNOWN → block Completeness Gate.
If checks[].statement is UNKNOWN → block Completeness Gate.
If checks[*].evidence is UNKNOWN → block Completeness Gate.
If telemetry.completed_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.PRIV
Pass conditions:
required_fields_present == true
checklist_defined == true
evidence_defined == true
review_points_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

PRIV-08

PRIV-08 — Anonymization/Pseudonymization Rules (hashing, tokenization)
Header Block
template_id: PRIV-08
title: Anonymization/Pseudonymization Rules (hashing, tokenization)
type: privacy_anonymization_pseudonymization_rules
template_version: 1.0.0
output_path: 10_app/privacy/PRIV-08_Anonymization_Pseudonymization_Rules.md
compliance_gate_id: TMP-05.PRIMARY.PRIV
upstream_dependencies: ["PRIV-02", "SKM-04", "DATA-06"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "PRIV-01", "PRIV-02", "SKM-04", "DATA-06", "CER-05"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical rules for anonymization and pseudonymization: what identifiers are hashed/tokenized, how salts/keys are managed, what counts as reversible vs irreversible transformation, and where these methods are used (logs, analytics, exports). This template must align with key usage rules and canonical data schemas.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Data inventory: {{xref:PRIV-01}} | OPTIONAL
PII classification: {{xref:PRIV-02}} | OPTIONAL
Key types/usage: {{xref:SKM-04}} | OPTIONAL
Canonical schemas: {{xref:DATA-06}} | OPTIONAL
Logging/redaction: {{xref:CER-05}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Transformation registry (transform_id list)
transform_id (stable identifier)
Target fields (what is transformed)
Method (hash/tokenize/encrypt/UNKNOWN)
Reversibility flag (reversible/irreversible/UNKNOWN)
Key/salt management rule (SKM refs)
Where applied (logs/analytics/db exports)
Collision/uniqueness expectations (for hashes)
Access control for reversible mappings
Telemetry requirements (transform errors, coverage)

Optional Fields
Rotation impact notes | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-PII-REDACTION]}} | OPTIONAL
Do not claim “anonymous” if reversible or if linkage remains feasible; call it pseudonymized.
Salts/keys must be managed securely and rotated per SKM policies.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Registry Summary
   total_transforms: {{meta.total}}
   notes: {{meta.notes}} | OPTIONAL
2. Transforms (repeat)
   Transform
   transform_id: {{items[0].transform_id}}
   fields: {{items[0].fields}}
   method: {{items[0].method}}
   reversibility: {{items[0].reversibility}}
   key_salt_rule: {{items[0].key_salt_rule}}
   applied_in: {{items[0].applied_in}}
   collision_rule: {{items[0].collision_rule}} | OPTIONAL
   access_rule: {{items[0].access_rule}} | OPTIONAL
   telemetry_metric: {{items[0].telemetry_metric}}
   rotation_impact: {{items[0].rotation_impact}} | OPTIONAL
   open_questions:
   {{items[0].open_questions[0]}} | OPTIONAL

(Repeat per transform.)

3. Telemetry
   transform_error_metric: {{telemetry.error_metric}} | OPTIONAL
4. References
   PII classification: {{xref:PRIV-02}} | OPTIONAL
   Key usage rules: {{xref:SKM-04}} | OPTIONAL
   Logging redaction: {{xref:SKM-09}} | OPTIONAL

Cross-References
Upstream: {{xref:PRIV-02}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:PRIV-10}}, {{xref:COMP-05}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define transforms, method, reversibility, and where applied.
intermediate: Required. Define key/salt rule and access rules and telemetry.
advanced: Required. Add rotation impact notes and collision/uniqueness rigor and coverage targets.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, collision/access rules, rotation impact, optional telemetry, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If items[*].transform_id is UNKNOWN → block Completeness Gate.*
*If items[*].fields is UNKNOWN → block Completeness Gate.
If items[*].method is UNKNOWN → block Completeness Gate.*
*If items[*].reversibility is UNKNOWN → block Completeness Gate.
If items[*].telemetry_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.PRIV
Pass conditions:
required_fields_present == true
transform_registry_defined == true
methods_and_reversibility_defined == true
key_management_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

PRIV-09

PRIV-09 — Privacy Incident Handling (breach response, notifications)
Header Block
template_id: PRIV-09
title: Privacy Incident Handling (breach response, notifications)
type: privacy_incident_handling
template_version: 1.0.0
output_path: 10_app/privacy/PRIV-09_Privacy_Incident_Handling.md
compliance_gate_id: TMP-05.PRIMARY.PRIV
upstream_dependencies: ["SEC-05", "PRIV-02", "COMP-06"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SEC-05", "PRIV-02", "COMP-06", "AUDIT-06"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical handling of privacy incidents (PII exposure, unauthorized access): triage, containment, assessment, notification triggers, and post-incident actions. This template must align with security incident response and regulatory requirements.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Incident response plan: {{xref:SEC-05}} | OPTIONAL
PII classification model: {{xref:PRIV-02}} | OPTIONAL
Regulatory requirements: {{xref:COMP-06}} | OPTIONAL
Investigation workflow: {{xref:AUDIT-06}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Privacy incident types list (pii leak, mis-send, vendor breach)
Severity model (privacy-specific or reuse SEC-05)
Triage process (who assesses)
Containment actions (disable sharing, rotate keys)
Assessment rule (what data impacted)
Notification trigger rules (user/regulator)
Timeline rules (if known, else UNKNOWN)
Evidence preservation rules
Post-incident remediation requirements
Telemetry requirements (incidents count, time-to-notify)

Optional Fields
Customer comms templates pointers | OPTIONAL

Vendor coordination rules | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-PII-REDACTION]}} | OPTIONAL
Do not claim notification timelines unless explicitly defined; use UNKNOWN where needed.
Assessment must identify impacted data classes and counts where possible.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Types
   types: {{types.list}}
2. Severity
   model: {{sev.model}}
   definitions: {{sev.definitions}} | OPTIONAL
3. Triage
   owner: {{triage.owner}}
   steps: {{triage.steps}}
4. Containment
   actions: {{contain.actions}}
5. Assessment
   assessment_rule: {{assess.rule}}
   data_classes_to_check: {{assess.data_classes}} | OPTIONAL
6. Notifications
   user_notify_trigger: {{notify.user_trigger}}
   regulator_notify_trigger: {{notify.regulator_trigger}} | OPTIONAL
   timeline: {{notify.timeline}} | OPTIONAL
7. Evidence
   capture_rule: {{evidence.capture_rule}}
   storage_location: {{evidence.storage_location}} | OPTIONAL
8. Post-Incident
   remediation_steps: {{post.steps}}
   rca_required: {{post.rca_required}} | OPTIONAL
9. Telemetry
   privacy_incident_metric: {{telemetry.incident_metric}}
   time_to_notify_metric: {{telemetry.time_to_notify_metric}} | OPTIONAL
10. References
    Security IR: {{xref:SEC-05}} | OPTIONAL
    Forensics workflow: {{xref:AUDIT-06}} | OPTIONAL
    Compliance requirements: {{xref:COMP-06}} | OPTIONAL

Cross-References
Upstream: {{xref:PRIV-02}}, {{xref:SPEC_INDEX}} | OPTIONAL

Downstream: {{xref:PRIV-10}}, {{xref:COMP-10}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define types, triage, containment, and assessment rule.
intermediate: Required. Define notification triggers and evidence rules and telemetry.
advanced: Required. Add vendor coordination and comms template pointers and stricter assessment metrics.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, definitions, regulator trigger, timeline, evidence storage, rca required, optional metrics, vendor/comms pointers, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If types.list is UNKNOWN → block Completeness Gate.
If triage.steps is UNKNOWN → block Completeness Gate.
If assess.rule is UNKNOWN → block Completeness Gate.
If telemetry.incident_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.PRIV
Pass conditions:
required_fields_present == true
types_and_triage_defined == true
containment_and_assessment_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

PRIV-10

PRIV-10 — Privacy Metrics & Audits (coverage, violations)
Header Block
template_id: PRIV-10
title: Privacy Metrics & Audits (coverage, violations)
type: privacy_metrics_audits
template_version: 1.0.0
output_path: 10_app/privacy/PRIV-10_Privacy_Metrics_Audits.md
compliance_gate_id: TMP-05.PRIMARY.PRIV
upstream_dependencies: ["PRIV-01", "PRIV-03", "PRIV-05", "COMP-10"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "PRIV-01", "PRIV-03", "PRIV-05", "COMP-10", "AUDIT-09"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical privacy metrics and audit program: coverage metrics for inventories and consent, violation monitoring, deletion/retention audits, and periodic review cadence. This template must align with audit anomaly detection and compliance reporting.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Data inventory: {{xref:PRIV-01}} | OPTIONAL
Minimization rules: {{xref:PRIV-03}} | OPTIONAL
Retention/deletion policy: {{xref:PRIV-05}} | OPTIONAL
Compliance reporting: {{xref:COMP-10}} | OPTIONAL
Audit anomaly detection: {{xref:AUDIT-09}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Core privacy metrics list (inventory coverage, consent coverage)
Violation metrics list (minimization violations, pii leaks)
Deletion/retention audit checks (TTL enforced)
Audit cadence (monthly/quarterly/UNKNOWN)
Owners (who reviews)
Evidence artifacts produced (reports)
Escalation rules (violations → incident)
Telemetry requirements (metrics published)

Optional Fields
External audit support | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-PII-REDACTION]}} | OPTIONAL
Audits must be repeatable and produce evidence artifacts.
Violations must have escalation paths tied to PRIV-09/SEC-05.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Core Metrics
   metrics: {{metrics.core}}
2. Violation Metrics
   violations: {{metrics.violations}}
3. Audit Checks
   checks: {{audit.checks}}
4. Cadence & Ownership
   cadence: {{cadence.value}}
   owners: {{owners.list}}
5. Evidence
   artifacts: {{evidence.artifacts}}
   storage_location: {{evidence.storage_location}} | OPTIONAL
6. Escalation
   escalation_rule: {{escalate.rule}}
   incident_ref: {{xref:PRIV-09}} | OPTIONAL
7. Telemetry
   published_metric: {{telemetry.published_metric}}
8. References
   Retention policy: {{xref:PRIV-05}} | OPTIONAL
   Incident handling: {{xref:PRIV-09}} | OPTIONAL
   Compliance reporting: {{xref:COMP-10}} | OPTIONAL

Cross-References
Upstream: {{xref:PRIV-01}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:COMP-09}}, {{xref:SEC-06}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define metrics list, cadence, and escalation rule.
intermediate: Required. Define audit checks and evidence artifacts and ownership.
advanced: Required. Add external audit support and stricter publication/reporting pipelines.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, evidence storage, incident ref, external audit, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

If metrics.core is UNKNOWN → block Completeness Gate.
If audit.checks is UNKNOWN → block Completeness Gate.
If cadence.value is UNKNOWN → block Completeness Gate.
If owners.list is UNKNOWN → block Completeness Gate.
If telemetry.published_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.PRIV
Pass conditions:
required_fields_present == true
metrics_defined == true
audit_checks_defined == true
cadence_and_owners_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

Audit Logging & Forensics (AUDIT)

AUDIT-01

AUDIT-01 — Audit Event Catalog (by event_type)
Header Block
template_id: AUDIT-01
title: Audit Event Catalog (by event_type)
type: audit_event_catalog
template_version: 1.0.0
output_path: 10_app/audit/AUDIT-01_Audit_Event_Catalog.md
compliance_gate_id: TMP-05.PRIMARY.AUDIT
upstream_dependencies: ["ADMIN-03", "API-01", "IAM-04"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "ADMIN-03", "API-01", "IAM-04", "PAY-07", "FMS-07"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Create the canonical catalog of audit events that must be recorded across the system, indexed by event_type. This catalog drives schema requirements, capture rules, alerts, and forensics workflows. It must align with privileged actions, financial actions, and sensitive data access.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Audit trail spec (admin): {{xref:ADMIN-03}} | OPTIONAL
API surface: {{xref:API-01}} | OPTIONAL
AuthZ enforcement points: {{xref:IAM-04}} | OPTIONAL
Payments ledger: {{xref:PAY-07}} | OPTIONAL
File access control: {{xref:FMS-07}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Event type registry (event_type list)
event_type (stable identifier)
Category (auth/authz/admin/data/payment/file)
Triggering action (what causes it)
Actor (user/service/admin)
Target (resource type/id)
Minimum required fields (schema pointer)
Retention class (short/standard/long/UNKNOWN)
Sensitivity level (contains PII? yes/no/UNKNOWN)
Downstream consumers (alerts/forensics)
Telemetry requirements (events per type)

Optional Fields
Example payload | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Every audit event type must be tied to a triggering action and capture at least actor+target.
Do not include raw secret material or full content bodies in audit payloads.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Registry Summary
   total_event_types: {{meta.total}}
   notes: {{meta.notes}} | OPTIONAL
2. Event Types (repeat per event_type)
   Event
   event_type: {{events[0].event_type}}
   category: {{events[0].category}}
   trigger: {{events[0].trigger}}
   actor_type: {{events[0].actor_type}}
   target: {{events[0].target}}
   required_fields: {{events[0].required_fields}}
   retention_class: {{events[0].retention_class}}
   contains_pii: {{events[0].contains_pii}}
   consumers: {{events[0].consumers}}
   telemetry_metric: {{events[0].telemetry_metric}}
   example_payload: {{events[0].example_payload}} | OPTIONAL
   open_questions:
   {{events[0].open_questions[0]}} | OPTIONAL

(Repeat per event.)

3. References
   Audit schema: {{xref:AUDIT-02}} | OPTIONAL
   Capture rules: {{xref:AUDIT-03}} | OPTIONAL
   Privileged audit: {{xref:AUDIT-07}} | OPTIONAL

Cross-References
Upstream: {{xref:ADMIN-03}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:AUDIT-02}}, {{xref:AUDIT-09}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define event types and categories and triggers.

intermediate: Required. Define required fields and retention class and consumers.
advanced: Required. Add example payloads and sensitivity/PII notes and telemetry rigor.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, notes, example payloads, consumers, retention class, contains pii, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If events[*].event_type is UNKNOWN → block Completeness Gate.*
*If events[*].trigger is UNKNOWN → block Completeness Gate.
If events[*].required_fields is UNKNOWN → block Completeness Gate.*
*If events[*].telemetry_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.AUDIT
Pass conditions:
required_fields_present == true
event_registry_defined == true
triggers_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

AUDIT-02

AUDIT-02 — Audit Schema (required fields, correlation IDs)
Header Block
template_id: AUDIT-02
title: Audit Schema (required fields, correlation IDs)
type: audit_schema
template_version: 1.0.0
output_path: 10_app/audit/AUDIT-02_Audit_Schema.md
compliance_gate_id: TMP-05.PRIMARY.AUDIT
upstream_dependencies: ["AUDIT-01", "SEC-02", "CER-05"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "AUDIT-01", "SEC-02", "CER-05", "DATA-06"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical schema for audit events: required fields, correlation identifiers, actor/target structure, and redaction rules. This schema is used by capture rules, storage, and investigation tooling.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Audit event catalog: {{xref:AUDIT-01}} | OPTIONAL
Security architecture: {{xref:SEC-02}} | OPTIONAL
Logging/redaction: {{xref:CER-05}} | OPTIONAL
Canonical schemas: {{xref:DATA-06}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Schema version (semver)
Required top-level fields list (timestamp, event_type, actor, target)
Actor schema (type/id/role)
Target schema (resource_type/id)
Request context fields (ip hash, user agent, device id)
Correlation IDs (request_id, trace_id)
Reason code field (deny reasons)
PII redaction rules (what must be hashed)
Extensibility rule (event-specific fields)
Telemetry requirements (schema validation failures)

Optional Fields
Example audit event | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Never include tokens/secrets or full content bodies in audit payloads.
Correlation IDs must be present for all events generated from API requests where possible.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Schema Version
   schema_version: {{schema.version}}
2. Required Fields
   required_fields: {{schema.required_fields}}
3. Actor
   actor_fields: {{actor.fields}}
   actor_types: {{actor.types}} | OPTIONAL
4. Target
   target_fields: {{target.fields}}
5. Context
   context_fields: {{context.fields}}
   hashing_rules: {{context.hashing_rules}} | OPTIONAL
6. Correlation
   correlation_fields: {{corr.fields}}
7. Reason Codes
   reason_code_field: {{reasons.field}}
   format_rule: {{reasons.format_rule}} | OPTIONAL
8. Redaction
   pii_hash_rule: {{redact.pii_hash_rule}}
   denylist_fields: {{redact.denylist_fields}}
9. Extensibility
   event_specific_fields_rule: {{ext.rule}}
10. Telemetry
    schema_validation_fail_metric: {{telemetry.validation_fail_metric}}
11. Example (Optional)
    example_event: {{example.event}} | OPTIONAL

Cross-References
Upstream: {{xref:AUDIT-01}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:AUDIT-03}}, {{xref:AUDIT-09}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define required fields and correlation and denylist.
intermediate: Required. Define actor/target/context schemas and redaction rules.
advanced: Required. Add extensibility rules, schema versioning, and example event and validation telemetry.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, actor types, hashing rules, reason format, example, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If schema.version is UNKNOWN → block Completeness Gate.
If schema.required_fields is UNKNOWN → block Completeness Gate.
If corr.fields is UNKNOWN → block Completeness Gate.
If redact.denylist_fields is UNKNOWN → block Completeness Gate.
If telemetry.validation_fail_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.AUDIT
Pass conditions:
required_fields_present == true
schema_defined == true
correlation_defined == true
redaction_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

AUDIT-03

AUDIT-03 — Capture Rules (what must be logged, where)
Header Block
template_id: AUDIT-03
title: Capture Rules (what must be logged, where)
type: audit_capture_rules
template_version: 1.0.0
output_path: 10_app/audit/AUDIT-03_Capture_Rules.md
compliance_gate_id: TMP-05.PRIMARY.AUDIT
upstream_dependencies: ["AUDIT-01", "AUDIT-02", "IAM-04"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "AUDIT-01", "AUDIT-02", "IAM-04", "ADMIN-05", "JBS-01"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical rules for capturing audit events: what must be logged, where capture occurs (API middleware, job workers, admin UI), how events are enriched (correlation IDs), and how failures are handled. This template must align with the audit catalog and auth enforcement points.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Audit event catalog: {{xref:AUDIT-01}} | OPTIONAL
Audit schema: {{xref:AUDIT-02}} | OPTIONAL
AuthZ enforcement points: {{xref:IAM-04}} | OPTIONAL
Privileged API surface: {{xref:ADMIN-05}} | OPTIONAL
Jobs inventory: {{xref:JBS-01}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Capture points list (api/ws/job/admin)
Event coverage rules (which events captured where)
Enrichment rules (request_id/trace_id/user_id hash)
Write path (queue/sync write/UNKNOWN)
Failure behavior (fail open/closed)
Deduping/idempotency rules for audit writes
Storage target (audit store)
Access controls for audit store (who can read)
Telemetry requirements (audit pipeline failures, lag)

Optional Fields
Sampling rules (for non-critical events) | OPTIONAL

Backfill/replay rules | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Privileged actions and security-relevant events must not be sampled away.
Audit capture must not fail silently; failures must be monitored.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Capture Points
   points: {{capture.points}}
2. Coverage Rules
   rules: {{coverage.rules}}
3. Enrichment
   required_enrichment: {{enrich.fields}}
   trace_propagation_rule: {{enrich.trace_rule}} | OPTIONAL
4. Write Path
   write_model: {{write.model}} (sync/queue/UNKNOWN)
   idempotency_rule: {{write.idempotency_rule}} | OPTIONAL
5. Failure Behavior
   on_write_fail: {{fail.on_write_fail}} (fail_open/fail_closed/UNKNOWN)
   alert_rule: {{fail.alert_rule}} | OPTIONAL
6. Storage
   store: {{store.target}}
   access_control_rule: {{store.access_control_rule}}
7. Telemetry
   audit_write_fail_metric: {{telemetry.write_fail_metric}}
   audit_lag_metric: {{telemetry.lag_metric}} | OPTIONAL
8. References
   Audit schema: {{xref:AUDIT-02}} | OPTIONAL
   Forensics workflow: {{xref:AUDIT-06}} | OPTIONAL
   Anomaly detection: {{xref:AUDIT-09}} | OPTIONAL

Cross-References
Upstream: {{xref:AUDIT-01}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:AUDIT-05}}, {{xref:AUDIT-09}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define capture points, write model, and failure behavior.
intermediate: Required. Define enrichment and storage access controls and telemetry.
advanced: Required. Add dedupe/idempotency, replay/backfill, and sampling constraints rigor.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, trace rule, idempotency, alert rule, optional metrics, sampling/backfill, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If capture.points is UNKNOWN → block Completeness Gate.
If write.model is UNKNOWN → block Completeness Gate.
If fail.on_write_fail is UNKNOWN → block Completeness Gate.
If store.target is UNKNOWN → block Completeness Gate.
If telemetry.write_fail_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.AUDIT
Pass conditions:
required_fields_present == true
capture_and_write_model_defined == true
failure_behavior_defined == true
storage_and_access_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

AUDIT-04

AUDIT-04 — Tamper Evidence & Integrity (append-only, hashing)
Header Block
template_id: AUDIT-04
title: Tamper Evidence & Integrity (append-only, hashing)
type: audit_tamper_evidence_integrity
template_version: 1.0.0
output_path: 10_app/audit/AUDIT-04_Tamper_Evidence_Integrity.md
compliance_gate_id: TMP-05.PRIMARY.AUDIT
upstream_dependencies: ["AUDIT-03", "SKM-04", "SEC-02"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "AUDIT-03", "SKM-04", "SEC-02", "COMP-02"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical integrity and tamper-evidence mechanisms for audit logs: append-only storage properties, hashing/chaining, signing, verification checks, and access restrictions. This template must align with key usage rules and compliance control expectations.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Capture rules: {{xref:AUDIT-03}} | OPTIONAL
Key usage rules: {{xref:SKM-04}} | OPTIONAL
Security architecture: {{xref:SEC-02}} | OPTIONAL
Compliance controls: {{xref:COMP-02}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Integrity model (append-only + hash chain/signature)
Hashing algorithm rule (or UNKNOWN)
Chaining rule (prev_hash)
Signing rule (if any)
Key management reference (SKM)
Verification process (periodic checks)
Access control rule (who can write/read)
Retention interaction (cannot edit/delete)
Telemetry requirements (integrity check failures)

Optional Fields
External WORM storage notes | OPTIONAL
Legal evidentiary notes | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Audit logs must be tamper-evident; edits must be impossible or detectable.
Keys used for signing must be protected and rotated per SKM.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Model
   integrity_model: {{model.name}}
   append_only_rule: {{model.append_only_rule}}
2. Hashing / Chaining
   hash_algo: {{hash.algo}}
   chain_rule: {{hash.chain_rule}}
3. Signing
   signing_supported: {{sign.supported}}
   signing_rule: {{sign.rule}} | OPTIONAL
   key_ref: {{sign.key_ref}} (expected: {{xref:SKM-04}}) | OPTIONAL
4. Verification
   verification_cadence: {{verify.cadence}}
   verification_steps: {{verify.steps}}
   evidence_artifact_rule: {{verify.evidence_artifact_rule}} | OPTIONAL
5. Access Controls
   write_access_rule: {{access.write_rule}}
   read_access_rule: {{access.read_rule}}
6. Retention Interaction
   no_edit_no_delete_rule: {{retain.no_edit_no_delete_rule}}
7. Telemetry
   integrity_failure_metric: {{telemetry.integrity_failure_metric}}
8. References
   Audit capture: {{xref:AUDIT-03}} | OPTIONAL
   Key mgmt: {{xref:SKM-02}} | OPTIONAL
   Rotation: {{xref:SKM-03}} | OPTIONAL

Cross-References
Upstream: {{xref:AUDIT-03}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:AUDIT-06}}, {{xref:COMP-09}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define model, hashing/chaining, and verification cadence.
intermediate: Required. Define access rules and signing support and key refs.
advanced: Required. Add WORM/legal notes and stricter evidence artifacts and verification automation.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, signing rules/refs, evidence artifact, worm/legal notes, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If model.append_only_rule is UNKNOWN → block Completeness Gate.
If hash.chain_rule is UNKNOWN → block Completeness Gate.
If verify.cadence is UNKNOWN → block Completeness Gate.
If retain.no_edit_no_delete_rule is UNKNOWN → block Completeness Gate.
If telemetry.integrity_failure_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.AUDIT
Pass conditions:
required_fields_present == true
integrity_model_defined == true
verification_defined == true
access_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

AUDIT-05

AUDIT-05 — Retention & Access Controls (who can view, how long)
Header Block
template_id: AUDIT-05
title: Retention & Access Controls (who can view, how long)
type: audit_retention_access_controls
template_version: 1.0.0
output_path: 10_app/audit/AUDIT-05_Retention_Access_Controls.md
compliance_gate_id: TMP-05.PRIMARY.AUDIT
upstream_dependencies: ["AUDIT-02", "IAM-06", "PRIV-05"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "AUDIT-02", "AUDIT-01", "IAM-06", "PRIV-05", "COMP-06"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical retention policy and access controls for audit logs: how long logs are retained per event category/class, who can view/export them, and how access is approved/audited. This template must align with privacy retention rules and privileged access policy.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Audit schema: {{xref:AUDIT-02}} | OPTIONAL
Audit event catalog: {{xref:AUDIT-01}} | OPTIONAL
Privileged access policy: {{xref:IAM-06}} | OPTIONAL
Privacy retention/deletion: {{xref:PRIV-05}} | OPTIONAL
Regulatory requirements: {{xref:COMP-06}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Retention classes list (short/standard/long)
Retention days per class (or UNKNOWN)
Access roles allowed (who can view)
Export rules (who can export, approvals)
Search/query access policy (who can search)
Redaction rules for audit viewing (PII masking)
Break-glass access rules (if needed)
Audit-of-audit requirements (log access to logs)
Telemetry requirements (access events, exports)

Optional Fields
Legal hold interaction rules | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-PII-REDACTION]}} | OPTIONAL
Audit logs should be retained long enough for security investigations and compliance, but must respect privacy constraints.
Viewing/export access must be least privilege and auditable.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Retention Classes
   classes: {{retention.classes}}
2. Retention Durations
   short_days: {{retention.short_days}}
   standard_days: {{retention.standard_days}}
   long_days: {{retention.long_days}}
3. Access Roles
   viewer_roles: {{access.viewer_roles}}
   exporter_roles: {{access.exporter_roles}} | OPTIONAL
4. Export Rules
   approval_required: {{export.approval_required}}
   approval_rule: {{export.approval_rule}} | OPTIONAL
5. Query/Search Access
   search_access_rule: {{search.access_rule}}
6. Redaction for Viewing
   masking_rule: {{view.masking_rule}}
7. Break-Glass
   supported: {{break.supported}}
   rule: {{break.rule}} | OPTIONAL
8. Audit of Audit
   log_access_events: {{audit_of_audit.log_access_events}}
   event_types: {{audit_of_audit.event_types}} | OPTIONAL
9. Telemetry
   audit_view_metric: {{telemetry.view_metric}}
   audit_export_metric: {{telemetry.export_metric}} | OPTIONAL
10. References
    Privileged access: {{xref:IAM-06}} | OPTIONAL
    Privacy retention: {{xref:PRIV-05}} | OPTIONAL
    Forensics workflow: {{xref:AUDIT-06}} | OPTIONAL

Cross-References
Upstream: {{xref:AUDIT-02}}, {{xref:SPEC_INDEX}} | OPTIONAL

Downstream: {{xref:AUDIT-06}}, {{xref:AUDIT-09}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define retention classes/days and viewer roles and masking rule.
intermediate: Required. Define export rules and audit-of-audit and telemetry metrics.
advanced: Required. Add legal hold interaction and strict approval workflows and break-glass rigor.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, approval rule, exporter roles, break rule, event types, optional metrics, legal hold interaction, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If retention.classes is UNKNOWN → block Completeness Gate.
If retention.standard_days is UNKNOWN → block Completeness Gate.
If access.viewer_roles is UNKNOWN → block Completeness Gate.
If view.masking_rule is UNKNOWN → block Completeness Gate.
If telemetry.view_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.AUDIT
Pass conditions:
required_fields_present == true
retention_defined == true
access_controls_defined == true
masking_defined == true
audit_of_audit_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

AUDIT-06

AUDIT-06 — Investigation Workflow (queries, exports, chain-of-custody)
Header Block
template_id: AUDIT-06
title: Investigation Workflow (queries, exports, chain-of-custody)
type: audit_investigation_workflow
template_version: 1.0.0
output_path: 10_app/audit/AUDIT-06_Investigation_Workflow.md
compliance_gate_id: TMP-05.PRIMARY.AUDIT
upstream_dependencies: ["AUDIT-05", "SEC-05", "AUDIT-10"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "AUDIT-05", "SEC-05", "AUDIT-10", "ADMIN-02"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical workflow for investigating security/privacy incidents using audit logs: who can query, how queries are recorded, how evidence is exported, and how chain-of-custody is maintained. This template must align with incident response plans and audit access controls.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Audit retention/access: {{xref:AUDIT-05}} | OPTIONAL
Incident response: {{xref:SEC-05}} | OPTIONAL
Forensics runbooks: {{xref:AUDIT-10}} | OPTIONAL
Support tools: {{xref:ADMIN-02}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Investigation roles (who can investigate)
Case/ticket model (case_id, owners)
Query rules (how to query, what tools)
Query logging rule (record query + who ran)
Export rules (formats, approvals)
Chain-of-custody rule (hash, signed exports)
Evidence storage rule (where stored, access)
Time sync rule (timestamps, timezone)
Telemetry requirements (investigations opened, exports)

Optional Fields
Standard query library | OPTIONAL
External counsel handoff rules | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Investigations must be auditable; queries and exports must be tracked.
Evidence exports must be integrity-protected (hash/sign).
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Roles
   investigator_roles: {{roles.investigators}}
   approver_roles: {{roles.approvers}} | OPTIONAL
2. Case Model
   case_id_format: {{case.id_format}}
   case_fields: {{case.fields}} | OPTIONAL
3. Querying
   tools: {{query.tools}}
   query_rule: {{query.rule}}
4. Query Logging
   log_rule: {{query.log_rule}}
   log_fields: {{query.log_fields}} | OPTIONAL
5. Exports
   export_formats: {{export.formats}}
   approval_required: {{export.approval_required}}
   approval_rule: {{export.approval_rule}} | OPTIONAL
6. Chain of Custody
   integrity_rule: {{coc.integrity_rule}}
   hash_algo: {{coc.hash_algo}} | OPTIONAL
   signature_rule: {{coc.signature_rule}} | OPTIONAL
7. Evidence Storage
   storage_location: {{evidence.storage_location}}
   access_rule: {{evidence.access_rule}} | OPTIONAL
8. Time Sync
   timezone_rule: {{time.timezone_rule}}
   clock_sync_rule: {{time.clock_sync_rule}} | OPTIONAL
9. Telemetry
   cases_opened_metric: {{telemetry.cases_opened_metric}}
   exports_metric: {{telemetry.exports_metric}} | OPTIONAL
10. References
    Audit access controls: {{xref:AUDIT-05}} | OPTIONAL
    Incident response: {{xref:SEC-05}} | OPTIONAL
    Forensics runbooks: {{xref:AUDIT-10}} | OPTIONAL

Cross-References
Upstream: {{xref:AUDIT-05}}, {{xref:SPEC_INDEX}} | OPTIONAL

Downstream: {{xref:AUDIT-09}}, {{xref:SEC-10}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define roles, query rule, export formats, and evidence storage.
intermediate: Required. Define query logging, approvals, and chain-of-custody.
advanced: Required. Add standard query library and counsel handoff rules and integrity automation.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, approver roles, case fields, log fields, approval rule, hash/signature details, access rule, clock sync, optional metrics, query library/counsel rules, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If roles.investigators is UNKNOWN → block Completeness Gate.
If query.rule is UNKNOWN → block Completeness Gate.
If export.formats is UNKNOWN → block Completeness Gate.
If coc.integrity_rule is UNKNOWN → block Completeness Gate.
If telemetry.cases_opened_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.AUDIT
Pass conditions:
required_fields_present == true
roles_and_case_model_defined == true
query_and_logging_defined == true
exports_and_chain_of_custody_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

AUDIT-07

AUDIT-07 — Admin/Privileged Actions Audit (special handling)
Header Block
template_id: AUDIT-07
title: Admin/Privileged Actions Audit (special handling)
type: audit_admin_privileged_actions
template_version: 1.0.0
output_path: 10_app/audit/AUDIT-07_Admin_Privileged_Actions_Audit.md
compliance_gate_id: TMP-05.PRIMARY.AUDIT
upstream_dependencies: ["IAM-06", "ADMIN-01", "AUDIT-01"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "IAM-06", "ADMIN-01", "ADMIN-05", "AUDIT-01"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the special audit requirements for admin and privileged actions: stricter capture rules, extra context fields, required approvals/step-up, and alerting on unusual activity. This template must align with privileged access policies and admin capabilities.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Privileged access policy: {{xref:IAM-06}} | OPTIONAL
Admin capabilities matrix: {{xref:ADMIN-01}} | OPTIONAL
Privileged API catalog: {{xref:ADMIN-05}} | OPTIONAL
Audit event catalog: {{xref:AUDIT-01}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Privileged action types list (action_id list)
Mapping to admin capabilities (ADMIN-01)
Extra required audit fields (reason, ticket_id)
Step-up requirement rule (SSO-07 ref)
Approval requirement rule (if any)
Real-time alerting rule (suspicious admin activity)
Retention class for privileged actions (long)
Redaction rules (no PII beyond necessary)
Telemetry requirements (privileged actions count, anomalies)

Optional Fields
2-person rule policy | OPTIONAL
Just-in-time access coupling | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Privileged actions must always be audited (no sampling).
Ticket/reason fields should be required for destructive actions.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Privileged Actions
   action_ids: {{actions.ids}}
2. Mapping
   capability_mapping: {{map.capability_mapping}}
3. Required Fields (extra)
   extra_fields: {{fields.extra}}
   reason_required_rule: {{fields.reason_required_rule}} | OPTIONAL
4. Step-up / Approvals
   step_up_ref: {{xref:SSO-07}} | OPTIONAL
   step_up_rule: {{step.rule}}
   approval_required: {{approve.required}} | OPTIONAL
   approval_rule: {{approve.rule}} | OPTIONAL
5. Alerts
   alert_rule: {{alerts.rule}}
   alert_ids: {{alerts.ids}} | OPTIONAL
6. Retention / Redaction
   retention_class: {{retention.class}}
   redaction_rule: {{redact.rule}}
7. Telemetry
   privileged_action_metric: {{telemetry.action_metric}}
   admin_anomaly_metric: {{telemetry.anomaly_metric}} | OPTIONAL
8. References
   Admin access policy: {{xref:IAM-06}} | OPTIONAL
   Audit schema: {{xref:AUDIT-02}} | OPTIONAL

Cross-References
Upstream: {{xref:IAM-06}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:AUDIT-09}}, {{xref:SEC-06}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define action list, extra fields, and retention class.
intermediate: Required. Define step-up rule, alert rule, and telemetry metrics.
advanced: Required. Add 2-person/JIT coupling and strict destructive-action reason rules.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, reason rule, approvals, alert ids,

anomaly metric, 2-person/jit, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If actions.ids is UNKNOWN → block Completeness Gate.
If fields.extra is UNKNOWN → block Completeness Gate.
If step.rule is UNKNOWN → block Completeness Gate.
If retention.class is UNKNOWN → block Completeness Gate.
If telemetry.action_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.AUDIT
Pass conditions:
required_fields_present == true
privileged_actions_defined == true
extra_fields_defined == true
alerts_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

AUDIT-08

AUDIT-08 — Redaction & PII Handling (safe storage of audit data)
Header Block
template_id: AUDIT-08
title: Redaction & PII Handling (safe storage of audit data)
type: audit_redaction_pii_handling
template_version: 1.0.0
output_path: 10_app/audit/AUDIT-08_Redaction_PII_Handling.md
compliance_gate_id: TMP-05.PRIMARY.AUDIT
upstream_dependencies: ["AUDIT-02", "PRIV-02", "SKM-09"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "AUDIT-02", "PRIV-02", "SKM-09", "CER-05"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical redaction and PII handling rules specific to audit data: what can be stored, what must be hashed/masked, how access is controlled, and how audit exports are scrubbed. This template must align with PII tiering and global logging redaction rules.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Audit schema: {{xref:AUDIT-02}} | OPTIONAL
PII classification: {{xref:PRIV-02}} | OPTIONAL
Secrets/log redaction: {{xref:SKM-09}} | OPTIONAL
Logging policy: {{xref:CER-05}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
PII handling rule (what is allowed in audit logs)
Hashing rules (which identifiers hashed)
Masking rules for viewing (UI masking)
Field allowlist/denylist for audit payloads
Export redaction rules
Access control rules (who can view unmasked data)
Retention interaction rule (PII in audit vs TTL)
Telemetry requirements (redaction applied, violations)

Optional Fields
Tier-specific handling overrides | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-PII-REDACTION]}} | OPTIONAL
Default to hashing identifiers; avoid raw PII in audit logs unless strictly required.
Exports must apply redaction by default.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Allowed PII
   allowed_rule: {{pii.allowed_rule}}
   allowed_fields: {{pii.allowed_fields}} | OPTIONAL
2. Hashing
   hash_fields: {{hash.fields}}
   hash_method_rule: {{hash.method_rule}} | OPTIONAL
3. Masking (Viewing)
   masking_rule: {{mask.rule}}
   unmask_access_rule: {{mask.unmask_access_rule}} | OPTIONAL
4. Allowlist / Denylist
   allowlist: {{fields.allowlist}}
   denylist: {{fields.denylist}}
5. Export Redaction
   export_rule: {{export.rule}}
   default_export_masked: {{export.default_masked}} | OPTIONAL
6. Retention Interaction
   retention_rule: {{retention.rule}}
7. Telemetry
   redaction_applied_metric: {{telemetry.redaction_applied_metric}}
   audit_pii_violation_metric: {{telemetry.pii_violation_metric}} | OPTIONAL
8. References
   PII classification: {{xref:PRIV-02}} | OPTIONAL
   Audit access controls: {{xref:AUDIT-05}} | OPTIONAL
   Forensics workflow: {{xref:AUDIT-06}} | OPTIONAL

Cross-References
Upstream: {{xref:AUDIT-02}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:AUDIT-05}}, {{xref:AUDIT-09}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define denylist, hashing fields, and export rule.
intermediate: Required. Define masking/unmask access rules and telemetry.
advanced: Required. Add tier overrides and stricter retention interaction rationale.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, allowed fields, hash method, unmask

access, default masked, tier overrides, optional metric, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If fields.denylist is UNKNOWN → block Completeness Gate.
If hash.fields is UNKNOWN → block Completeness Gate.
If export.rule is UNKNOWN → block Completeness Gate.
If retention.rule is UNKNOWN → block Completeness Gate.
If telemetry.redaction_applied_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.AUDIT
Pass conditions:
required_fields_present == true
hashing_and_denylist_defined == true
export_redaction_defined == true
retention_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

AUDIT-09

AUDIT-09 — Alerts & Anomaly Detection (suspicious patterns)
Header Block
template_id: AUDIT-09
title: Alerts & Anomaly Detection (suspicious patterns)
type: audit_alerts_anomaly_detection
template_version: 1.0.0
output_path: 10_app/audit/AUDIT-09_Alerts_Anomaly_Detection.md
compliance_gate_id: TMP-05.PRIMARY.AUDIT
upstream_dependencies: ["AUDIT-01", "AUDIT-07", "SEC-06"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "AUDIT-01", "AUDIT-07", "SEC-06", "IAM-10"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical alerting and anomaly detection rules built on audit data: suspicious patterns, thresholds, routing, and runbooks. This template must align with security monitoring and privileged action audit requirements.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Audit event catalog: {{xref:AUDIT-01}} | OPTIONAL
Privileged action audit: {{xref:AUDIT-07}} | OPTIONAL
Security monitoring baseline: {{xref:SEC-06}} | OPTIONAL
Access observability: {{xref:IAM-10}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Detection rule registry (rule_id list)
rule_id (stable identifier)
Event types used (AUDIT-01 refs)
Pattern/condition (threshold, sequence)
Severity (low/med/high/UNKNOWN)
Routing (oncall/security)
Suppression/dedupe rules
Runbook reference (SEC-10/AUDIT-10)
Telemetry requirements (alerts fired, false positives)

Optional Fields
ML-based detection notes | OPTIONAL
Tuning process | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Rules must be explainable and actionable (not black box only).
Every rule must have routing and a runbook.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Rule Registry Summary
   total_rules: {{meta.total}}
   notes: {{meta.notes}} | OPTIONAL
2. Rules (repeat per rule_id)
   Rule
   rule_id: {{rules[0].rule_id}}
   event_types: {{rules[0].event_types}}
   condition: {{rules[0].condition}}
   severity: {{rules[0].severity}}
   routing: {{rules[0].routing}}
   suppression_rule: {{rules[0].suppression_rule}}
   runbook_ref: {{rules[0].runbook_ref}}
   telemetry_metric: {{rules[0].telemetry_metric}}
   false_positive_tracking: {{rules[0].false_positive_tracking}} | OPTIONAL
   tuning_notes: {{rules[0].tuning_notes}} | OPTIONAL
   open_questions:
   {{rules[0].open_questions[0]}} | OPTIONAL

(Repeat per rule.)

3. References
   Security monitoring: {{xref:SEC-06}} | OPTIONAL
   Forensics runbooks: {{xref:AUDIT-10}} | OPTIONAL

Cross-References
Upstream: {{xref:AUDIT-01}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:AUDIT-10}}, {{xref:SEC-05}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define rules with condition, routing, runbook ref, telemetry.
intermediate: Required. Define suppression/dedupe and false positive tracking.
advanced: Required. Add tuning process and ML notes and stricter evidence pointers.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, notes, false positive tracking, tuning notes, ML notes, tuning process, open_questions

If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If rules[*].rule_id is UNKNOWN → block Completeness Gate.*
*If rules[*].condition is UNKNOWN → block Completeness Gate.
If rules[*].routing is UNKNOWN → block Completeness Gate.*
*If rules[*].runbook_ref is UNKNOWN → block Completeness Gate.
If rules[*].telemetry_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.AUDIT
Pass conditions:
required_fields_present == true
rule_registry_defined == true
each_rule_has_routing_and_runbook == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

AUDIT-10

AUDIT-10 — Forensics Runbooks (incident support procedures)
Header Block
template_id: AUDIT-10
title: Forensics Runbooks (incident support procedures)
type: audit_forensics_runbooks
template_version: 1.0.0
output_path: 10_app/audit/AUDIT-10_Forensics_Runbooks.md
compliance_gate_id: TMP-05.PRIMARY.AUDIT
upstream_dependencies: ["AUDIT-06", "SEC-05", "AUDIT-09"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "AUDIT-06", "SEC-05", "AUDIT-09", "SEC-10"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical forensics runbooks used during security/privacy incidents: evidence collection, query recipes, export/chain-of-custody steps, and handoffs. This template must align with investigation workflow and incident response plans.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Investigation workflow: {{xref:AUDIT-06}} | OPTIONAL
Incident response plan: {{xref:SEC-05}} | OPTIONAL
Audit anomaly rules: {{xref:AUDIT-09}} | OPTIONAL
Security runbooks: {{xref:SEC-10}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Runbook registry (runbook_id list)
runbook_id (stable identifier)
Incident type binding (SEC-05 type)
Trigger (alert_id/rule_id)
Evidence capture checklist
Standard query recipes (what to query)
Export steps (format, hash/sign)
Chain-of-custody steps
Escalation/handoff rules
Telemetry requirements (runbook invoked, time-to-evidence)

Optional Fields
External counsel handoff | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Exports must be integrity-protected; chain-of-custody must be maintained.
Runbooks must be executable and step-by-step.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Registry Summary
   total_runbooks: {{meta.total}}
   notes: {{meta.notes}} | OPTIONAL
2. Runbooks (repeat)
   Runbook
   runbook_id: {{books[0].runbook_id}}
   incident_type: {{books[0].incident_type}}
   trigger: {{books[0].trigger}}
   evidence_checklist: {{books[0].evidence_checklist}}
   query_recipes:
   {{books[0].query_recipes[0]}}
   {{books[0].query_recipes[1]}} | OPTIONAL
   export_steps: {{books[0].export_steps}}
   chain_of_custody: {{books[0].chain_of_custody}}
   handoff_rule: {{books[0].handoff_rule}}
   telemetry_metric: {{books[0].telemetry_metric}}
   counsel_handoff: {{books[0].counsel_handoff}} | OPTIONAL
   open_questions:
   {{books[0].open_questions[0]}} | OPTIONAL

(Repeat per runbook.)

3. References
   Investigation workflow: {{xref:AUDIT-06}} | OPTIONAL
   Security IR: {{xref:SEC-05}} | OPTIONAL
   Security runbooks: {{xref:SEC-10}} | OPTIONAL

Cross-References
Upstream: {{xref:AUDIT-06}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:SEC-05}}, {{xref:COMP-10}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define runbooks with evidence checklist and export steps.
intermediate: Required. Add query recipes and escalation/handoff rules and telemetry.
advanced: Required. Add counsel handoff details and tighter trigger mappings and automation hooks.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, meta notes, optional query recipe, counsel handoff, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If books[*].runbook_id is UNKNOWN → block Completeness Gate.
If books[*].evidence_checklist is UNKNOWN → block Completeness Gate.
If books[*].export_steps is UNKNOWN → block Completeness Gate.
If books[*].chain_of_custody is UNKNOWN → block Completeness Gate.
If books[*].telemetry_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.AUDIT
Pass conditions:
required_fields_present == true
runbooks_defined == true
evidence_and_export_defined == true
chain_of_custody_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

Compliance & Risk (COMP)

COMP-01

COMP-01 — Compliance Scope (frameworks, in/out scope)
Header Block
template_id: COMP-01
title: Compliance Scope (frameworks, in/out scope)
type: compliance_scope
template_version: 1.0.0
output_path: 10_app/compliance/COMP-01_Compliance_Scope.md
compliance_gate_id: TMP-05.PRIMARY.COMP
upstream_dependencies: ["SEC-01", "PRIV-01", "PRD-01"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SEC-01", "PRIV-01", "PRD-01", "IXS-01"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical compliance scope: which frameworks/regulations apply, what is in-scope and out-of-scope, and what parts of the system are covered. This document anchors the compliance series and must not claim compliance certifications unless explicitly provided.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Security overview: {{xref:SEC-01}} | OPTIONAL
Data inventory: {{xref:PRIV-01}} | OPTIONAL
Product overview: {{xref:PRD-01}} | OPTIONAL
Integration inventory: {{xref:IXS-01}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Frameworks/regulations list (soc2/gdpr/pci/UNKNOWN)
In-scope systems/surfaces
Out-of-scope statement (explicit)
Assumptions (what must be true)
Compliance ownership (who owns)
Review cadence (when updated)
Evidence storage location (where artifacts live)
References to downstream compliance docs (COMP-02..COMP-10)

Optional Fields
Target certification goals | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
Do not claim compliance status or certification unless provided by inputs.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Frameworks / Regulations
   frameworks: {{scope.frameworks}}
2. Scope Boundaries
   in_scope:
   {{scope.in[0]}}
   {{scope.in[1]}}
   out_of_scope:
   {{scope.out[0]}}
   {{scope.out[1]}}
3. Assumptions
   {{assumptions[0]}}
   {{assumptions[1]}} | OPTIONAL
4. Ownership & Cadence
   owner: {{gov.owner}}
   review_cadence: {{gov.review_cadence}}
5. Evidence Storage
   evidence_location: {{evidence.location}}
6. References
   Control matrix: {{xref:COMP-02}} | OPTIONAL
   Vendor risk: {{xref:COMP-03}} | OPTIONAL
   Regulatory requirements: {{xref:COMP-06}} | OPTIONAL

Cross-References
Upstream: {{xref:SEC-01}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:COMP-02}}, {{xref:COMP-09}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define frameworks list and in/out scope and owner.
intermediate: Required. Define evidence location and review cadence.
advanced: Required. Add certification goals and explicit assumptions and strict references.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, certification goals, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If scope.frameworks is UNKNOWN → block Completeness Gate.
If scope.in is UNKNOWN → block Completeness Gate.

If gov.owner is UNKNOWN → block Completeness Gate.
If evidence.location is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.COMP
Pass conditions:
required_fields_present == true
frameworks_and_scope_defined == true
ownership_and_evidence_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

COMP-02

COMP-02 — Control Matrix (control_id → requirement → evidence)
Header Block
template_id: COMP-02
title: Control Matrix (control_id → requirement → evidence)
type: compliance_control_matrix
template_version: 1.0.0
output_path: 10_app/compliance/COMP-02_Control_Matrix.md
compliance_gate_id: TMP-05.PRIMARY.COMP
upstream_dependencies: ["COMP-01", "SEC-03", "PRIV-07"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "COMP-01", "SEC-03", "PRIV-07", "AUDIT-04"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Create the canonical control matrix mapping compliance controls to security/privacy requirements and the evidence needed to prove them. This document is used for audits and internal assurance and must align with the security baseline controls and privacy-by-design checks.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Compliance scope: {{xref:COMP-01}} | OPTIONAL
Security controls baseline: {{xref:SEC-03}} | OPTIONAL
Privacy checklist: {{xref:PRIV-07}} | OPTIONAL
Audit integrity model: {{xref:AUDIT-04}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Control registry (control_id list)
control_id (stable identifier)
Framework mapping (which framework clause)
Requirement statement (what must be true)
Owner (team/role)
Evidence artifacts list (reports/logs/config)
Evidence cadence (how often)
Test/verification method (test/manual/report)
Status (planned/in_place/UNKNOWN)
Exception process reference (COMP-08)

Optional Fields
Automated evidence collection support | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Every control must have evidence and a cadence; no “TBD” without an exception record.
Evidence must be storable and reviewable.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Registry Summary
   total_controls: {{meta.total}}
   notes: {{meta.notes}} | OPTIONAL
2. Controls (repeat per control_id)
   Control
   control_id: {{controls[0].control_id}}
   framework_clause: {{controls[0].framework_clause}}
   requirement: {{controls[0].requirement}}
   owner: {{controls[0].owner}}
   evidence_artifacts: {{controls[0].evidence_artifacts}}
   evidence_cadence: {{controls[0].evidence_cadence}}
   verification_method: {{controls[0].verification_method}}
   status: {{controls[0].status}}
   exceptions_ref: {{controls[0].exceptions_ref}} (expected: {{xref:COMP-08}}) | OPTIONAL
   automation_notes: {{controls[0].automation_notes}} | OPTIONAL

(Repeat per control.)

3. References
   Exception management: {{xref:COMP-08}} | OPTIONAL
   Evidence collection plan: {{xref:COMP-09}} | OPTIONAL

Cross-References
Upstream: {{xref:COMP-01}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:COMP-09}}, {{xref:COMP-10}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define control registry and requirement statements and evidence artifacts.
intermediate: Required. Define cadence, owners, and verification methods.
advanced: Required. Add automation notes and strict framework clause mapping and status rigor.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, notes, exceptions ref, automation notes, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If controls[*].control_id is UNKNOWN → block Completeness Gate.
If controls[].requirement is UNKNOWN → block Completeness Gate.
If controls[].evidence_artifacts is UNKNOWN → block Completeness Gate.
If controls[].evidence_cadence is UNKNOWN → block Completeness Gate.
If controls[*].verification_method is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.COMP
Pass conditions:
required_fields_present == true
control_registry_defined == true
evidence_and_cadence_defined == true
verification_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

COMP-03

COMP-03 — Vendor Risk Management (third-party reviews, DPAs)
Header Block
template_id: COMP-03
title: Vendor Risk Management (third-party reviews, DPAs)
type: compliance_vendor_risk_management
template_version: 1.0.0
output_path: 10_app/compliance/COMP-03_Vendor_Risk_Management.md
compliance_gate_id: TMP-05.PRIMARY.COMP
upstream_dependencies: ["IXS-01", "PRIV-06", "COMP-01"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "IXS-01", "PRIV-06", "COMP-01", "IXS-08"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical vendor risk management process: how third parties are assessed, approved, monitored, and re-reviewed, including security questionnaires, DPAs, and evidence storage. This template must align with integration inventory and data sharing map.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Integration inventory: {{xref:IXS-01}} | OPTIONAL
Data sharing map: {{xref:PRIV-06}} | OPTIONAL
Compliance scope: {{xref:COMP-01}} | OPTIONAL
Integration security baseline: {{xref:IXS-08}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Vendor tiering model (low/med/high risk)
Vendors in scope (provider_id list)
Pre-engagement review requirements (questionnaire, SOC2 report)
DPA requirement rule (when needed)
Approval roles (security/legal)
Re-review cadence (annual/UNKNOWN)
Incident notification expectations (vendor must notify)
Evidence storage location
Telemetry requirements (vendors reviewed, overdue)

Optional Fields
Continuous monitoring approach | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
High-risk vendors must have stricter review and DPAs where required.
Vendor approvals must be recorded and auditable.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Tiering Model
   tiers: {{tiers.model}}
   tiering_rule: {{tiers.rule}} | OPTIONAL
2. Vendors In Scope
   vendors: {{vendors.list}}
3. Review Requirements
   required_artifacts: {{review.artifacts}}
   minimum_controls: {{review.minimum_controls}} | OPTIONAL
4. DPAs
   dpa_required_rule: {{dpa.required_rule}}
   dpa_storage_location: {{dpa.storage_location}} | OPTIONAL
5. Approvals
   approver_roles: {{approve.roles}}
   approval_workflow: {{approve.workflow}} | OPTIONAL
6. Re-Review
   cadence: {{recheck.cadence}}
   overdue_rule: {{recheck.overdue_rule}} | OPTIONAL
7. Incident Notifications
   vendor_notify_rule: {{incident.vendor_notify_rule}}
   contact_method: {{incident.contact_method}} | OPTIONAL
8. Evidence Storage
   evidence_location: {{evidence.location}}
9. Telemetry
   vendors_reviewed_metric: {{telemetry.reviewed_metric}}
   vendors_overdue_metric: {{telemetry.overdue_metric}} | OPTIONAL
10. References
    Integration inventory: {{xref:IXS-01}} | OPTIONAL
    Data sharing map: {{xref:PRIV-06}} | OPTIONAL
    Security baseline: {{xref:IXS-08}} | OPTIONAL

Cross-References
Upstream: {{xref:COMP-01}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:COMP-05}}, {{xref:COMP-09}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define tiering and vendor list and evidence location.

intermediate: Required. Define review artifacts, DPA rule, approvals, cadence.
advanced: Required. Add continuous monitoring and strict overdue enforcement and incident notification detail.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, tiering rule, minimum controls, dpa storage, approval workflow, overdue rule, contact method, optional metrics, continuous monitoring, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If tiers.model is UNKNOWN → block Completeness Gate.
If vendors.list is UNKNOWN → block Completeness Gate.
If dpa.required_rule is UNKNOWN → block Completeness Gate.
If evidence.location is UNKNOWN → block Completeness Gate.
If telemetry.reviewed_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.COMP
Pass conditions:
required_fields_present == true
tiering_and_vendor_list_defined == true
review_and_approval_defined == true
evidence_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

COMP-04

COMP-04 — Policy & Training Requirements (who must do what)
Header Block
template_id: COMP-04
title: Policy & Training Requirements (who must do what)
type: compliance_policy_training_requirements
template_version: 1.0.0
output_path: 10_app/compliance/COMP-04_Policy_Training_Requirements.md
compliance_gate_id: TMP-05.PRIMARY.COMP
upstream_dependencies: ["COMP-01", "SEC-07", "PRIV-07"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "COMP-01", "SEC-07", "PRIV-07", "IAM-06"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical set of policies and trainings required for the organization/team operating this product: what must exist, who must complete training, cadence, and evidence of completion. This template is used for audits and internal assurance.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Compliance scope: {{xref:COMP-01}} | OPTIONAL
Secure SDLC policy: {{xref:SEC-07}} | OPTIONAL
Privacy checklist: {{xref:PRIV-07}} | OPTIONAL
Privileged access policy: {{xref:IAM-06}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Policy registry (policy_id list)
policy_id (stable identifier)
Policy name
Who is required (roles)
Training required (yes/no/UNKNOWN)
Training cadence (annual/onboarding/UNKNOWN)
Evidence required (completion record)
Owner (who maintains)
Enforcement rule (what happens if not completed)
Telemetry requirements (completion rate, overdue)

Optional Fields
External vendor training requirements | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Policies must have owners and evidence requirements.
Privileged roles should have stricter training requirements.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Registry Summary
   total_policies: {{meta.total}}
   notes: {{meta.notes}} | OPTIONAL
2. Policies (repeat)
   Policy
   policy_id: {{policies[0].policy_id}}
   name: {{policies[0].name}}
   required_roles: {{policies[0].required_roles}}
   training_required: {{policies[0].training_required}}
   training_cadence: {{policies[0].training_cadence}}
   evidence: {{policies[0].evidence}}
   owner: {{policies[0].owner}}
   enforcement: {{policies[0].enforcement}}
   telemetry_metric: {{policies[0].telemetry_metric}}
   open_questions:
   {{policies[0].open_questions[0]}} | OPTIONAL

(Repeat per policy.)

3. References
   Secure SDLC: {{xref:SEC-07}} | OPTIONAL
   Incident response: {{xref:SEC-05}} | OPTIONAL
   Privacy checklist: {{xref:PRIV-07}} | OPTIONAL

Cross-References
Upstream: {{xref:COMP-01}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:COMP-09}}, {{xref:COMP-10}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define policy list, required roles, cadence, evidence.
intermediate: Required. Define enforcement rules and telemetry and ownership.
advanced: Required. Add vendor training and stricter privileged role coupling and audit-ready evidence storage.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, notes, open_questions, vendor training

If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If policies[*].policy_id is UNKNOWN → block Completeness Gate.*
*If policies[*].required_roles is UNKNOWN → block Completeness Gate.
If policies[*].evidence is UNKNOWN → block Completeness Gate.*
*If policies[*].owner is UNKNOWN → block Completeness Gate.
If telemetry requirements are UNKNOWN → block Completeness Gate (telemetry_metric per policy).

Completeness Gate
Gate ID: TMP-05.PRIMARY.COMP
Pass conditions:
required_fields_present == true
policy_registry_defined == true
roles_and_cadence_defined == true
evidence_and_owners_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

COMP-05

COMP-05 — Data Processing Agreements & Records (RoPA, DPA pointers)
Header Block
template_id: COMP-05
title: Data Processing Agreements & Records (RoPA, DPA pointers)
type: compliance_data_processing_agreements_records
template_version: 1.0.0
output_path: 10_app/compliance/COMP-05_Data_Processing_Agreements_Records.md
compliance_gate_id: TMP-05.PRIMARY.COMP
upstream_dependencies: ["PRIV-06", "COMP-03", "IXS-01"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "PRIV-06", "COMP-03", "IXS-01", "PRIV-01"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical record-keeping for data processing: RoPA-style records of processing, DPA pointers per vendor, and where these records live. This template must align with data sharing maps and vendor risk processes.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Data sharing map: {{xref:PRIV-06}} | OPTIONAL
Vendor risk management: {{xref:COMP-03}} | OPTIONAL
Integration inventory: {{xref:IXS-01}} | OPTIONAL
Data inventory: {{xref:PRIV-01}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Processing record registry (record_id list)
record_id (stable identifier)
Processing activity name
Data categories processed (data_class refs)
Purpose (why)
Recipients/vendors (provider_id/service_id)
Legal basis/consent ref (if applicable)
Retention policy ref (PRIV-05)
DPA pointer (where DPA stored)
Owner (who maintains record)
Review cadence
Telemetry requirements (records complete, missing DPA)

Optional Fields
Cross-border transfer notes | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-PII-REDACTION]}} | OPTIONAL
Every external processor should have a DPA pointer (or explicit exception).
Records must be kept current and review cadence enforced.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Registry Summary
   total_records: {{meta.total}}
   notes: {{meta.notes}} | OPTIONAL
2. Records (repeat)
   Record
   record_id: {{records[0].record_id}}
   activity_name: {{records[0].activity_name}}
   data_categories: {{records[0].data_categories}}
   purpose: {{records[0].purpose}}
   recipients: {{records[0].recipients}}
   legal_basis_ref: {{records[0].legal_basis_ref}} | OPTIONAL
   retention_ref: {{records[0].retention_ref}} (expected: {{xref:PRIV-05}}) | OPTIONAL
   dpa_pointer: {{records[0].dpa_pointer}}
   owner: {{records[0].owner}}
   review_cadence: {{records[0].review_cadence}}
   telemetry_metric: {{records[0].telemetry_metric}}
   transfer_notes: {{records[0].transfer_notes}} | OPTIONAL
   open_questions:
   {{records[0].open_questions[0]}} | OPTIONAL

(Repeat per record.)

3. References
   Vendor risk: {{xref:COMP-03}} | OPTIONAL
   Data sharing: {{xref:PRIV-06}} | OPTIONAL
   Privacy retention: {{xref:PRIV-05}} | OPTIONAL

Cross-References
Upstream: {{xref:PRIV-06}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:COMP-09}}, {{xref:COMP-10}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define records with purpose, recipients, and DPA pointers.
intermediate: Required. Add retention refs and cadence and telemetry.
advanced: Required. Add transfer notes and stricter completeness enforcement and exception records.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, legal basis ref, retention ref, transfer notes, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If records[*].record_id is UNKNOWN → block Completeness Gate.
If records[*].purpose is UNKNOWN → block Completeness Gate.
If records[*].recipients is UNKNOWN → block Completeness Gate.
If records[*].dpa_pointer is UNKNOWN → block Completeness Gate.
If records[*].telemetry_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.COMP
Pass conditions:
required_fields_present == true
records_defined == true
dpa_pointers_defined == true
cadence_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

COMP-06

COMP-06 — Regulatory Requirements (CAN-SPAM, PCI, SOC2, HIPAA, etc.)
Header Block
template_id: COMP-06
title: Regulatory Requirements (CAN-SPAM, PCI, SOC2, HIPAA, etc.)
type: compliance_regulatory_requirements
template_version: 1.0.0
output_path: 10_app/compliance/COMP-06_Regulatory_Requirements.md
compliance_gate_id: TMP-05.PRIMARY.COMP
upstream_dependencies: ["COMP-01", "PRIV-02", "PAY-09", "NOTIF-04"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "COMP-01", "PRIV-02", "PAY-09", "NOTIF-04", "AUDIT-05"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical list of applicable regulatory requirements and what the system must do to comply (at a requirements level). This template must not claim certifications, and must link requirements to the relevant system policies (payments, notifications, retention, audit).

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Compliance scope: {{xref:COMP-01}} | OPTIONAL
PII classification: {{xref:PRIV-02}} | OPTIONAL
Payments security: {{xref:PAY-09}} | OPTIONAL
Notification send policy: {{xref:NOTIF-04}} | OPTIONAL
Audit retention/access: {{xref:AUDIT-05}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Regulation registry (reg_id list)
reg_id (stable identifier)
Regulation/framework name
Applicability statement (why applies)
System requirements list (what must be done)
Evidence expectations (what proves compliance)
Owner (who ensures)
Review cadence
Telemetry requirements (violations, compliance checks)

Optional Fields
Jurisdiction scope notes | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
Do not claim “compliant” unless proven; describe “requirements” only.
Each regulation entry must map to at least one system policy/doc reference.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Registry Summary
   total_regs: {{meta.total}}
   notes: {{meta.notes}} | OPTIONAL
2. Regulations (repeat)
   Regulation
   reg_id: {{regs[0].reg_id}}
   name: {{regs[0].name}}
   applicability: {{regs[0].applicability}}
   requirements: {{regs[0].requirements}}
   evidence: {{regs[0].evidence}}
   owner: {{regs[0].owner}}
   review_cadence: {{regs[0].review_cadence}}
   telemetry_metric: {{regs[0].telemetry_metric}}
   jurisdiction_notes: {{regs[0].jurisdiction_notes}} | OPTIONAL
   open_questions:
   {{regs[0].open_questions[0]}} | OPTIONAL

(Repeat per regulation.)

3. References
   Payments security: {{xref:PAY-09}} | OPTIONAL
   Notification policy: {{xref:NOTIF-04}} | OPTIONAL
   Retention/deletion: {{xref:PRIV-05}} | OPTIONAL
   Audit retention: {{xref:AUDIT-05}} | OPTIONAL

Cross-References
Upstream: {{xref:COMP-01}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:COMP-02}}, {{xref:COMP-09}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define reg list, applicability, and requirements.
intermediate: Required. Add evidence, owners, cadence, telemetry.
advanced: Required. Add jurisdiction scope notes and stricter policy/doc references per requirement.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, notes, jurisdiction notes, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If regs[*].reg_id is UNKNOWN → block Completeness Gate.
If regs[].requirements is UNKNOWN → block Completeness Gate.
If regs[*].evidence is UNKNOWN → block Completeness Gate.
If regs[].owner is UNKNOWN → block Completeness Gate.
If regs[*].telemetry_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.COMP
Pass conditions:
required_fields_present == true
reg_registry_defined == true
requirements_and_evidence_defined == true
owners_and_cadence_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

COMP-07

COMP-07 — Risk Assessments (periodic, triggers, owners)
Header Block
template_id: COMP-07
title: Risk Assessments (periodic, triggers, owners)
type: compliance_risk_assessments
template_version: 1.0.0
output_path: 10_app/compliance/COMP-07_Risk_Assessments.md
compliance_gate_id: TMP-05.PRIMARY.COMP
upstream_dependencies: ["TMA-04", "COMP-01", "SEC-03"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "COMP-01", "TMA-04", "SEC-03", "COMP-08"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical risk assessment process: how risks are identified, assessed, tracked, reviewed, and re-assessed—covering security/privacy/compliance risks and vendor risks. This template must align with threat risk register and exception management.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Compliance scope: {{xref:COMP-01}} | OPTIONAL
Threat risk register: {{xref:TMA-04}} | OPTIONAL
Security baseline controls: {{xref:SEC-03}} | OPTIONAL
Exception management: {{xref:COMP-08}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Risk categories list (security/privacy/compliance/vendor)
Assessment cadence (quarterly/annual/UNKNOWN)
Trigger events (new vendor, new feature, incident)
Assessment workflow steps
Rating model (likelihood/impact)
Ownership roles (who assesses, who approves)
Documentation/evidence requirements
Escalation rules (high risk)
Telemetry requirements (assessments completed, overdue)

Optional Fields
Tooling/location for risk register | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Assessments must be recorded and reviewable; not informal.
High risks must have action plans or acceptance records.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Categories
   categories: {{risk.categories}}
2. Cadence
   cadence: {{cadence.value}}
   trigger_events: {{cadence.triggers}}
3. Workflow
   steps:
   {{workflow.steps[0]}}
   {{workflow.steps[1]}}
   {{workflow.steps[2]}} | OPTIONAL
4. Rating Model
   model: {{rating.model}}
   definitions: {{rating.definitions}} | OPTIONAL
5. Ownership
   assessor_roles: {{owners.assessor_roles}}
   approver_roles: {{owners.approver_roles}} | OPTIONAL
6. Evidence
   required_artifacts: {{evidence.artifacts}}
   storage_location: {{evidence.storage_location}} | OPTIONAL
7. Escalation
   high_risk_rule: {{esc.high_risk_rule}}
   acceptance_ref: {{xref:COMP-08}} | OPTIONAL
8. Telemetry
   assessments_completed_metric: {{telemetry.completed_metric}}
   assessments_overdue_metric: {{telemetry.overdue_metric}} | OPTIONAL
9. References
   Risk register: {{xref:TMA-04}} | OPTIONAL
   Vendor risk: {{xref:COMP-03}} | OPTIONAL
   Exceptions: {{xref:COMP-08}} | OPTIONAL

Cross-References
Upstream: {{xref:COMP-01}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:COMP-10}}, {{xref:COMP-09}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define categories, cadence, workflow steps, and high-risk rule.

intermediate: Required. Define ownership and evidence artifacts and telemetry.
advanced: Required. Add tooling/location details and stricter triggers and acceptance linkage.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, definitions, approver roles, storage location, overdue metric, tooling/location, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If risk.categories is UNKNOWN → block Completeness Gate.
If cadence.value is UNKNOWN → block Completeness Gate.
If workflow.steps[0] is UNKNOWN → block Completeness Gate.
If esc.high_risk_rule is UNKNOWN → block Completeness Gate.
If telemetry.completed_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.COMP
Pass conditions:
required_fields_present == true
cadence_and_triggers_defined == true
workflow_and_rating_defined == true
ownership_and_evidence_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

COMP-08

COMP-08 — Exception Management (waivers, expiries, reviews)
Header Block
template_id: COMP-08
title: Exception Management (waivers, expiries, reviews)
type: compliance_exception_management
template_version: 1.0.0
output_path: 10_app/compliance/COMP-08_Exception_Management.md
compliance_gate_id: TMP-05.PRIMARY.COMP
upstream_dependencies: ["SEC-08", "COMP-02"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "SEC-08", "COMP-02", "AUDIT-07"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical process for compliance exceptions/waivers: request, approval, expiry, review, and audit logging. This template coordinates with security exceptions but covers compliance control deviations broadly.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Security exceptions process: {{xref:SEC-08}} | OPTIONAL
Control matrix: {{xref:COMP-02}} | OPTIONAL
Privileged audit: {{xref:AUDIT-07}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Exception request schema (fields)
Approval roles (compliance/security/legal)
Expiry requirement (max duration)
Compensating controls requirement
Evidence requirement (why approved)
Review cadence (re-approval)
Revocation process
Tracking system/location
Audit logging requirements
Telemetry requirements (active exceptions, overdue)

Optional Fields
Emergency waivers process | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
No waivers without expiry and documented risk.
Approvals and evidence must be recorded and auditable.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Request Schema
   fields_required: {{schema.fields_required}}
2. Approvals
   approver_roles: {{approve.roles}}
   workflow: {{approve.workflow}} | OPTIONAL
3. Expiry
   max_duration_days: {{expiry.max_duration_days}}
   renewal_policy: {{expiry.renewal_policy}} | OPTIONAL
4. Compensating Controls
   required: {{comp.required}}
   documentation_rule: {{comp.doc_rule}} | OPTIONAL
5. Evidence
   evidence_fields: {{evidence.fields}}
6. Reviews
   review_cadence: {{review.cadence}}
   overdue_rule: {{review.overdue_rule}} | OPTIONAL
7. Revocation
   revoke_process: {{revoke.process}}
8. Tracking
   system: {{track.system}}
   storage_location: {{track.storage_location}} | OPTIONAL
9. Audit
   audit_required: {{audit.required}}
   audit_events: {{audit.events}} | OPTIONAL
10. Telemetry
    active_exceptions_metric: {{telemetry.active_metric}}
    overdue_exceptions_metric: {{telemetry.overdue_metric}} | OPTIONAL
11. References
    Security exceptions: {{xref:SEC-08}} | OPTIONAL
    Control matrix: {{xref:COMP-02}} | OPTIONAL

Cross-References
Upstream: {{xref:COMP-02}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:COMP-09}}, {{xref:COMP-10}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define schema fields, approvers, max duration, revoke process.
intermediate: Required. Define evidence fields, reviews, audit, telemetry.
advanced: Required. Add emergency process and strict overdue enforcement and cross-links to controls.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, workflow, renewal policy, doc rule, overdue rule, storage location, audit events, optional metrics, emergency process, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If schema.fields_required is UNKNOWN → block Completeness Gate.
If approve.roles is UNKNOWN → block Completeness Gate.
If expiry.max_duration_days is UNKNOWN → block Completeness Gate.
If revoke.process is UNKNOWN → block Completeness Gate.
If telemetry.active_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.COMP
Pass conditions:
required_fields_present == true
approvals_and_expiry_defined == true
evidence_and_reviews_defined == true
audit_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

COMP-09

COMP-09 — Evidence Collection Plan (artifacts, cadence, storage)
Header Block
template_id: COMP-09
title: Evidence Collection Plan (artifacts, cadence, storage)
type: compliance_evidence_collection_plan
template_version: 1.0.0
output_path: 10_app/compliance/COMP-09_Evidence_Collection_Plan.md
compliance_gate_id: TMP-05.PRIMARY.COMP
upstream_dependencies: ["COMP-02", "SEC-07", "AUDIT-04"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "COMP-02", "SEC-07", "AUDIT-04", "PRIV-10"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical plan for collecting and storing compliance evidence artifacts: what artifacts are collected for which controls, how often, who collects them, and where they are stored. This template must align with the control matrix and Secure SDLC evidence outputs.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Control matrix: {{xref:COMP-02}} | OPTIONAL
Secure SDLC evidence outputs: {{xref:SEC-07}} | OPTIONAL
Audit integrity: {{xref:AUDIT-04}} | OPTIONAL
Privacy metrics/audits: {{xref:PRIV-10}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Evidence registry (evidence_id list)
evidence_id (stable identifier)
Linked control_id (COMP-02)
Artifact description (what is collected)
Source system/tool (CI, SIEM, ticketing)
Collection cadence
Owner/collector role
Storage location (bucket/wiki)
Integrity rule (hash/sign)
Access control rule (who can view)
Telemetry requirements (evidence collected on time)

Optional Fields
Automation support notes | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Evidence must be immutable or tamper-evident where feasible.
Cadence must be enforceable; missed collections must be visible.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Registry Summary
   total_evidence_items: {{meta.total}}
   notes: {{meta.notes}} | OPTIONAL
2. Evidence Items (repeat)
   Evidence
   evidence_id: {{items[0].evidence_id}}
   control_id: {{items[0].control_id}}
   artifact: {{items[0].artifact}}
   source: {{items[0].source}}
   cadence: {{items[0].cadence}}
   owner: {{items[0].owner}}
   storage_location: {{items[0].storage_location}}
   integrity_rule: {{items[0].integrity_rule}}
   access_rule: {{items[0].access_rule}}
   telemetry_metric: {{items[0].telemetry_metric}}
   automation_notes: {{items[0].automation_notes}} | OPTIONAL
   open_questions:
   {{items[0].open_questions[0]}} | OPTIONAL

(Repeat per evidence.)

3. References
   Control matrix: {{xref:COMP-02}} | OPTIONAL
   Audit integrity: {{xref:AUDIT-04}} | OPTIONAL
   Exception management: {{xref:COMP-08}} | OPTIONAL

Cross-References
Upstream: {{xref:COMP-02}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:COMP-10}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define evidence items with control linkage, cadence, storage.

intermediate: Required. Define integrity/access rules and telemetry metrics.
advanced: Required. Add automation notes and strict tamper-evidence alignment and escalation for missed cadence.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, notes, automation notes, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If items[*].evidence_id is UNKNOWN → block Completeness Gate.
If items[*].control_id is UNKNOWN → block Completeness Gate.
If items[*].cadence is UNKNOWN → block Completeness Gate.
If items[*].storage_location is UNKNOWN → block Completeness Gate.
If items[*].telemetry_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.COMP
Pass conditions:
required_fields_present == true
evidence_registry_defined == true
control_linkage_defined == true
cadence_and_storage_defined == true
integrity_and_access_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true

COMP-10

COMP-10 — Compliance Reporting & Audits (internal/external audits)
Header Block
template_id: COMP-10
title: Compliance Reporting & Audits (internal/external audits)
type: compliance_reporting_audits
template_version: 1.0.0
output_path: 10_app/compliance/COMP-10_Compliance_Reporting_Audits.md
compliance_gate_id: TMP-05.PRIMARY.COMP
upstream_dependencies: ["COMP-02", "COMP-09", "PRIV-10"]
inputs_required: ["SPEC_INDEX", "DOMAIN_MAP", "GLOSSARY", "STANDARDS_INDEX", "COMP-02", "COMP-09", "PRIV-10", "AUDIT-06"]
required_by_skill_level: {"beginner": true, "intermediate": true, "advanced": true}

Purpose
Define the canonical compliance reporting and audit execution process: internal audit cadence, external audit readiness, what reports are produced, and how evidence is packaged and delivered. This template must align with evidence collection plans and investigation workflows.

Inputs Required
SPEC_INDEX: {{spec.index}}
DOMAIN_MAP: {{domain.map}} | OPTIONAL
GLOSSARY: {{glossary.terms}} | OPTIONAL
STANDARDS_INDEX: {{standards.index}} | OPTIONAL
Control matrix: {{xref:COMP-02}} | OPTIONAL
Evidence collection plan: {{xref:COMP-09}} | OPTIONAL
Privacy metrics/audits: {{xref:PRIV-10}} | OPTIONAL
Investigation workflow: {{xref:AUDIT-06}} | OPTIONAL
Existing docs/notes: {{inputs.notes}} | OPTIONAL

Required Fields
Reporting types list (internal audit, external audit, compliance report)
Cadence (quarterly/annual/UNKNOWN)
Owners (who prepares)
Evidence packaging process (how gathered)
Audit request intake workflow (external requests)
Scope confirmation process (what included)
Findings tracking process (issues → remediation)
Communication rules (who receives reports)
Telemetry requirements (audit completion, findings closed)

Optional Fields
Auditor access rules | OPTIONAL
Open questions | OPTIONAL

Rules
Must align to: {{standards.rules[STD-SECURITY]}} | OPTIONAL
Reports must be based on evidence artifacts, not statements.
Findings must be tracked to closure with owners and due dates.
If a required field is not provided by inputs, write UNKNOWN unless explicitly disallowed.

Output Format

1. Reporting Types
   types: {{report.types}}
2. Cadence & Owners
   cadence: {{cadence.value}}
   owners: {{owners.list}}
3. Evidence Packaging
   process: {{evidence.process}}
   packaging_location: {{evidence.location}} | OPTIONAL
4. Audit Intake
   intake_steps: {{audit.intake_steps}}
   scope_confirm_rule: {{audit.scope_confirm_rule}} | OPTIONAL
5. Findings
   tracking_system: {{findings.system}}
   workflow: {{findings.workflow}}
   closure_rule: {{findings.closure_rule}} | OPTIONAL
6. Communications
   recipients: {{comms.recipients}}
   confidentiality_rule: {{comms.confidentiality_rule}} | OPTIONAL
7. Telemetry
   audits_completed_metric: {{telemetry.completed_metric}}
   findings_closed_metric: {{telemetry.closed_metric}} | OPTIONAL
8. References
   Control matrix: {{xref:COMP-02}} | OPTIONAL
   Evidence plan: {{xref:COMP-09}} | OPTIONAL
   Investigation workflow: {{xref:AUDIT-06}} | OPTIONAL

Cross-References
Upstream: {{xref:COMP-09}}, {{xref:SPEC_INDEX}} | OPTIONAL
Downstream: {{xref:SEC-06}} | OPTIONAL
Standards: {{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL

Skill Level Requiredness Rules
beginner: Required. Define report types, cadence, and findings tracking system.
intermediate: Required. Define evidence packaging and intake workflow and telemetry.
advanced: Required. Add auditor access rules and strict confidentiality and scope confirmation rigor.

Unknown Handling
UNKNOWN_ALLOWED: domain.map, glossary.terms, packaging location, scope confirm rule, closure rule, confidentiality rule, auditor access, open_questions
If any Required Field is UNKNOWN, allow only if:
{{standards.rules[STD-UNKNOWN-HANDLING]}} | OPTIONAL
If report.types is UNKNOWN → block Completeness Gate.
If cadence.value is UNKNOWN → block Completeness Gate.
If findings.system is UNKNOWN → block Completeness Gate.
If telemetry.completed_metric is UNKNOWN → block Completeness Gate.

Completeness Gate
Gate ID: TMP-05.PRIMARY.COMP
Pass conditions:
required_fields_present == true
reporting_and_cadence_defined == true
evidence_packaging_defined == true
findings_tracking_defined == true
telemetry_defined == true
placeholder_resolution == true
no_unapproved_unknowns == true